



Go-To-Market Package

Taking a privacy-first personal health record to market — direct to consumer. Strategy, product readiness, consumer-privacy compliance, pricing, competition, and the numbers.

PREPARED	MODEL	TO PAID LAUNCH	RAISE
June 20, 2026	Direct-to-Consumer · Freemium	~5–6 months · ~\$225K	~\$750K–\$1.0M pre-seed

CONFIDENTIAL — INTERNAL & INVESTOR USE

Grounded in direct inspection of the codebase plus live 2024–2026 consumer-market & regulatory research, with an adversarial review pass on every document. All forward-looking figures are labeled (*estimate*) or (*illustrative*). OwnMyHealth currently holds no security certifications and has no self-serve billing; nothing herein claims otherwise.

Contents

Ten sections — an overview index plus nine standalone briefs.

OVERVIEW	Package Overview & Index How to read this package, headline numbers, and what the research changed.
SECTION 00	Executive Summary The recommendation, the three gates, headline numbers, next steps.
SECTION 01	Go-To-Market Strategy Positioning, target consumer, the organic growth motion, activation & retention, phased launch.
SECTION 02	Product Readiness Checklist Prioritized P0/P1/P2 demo→market-ready gaps — billing, PWA, MFA — with acceptance criteria.
SECTION 03	Consumer Privacy & Compliance Roadmap FTC HBNR + state law (the primary regime), why HIPAA is generally N/A, app-store policy, SOC 2 as optional trust.
SECTION 04	Pricing & Monetization Freemium-now design, price points, the AI/OCR variable-cost floor, the planned paywall experiment.
SECTION 05	Competitive Landscape Consumer competitors (Function, Apple Health, ChatGPT Health, cost tools), the white space, the moat.
SECTION 06	Cost-to-Market & Financial Model Cost-to-launch, operating costs, a 24-month subscription funnel, unit economics, funding ask.
SECTION 07	Consumer Value Proposition A one-page consumer-facing value-prop sheet — landing-hero plus investor blurb.
SECTION 08	Risk Register Prioritized risks + mitigations + go / no-go kill criteria.

OVERVIEW

Package Overview & Index

Generated 2026-06-20. A board/investor-ready GTM package grounded in (a) direct inspection of this codebase, (b) live 2024–2026 consumer-market & regulatory research, and (c) an adversarial review pass on every document (hunting compliance overclaims, readiness overclaims, unsupported numbers, and any B2B/employer-channel drift).

Honest framing throughout: OwnMyHealth is a real, security-forward asset (~96K LOC; verified Postgres row-level security + per-user AES-256-GCM encryption core) but is — by its own UX review — a *“polished demo, not yet a trustworthy daily health record.”* It holds **no certifications** (only the Anthropic BAA is signed), has **no self-serve billing**, **no mobile app/PWA** (web-only), and **no MFA**. Nothing here claims otherwise. All market figures are cited to the research brief; all forward-looking numbers are labeled (estimate) / (illustrative) .

The recommendation in one line

Go to market as a pure direct-to-consumer subscription app — freemium now, with a planned experiment to test a harder paywall later — and win on the one position no competitor occupies: **an AI guide that reasons over your own longitudinal health record and your real insurance costs, in one private place**. Not lab testing (Function owns it), not raw record aggregation (Apple/Epic own the rails), and not “AI chat over your records” (commoditized Jan 2026). Grow **organic-first** (content/SEO, referral, community) — never paid-first.

Headline numbers (all illustrative; assumptions stated in the docs)

Metric	Figure
Cost to reach paid-launch readiness	~\$225K (range \$170K–\$340K)
Time to public paid launch	~5–6 months (two eng tracks; single-track → 7–8 mo)
Recommended raise	~\$750K–\$1.0M pre-seed SAFE
24-month base-case ARR run-rate	~\$128K (bear \$42K → bull \$235K); ~1,150 paying subs
Unit economics (organic-led)	LTV:CAC ~3.0–3.5:1, blended CAC ~\$25, payback ~3–4 mo
Pricing	Free to start → Premium \$9.99/mo or \$69.99/yr (annual is the retention lever)
Differentiation window	~12–24 months before a ChatGPT-Health-class incumbent could close the seam

Documents

#	File	What it is
00	00-EXECUTIVE-SUMMARY.md	The recommendation, the three gates, headline numbers, next steps — read first

#	File	What it is
01	01-GTM-STRATEGY.md	Positioning, target consumer, the organic growth motion, activation/retention, phased launch, metrics
02	02-PRODUCT-READINESS-CHECKLIST.md	Prioritized P0/P1/P2 demo→market-ready gaps (incl. billing, PWA, MFA) with acceptance criteria
03	03-COMPLIANCE-ROADMAP.md	FTC HBNR + state law (the primary regime), why HIPAA generally N/A, app-store policy, SOC 2 as optional trust
04	04-PRICING-AND-MONETIZATION.md	Freemium-now design, price points, the AI/OCR variable-cost floor, the planned paywall experiment
05	05-COMPETITIVE-LANDSCAPE.md	Consumer competitors (Function, Apple Health, ChatGPT Health, cost tools), the white space, the moat
06	06-FINANCIAL-MODEL.md	Cost-to-launch, operating costs, a 24-month subscription funnel, unit economics, funding ask
07	07-PITCH-ONE-PAGER.md	Consumer-facing value-prop one-pager (landing-hero + investor blurb)
08	08-RISK-REGISTER.md	Prioritized risks + mitigations + go/no-go kill criteria
	OwnMyHealth-Go-To-Market.pdf	All of the above, typeset as one branded PDF

Three things the research changed (worth knowing before reading)

1. **“AI over your records” got commoditized in Jan 2026** (ChatGPT Health, Copilot Health, Perplexity Health, Claude for Healthcare). The defensible wedge is the *cost-navigation + record fusion* — “understand your health AND what your care will cost” — and the window to own it is ~12–24 months.
2. **For a pure consumer PHR, the FTC Health Breach Notification Rule + state laws are the primary regime — not HIPAA** (HIPAA generally doesn’t apply to a consumer-controlled record absent a provider/FHIR Business-Associate path). Washington’s My Health My Data Act carries a **private right of action**. **SOC 2 / HITRUST are optional trust signals, not launch gates** — there’s no enterprise buyer demanding them.
3. **The real launch blockers are on the commercial surface, not the engine.** The technical security core is strong; what’s missing is **self-serve billing (Stripe)**, a **mobile/PWA** experience (it’s web-only), **MFA**, and the **OCR spend cap** (H-3). Closing those P0/P1 seams — plus minimal privacy counsel — is the ~\$225K / ~5–6-month path to a chargeable product.

Executive Summary

Board / Investor Brief · Prepared 2026-06-20 · Pure Direct-to-Consumer

The Recommendation

Take OwnMyHealth to market as a pure direct-to-consumer (D2C) subscription app, launched freemium-first with a planned pricing experiment to test a harder paywall once retention data exists — and win on the one position no competitor occupies: an AI guide that reasons over your *own* longitudinal health record AND your *real* insurance costs in a single loop. Do not compete on lab testing (Function is well-capitalized — reportedly a ~\$2.5B valuation, Nov 2025, per PRNewswire — and wins that rail), on raw record aggregation (Apple, Epic, b.well own the rails), or on “AI chat over your records” — that was commoditized in January 2026 by ChatGPT Health, Copilot Health, Perplexity Health, and Claude for Healthcare. The defensible wedge is the **fusion plus the consumer cost-navigation angle**: *“understand your health AND what your care will cost, in one private, member-owned place.”*

The strategic logic is simple. Every health/AI player (Function, Apple, Perplexity, ChatGPT) starts from your health data and either ignores cost or merely *interprets* an insurance document. Every cost player (GoodRx, Sidecar, Sheer Health, Goodbill) starts from the bill or the plan and has zero visibility into your labs, conditions, or biomarker trajectory. **The seam between “where am I trending” and “what will it cost / how do I pay less” is unowned.** (*Competitor positioning here is analyst assessment, not a brief-supplied fact.*) ChatGPT Health is the only player adjacent to it — making it the strongest future threat and putting a window on the opportunity of an estimated **12–24 months** (estimate).

What OwnMyHealth Is

OwnMyHealth is a member-owned, encrypted personal health record that fuses three things competitors keep separate: (1) a **longitudinal biomarker + lab record** — drop in a lab PDF or sync Quest, and biomarkers are auto-extracted, tracked over time as a real time series, and flagged when out of range; (2) **insurance and cost navigation** — Summary-of-Benefits parsing, deductible/out-of-pocket projection, and AI cost analysis over the user’s actual plan; and (3) an **AI guide grounded in the user’s own data**. It is a genuinely deep single-player product — ~96,000 lines of production code, 19 data models, built over ~7 months and carrying a traditional-firm rebuild value of roughly **\$850K–\$1.1M** (most-likely; range \$600K–\$1.5M) as an asset. Its technical security core is strong: Postgres FORCE row-level security, per-user AES-256-GCM field encryption, audit logging, JWT rotation. The gaps are not in the engine — they are in the *commercial and consumer-trust surface*.

The Three Gates — Where We Honestly Stand

We sequence launch through three gates. Honest status below; **the product is a “polished demo, not yet a trustworthy daily health record,” holds no certifications (only the Anthropic BAA is signed), and is not HIPAA/SOC 2/HITRUST-attested today.**

Gate	What it requires (D2C)	Honest status
1 • Compliance / Legal	Primary regime is the FTC Health Breach Notification Rule (2024 amendments; civil penalties up to ~\$51,744/violation, indexed annually — FTC/Federal Register 2024) + state laws — Washington My Health My Data Act has a private right of action , plus CCPA/CPRA. HIPAA generally N/A for a consumer-controlled PHR. Plus app-store health policies, consumer privacy posture, AI medical-advice disclaimers. SOC 2 / HITRUST are <i>trust signals, not sales gates</i> for a consumer audience.	Partially met. Strong encryption/RLS core, but: vendor BAAs unconfirmed for services that touch PHI (Google Cloud, Document AI, Quest, SendGrid); legacy plaintext PHI residue in prod (filename backfill not run); no breach-detection alerting; no published consumer Privacy Policy / ToS / standalone consumer-health-data policy; stale README audit claims to retract.
2 • Product Hardening	Demo → trustworthy daily record, <i>plus</i> D2C essentials: self-serve billing, onboarding/activation, retention loops, and mobile/PWA.	Largely unmet on the commercial surface. No Stripe — the “Upgrade” button is a “contact us” stub (a launch blocker). No MFA. No mobile app or PWA (web-only — a real D2C gap). Two open High issues: H-3 (Document AI OCR spend uncapped) and H-2 (FHIR needs <code>--max-instances=1</code> until Redis). Five PHI-path controllers untested. Known trust-breakers reported fixed but unverified end-to-end .
3 • Distribution / Growth	Consumer growth: content/SEO, referral/virality, community, creator/influencer, ASO, and lab/wearable/telehealth partnerships. Not paid-first.	Unbuilt. No referral/invite system, no patient-initiated sharing, no public pricing/landing surface, no push/PWA re-engagement. Retention rests entirely on an email scheduler. No viral loop exists yet.

Headline Numbers

Dimension	Read
Differentiated wedge	The only consumer product whose AI sees both your longitudinal clinical/biomarker data <i>and</i> your claims/deductible/bills/Rx costs, using each to inform the other. White space assessed vacant (analyst view); window ~12–24 months (estimate).
Asset value (context, not spend)	~\$850K–\$1.1M most-likely rebuild cost; ~96K LOC already built.
Cost to reach first paying cohort	~\$120K–\$220K (illustrative): Stripe + self-serve billing, MFA, breach alerting, OCR cost cap, PHI backfill, PWA, privacy counsel for HBNR/state-law/AI-disclaimers (~\$20–60K), plus legal artifacts. Excludes optional trust spend (SOC 2 \$25–45K, pentest \$10–20K — benchmark estimates) which are not launch gates.

Dimension	Read
Time to first paying cohort	~3–5 months (estimate), gated by closing the seven P0 blockers below.
Target CAC/LTV shape	Organic/referral/content-led, NOT paid-first. Target paying CAC ~\$30–60 (research anchor); fully-loaded LTV:CAC $\geq 3:1$ (4–6:1 reported typical for health/wellness — industry estimate). Pricing anchors and trial length under “Monetization” are illustrative experiment inputs, not settled.
Monetization model	Freemium now (manual entry + document vault, minimal AI/OCR) → Premium unlocks AI guidance, OCR/AI extraction, insurance cost analysis, FHIR lab-connect. Then test a harder paywall later (hard paywalls convert ~5x better — 10.7% vs 2.1%, RevenueCat research anchor — but freemium builds top-of-funnel + trust first). Push annual plans (~68% adoption; 40–60% better retention — research anchors). Maps to existing FREE/PRO plan-gating infra; billing not yet wired . Illustrative anchors to validate: ~\$69.99/yr + ~\$9.99–12.99/mo with a longer (17–32 day) trial (estimates — longer trials reportedly out-convert short ones; to be A/B-validated).
Market context	SAM anchored on US mHealth apps (~\$12B, ~11% CAGR — Grand View Research 2024, third-party estimate), deliberately <i>not</i> the broader “digital health” headline (~\$140B US / ~\$493B global — IMARC/Nova One 2024–25, directional). Adjacent feature value: PHR software (~\$10B global, low-single-digit growth — Research and Markets 2025) and consumer price-transparency (~\$2B, B2B-skewed — The Business Research Company 2025). All market-sizing figures are third-party, definition-sensitive estimates.
Consumer tailwinds	34% of covered workers now hold \$2,000+ single-coverage deductibles (KFF 2025 Employer Health Benefits Survey); 57% of individuals used an app — not just a portal — to access records in 2024 (ASTP/ONC Data Brief No. 77, 2025). Both are primary-source consumer-demand signals, not a B2B channel.
VC climate	Best since 2022: US digital-health VC ~\$14.2B in 2025, +35% YoY, with AI taking ~54% of dollars (Rock Health 2025 Year-End, Jan 2026). Consumer/wellness re-rated from the 8th- to 3rd-most-funded value proposition (same source).

Three hard truths we confront head-on, not bury: (1) brutal CAC (~\$30–60/paying sub — research anchor) and weak free retention (~3–8% day-30 — research anchor) — so we engineer cheap organic/referral/content growth and a sticky daily-use wedge, never paid-first; (2) the Jan-2026 commoditization of generic AI-over-records — we win on cost-navigation + record fusion; (3) consumer-PHI trust *is* the product — one breach or FTC action ends a consumer health startup.

What We Do Next

- 1. Close the seven launch-blocking P0s** before any paying consumer: wire **Stripe self-serve billing**; **build (or verify, if present) self-serve data export + account deletion** — required by WA MHMDA/CCPA and app-store policy, status in codebase unconfirmed; add **TOTP MFA + recovery**; stand up **breach-detection alerting + a named Security Officer + breach runbook**; confirm **vendor BAAs** (Google Cloud, Document AI, Quest; SendGrid PHI-free or swapped); run the **plaintext-PHI backfill**; and **cap Document AI OCR spend** (H-3) to prevent a runaway vendor bill as upload volume scales.
- 2. Publish the consumer legal + trust surface:** standalone consumer Privacy Policy, Terms, and a **Consumer Health Data Privacy Policy** (WA/NV); prominent, *true* “we never sell or share your health data for advertising” promise (legally enforceable post-GoodRx); AI medical-advice disclaimers; retract stale README audit claims.

3. **Ship an installable PWA** (manifest, service worker, web push, “add to home screen” coaching) to close most of the web-only retention/engagement gap cheaply; defer native until HealthKit/App-Store discovery becomes conversion-limiting.
4. **Make the bucket not leak:** instrument activation, engineer onboarding to drive **3+ sessions in the first 14 days** (the #1 churn predictor — Adapty research), fix the placebo onboarding steps, and add a real re-engagement loop (trends/new-result/reminder) before spending a dollar on acquisition.
5. **Stand up the freemium funnel + pricing experiment infrastructure:** onboarding-placed paywall echoing the user’s stated health goal, annual-anchored pricing with a longer trial, and A/B tooling to later test a harder paywall on **new-install cohorts only** (grandfather free users; decide on ARPU/LTV at Day 60). Treat all specific price points and trial windows as hypotheses to validate, not commitments.
6. **Build owned, compounding growth engines** (months 1–6, in parallel): **content/SEO + programmatic** biomarker/cost pages and free calculators (Flo’s content engine reportedly drives ~6M monthly visitors — Growth Case Studies 2024); **founder/clinician authority** on the health-podcast circuit; **ASO**; and a **double-sided, activation-gated referral loop** (Whoop reports referral driving >10% of sign-ups — Talkable 2022). Add **wearable/lab partnerships** via an aggregator for stickiness. **Paid is a throttle applied last, only after LTV:CAC clears 3:1.**
7. **Harden the seams that break trust:** verify the reported trust-fixes end-to-end, add tests to the five untested PHI-path controllers, and provision **Redis** to remove the `--max-instances=1` pin (unblocking autoscale, exact spend caps, and reliable FHIR) ahead of a launch spike.

Bottom line: the engine is built and valuable; the go-to-market machine is not. Close seven P0 trust/safety/billing blockers, publish the consumer legal-and-trust surface, ship a PWA, and grow on owned/organic loops — and OwnMyHealth can own the vacant cost-aware-health-copilot position before a big-AI entrant bolts a cost layer onto its record product.

Go-To-Market Strategy

Board / investor working document — v2, 2026-06-20. Pure direct-to-consumer (B2C). No employer, broker, TPA, benefits, or per-employee channel exists anywhere in this plan. Every revenue dollar comes from an individual who signs up, uploads their own records, and pays for their own subscription.

Sourcing note. All external market, competitor, regulatory, and company-specific statistics in this document (e.g., KFF deductible figures, ONC record-access data, Flo/Function/Whoop/Oura company metrics, RevenueCat/Adapty conversion benchmarks, FTC penalty amounts, market-concentration figures) are drawn from the cited sources compiled in the research brief that informed this plan. Figures that are our own planning inferences — not researched data — are explicitly labeled **(estimate)** or **(illustrative)**. Channel CAC ranges are **(estimate)** unless a specific named-company figure is cited.

0. Executive Summary

OwnMyHealth is a **member-owned longitudinal health record fused with insurance cost-navigation**, guided by an AI grounded in the user's *own* data. The defensible wedge is the **fusion** — “understand your health *and* what your care will cost, in one place” — not “AI chat over your records,” which was commoditized in January 2026 by ChatGPT Health, Copilot Health, Perplexity Health, and Claude for Healthcare.

Three facts shape this entire plan, and we confront them head-on rather than bury them:

1. **The economics of consumer health are brutal.** Fully-loaded CAC runs ~\$30–60 per paying subscriber; free-user Day-30 retention is ~3–8%; freemium converts ~5x worse than a hard paywall (2.1% vs 10.7% download-to-paid). We therefore engineer **cheap, organic, content/SEO- and referral-led growth around a sticky daily-use wedge — never paid-acquisition-first.**
2. **Generic “AI over your records” is commoditized.** We win on the cost-navigation rail welded to the health rail — a position no competitor occupies (per the competitive map below).
3. **Trust is the product.** One breach or one FTC action ends a consumer health startup. Our growth motion and our compliance posture are the same artifact.

Honest readiness: the product's own UX review called it “a polished demo, not yet a trustworthy daily health record.” We hold **no certifications** (only the Anthropic BAA is signed). There is **no billing system, no MFA, no mobile app/PWA**, two open High issues, and five untested PHI-path controllers. This document sequences the work to fix that *before* we spend a dollar acquiring a paying customer.

Monetization decision (founder-set): launch **freemium now**, build the funnel and trust, then **test a harder paywall later** once retention data exists. Billing (Stripe) is not yet wired — it is the single largest launch blocker.

On the competitive window: our differentiation is a window, not a permanent moat. ChatGPT Health and Perplexity Health are converging fast from the AI side with enormous distribution. **We treat the window as a finite planning**

judgment — likely one to two years before a big-AI entrant or a cost player bolts on the missing rail — and build to convert it into retention and a trusted brand. This is a strategic judgment, *not* a researched figure (see §1.2).

1. Positioning & The Wedge

1.1 The one consumer outcome we sell

“Drop in your lab PDF — or sync your labs — and instantly see your biomarkers tracked over time, flagged when out of range, explained in plain language, *alongside what your care actually costs under your insurance.*”

We do **not** sell a chatbot. We sell a private, member-owned record where the clinical “why am I trending this way?” and the financial “what will this cost and how do I pay less?” live in **one reasoning loop**. That seam — between health and cost — is the wedge.

1.2 Why this position is defensible (the competitive map)

No competitor owns all four pillars (PHR aggregation + biomarker trends + insurance/cost navigation + AI grounded in your own data):

Player	PHR aggregation	Biomarker trends	Insurance / cost navigation	AI on your data
Function / Superpower / Levels / InsideTracker	weak (upload only)	strong	none	partial (own labs only)
Apple Health Records	strong	weak	none	none
MyChart (Epic)	strong (Epic-bound)	weak	partial (own-provider bills/estimates)	weak
Fasten / b.well / Hugo	strong	weak	none–weak	none (b.well = backend for others)
ChatGPT Health (Jan 2026)	strong (portals)	partial	partial (reads insurance docs, plan trade-offs)	strong
Perplexity Health (Mar 2026)	strong (b.well-backed)	strong (trend dashboard)	none	strong
GoodRx / Sidecar / Sheer / Goodbill / Bluebook	none	none	strong (each a slice)	partial

The unoccupied position is the cost-navigation rail welded to the health rail. Every cost player (GoodRx, Sidecar, Sheer, Goodbill, Bluebook) starts from the *bill or the plan* and has zero visibility into your labs or biomarker trajectory. Every health/AI player (Function, Apple, Perplexity, even ChatGPT) starts from your *health data* and either ignores cost or only *interprets* an insurance document without acting on it. **No competitor connects the clinical “why” to the financial “how much / how do I pay less.”**

Honest threat assessment. ChatGPT Health already reads insurance documents and reasons about plan trade-offs — it is the player most likely to close the gap, and it has enormous distribution (per the brief, ~230M people ask ChatGPT health questions weekly). Perplexity Health already ships three of our four pillars (PHR + trends + AI), missing only the cost rail. **Our differentiation is therefore a window, not a permanent moat.**

On the size of that window (planning judgment, NOT a researched figure): We plan around a **finite window of roughly one to two years**. This is our own estimate, derived from a single stated assumption — *the typical time for a large-AI player or a funded cost-navigation player to design, build, and ship a new vertical feature (a cost rail, or a health/biomarker rail) into an existing product*. No source supplies a “12–24 month” number; it is a planning assumption, not data, and the plan’s “speed on the gates” logic should be read as “move before a well-resourced competitor can plausibly span the seam,” not as a precise countdown.

1.3 Strategic guardrails

- **Do NOT compete on biomarker testing.** Function’s war chest wins that; we treat lab draws as an *ingested input*, like Perplexity and ChatGPT do.
- **Do NOT compete on raw record aggregation.** Apple/Epic/b.well own those rails; we ingest from them.
- **DO own the cost-aware health copilot** — the only consumer product whose AI sees both your longitudinal clinical/biomarker data *and* your claims/deductible/bills/Rx prices, using each to inform the other.

1.4 The Ideal Customer Profile (who feels this pain most)

We prioritize three concentric consumer segments. The wedge is sharpest where *health complexity* and *cost exposure* overlap.

Primary ICP — the high-deductible chronic-condition manager. This person has both a recurring clinical reason to track data *and* real financial skin in the game:

- **34% of covered workers now have a \$2,000+ single-coverage deductible** (up 77% over 10 years; KFF 2025), and the average single deductible is **\$1,886** — so out-of-pocket cost is now the consumer’s problem, not the plan’s.
- **41% of US adults carry medical/dental debt**; ~half could not pay an unexpected \$500 medical bill (KFF). Pain is acute and broad.
- **58% would price-shop healthcare if they knew costs upfront** — but **64% have never done so** (Fierce Healthcare, 2024). Large latent demand; we make the latent behavior easy.
- They generate fresh lab data several times a year (labs, refills, follow-ups), which feeds the longitudinal trend hook that drives retention.

Secondary ICP — the longevity / quantified-self consumer.

- Individuals are 35% of the **\$27.6B longevity market** (SNS Insider, 2025); proven willingness to pay (~\$6/mo Oura benchmark; Function \$365/yr; Superpower \$199/yr).
- Already uploads labs and wants trends + interpretation. We are *not* their testing provider; we are the private record that unifies whatever they test, plus the cost layer they currently lack.

Tertiary ICP — the caregiver / proxy.

- Proxy/caregiver record access doubled to **51%** (from 24% in 2020; ONC 2024). An adult managing a parent’s or child’s labs *and* bills feels the fusion pain double. **Important constraint:** there is **no family/multi-member account model in code today** — a single account with higher numeric limits is not a family product. This segment is a **v2 target, not a launch claim**; we serve it only when the multi-member account model ships (see §5, §7.2).

Why this ICP order: the high-deductible chronic manager has the tightest health-AND-cost overlap, the most frequent fresh-data events, and the clearest “this saved me money / explained my result” moment — the strongest fuel for word-of-mouth and retention.

2. The Consumer Growth Motion

2.1 Core thesis: organic-first, paid-last

The companies that won consumer health *cheaply* — Flo, Function, Levels, Oura, Whoop — did **not** win on paid acquisition. They won on three compounding, low-marginal-cost engines: **(1) a credible founder/creator voice, (2) content/SEO capturing the enormous “is my [biomarker] normal?” search demand, and (3) word-of-mouth + referral fed by genuine retention.** Word-of-mouth is *Flo’s largest traffic driver* and a top driver for Function. Paid is a scaling throttle applied late, never the foundation.

2.2 Why paid-first is dangerous (confront, don’t bury)

1. **The leaky bucket.** With ~3% Day-30 retention for health & fitness apps and ~9.2% monthly churn, paid-acquired users churn before we recoup CAC. Paid only works *after* retention is fixed.
2. **CAC inflation + signal loss.** Cross-channel CAC rose **40–60% from 2023→2025**; post-ATT Meta CPAs rose 20–40% with conversion-reporting accuracy down 30–50% for DTC.
3. **Health-data targeting is restricted.** Meta/Google curtail health-condition targeting — the precision paid social relied on is gone for health advertisers (restriction is fact; impact on health CAC is **(estimate)**).
4. **No compounding.** Paid is rented; content/SEO, referral, community, and ASO are *owned* and compound.

Unit-economics guardrail: target **LTV:CAC ≥ 3:1** (4:1–5:1 preferred), CAC payback < 12 months, before any meaningful paid spend.

2.3 Channel CAC cheat-sheet (sequenced priority)

Priority	Channel	CAC range (D2C health)	Confidence	Time-to-impact	Compounds?
1	Content / SEO + programmatic	\$0–\$50 amortized, →~\$0 at scale	estimate (high-intent health queries far below SaaS \$290 baseline)	6–12 mo lag	Yes
1	Founder / creator-led earned media	~\$0 marginal	estimate	depends on audience	Yes

Priority	Channel	CAC range (D2C health)	Confidence	Time-to-impact	Compounds?
2	Referral / virality	\$20–\$150	estimate (anchored to \$150 SaaS referral floor)	slow ramp	Yes
2	Community	low (mostly time)	estimate	slow	Yes
2	ASO (once a PWA/app exists)	near-\$0 marginal	fact-anchored	medium	Yes
3	PR / Product Hunt launch	one-time spike, low \$/user	estimate	instant, non-recurring	No
3	Micro-influencer + CPA affiliate	\$40–\$120	estimate	medium	partial
3	Partnerships (labs / wearables / telehealth)	variable, often rev-share	estimate	medium-slow	partial
4 (last)	Paid search (Google)	\$70–\$300+	estimate (general paid-search ~\$70 baseline; health inflates)	instant, non-compounding	No
4 (last)	Paid social (Meta)	\$150–\$400+ post-ATT	estimate (FB ~\$230 baseline)	instant, non-compounding	No

These ranges are **(estimate)** unless a specific company figure is cited; the underlying benchmarks (SaaS referral floor, FB/Google paid baselines, CAC inflation, iOS/Android CPI) are from the cited sources in the brief.

2.4 Channel playbooks

① **Content / SEO + programmatic — the cheapest scalable engine.** Consumer health is search-demand-rich: every biomarker, symptom, lab value, and supplement is a query with weak incumbent content. The category leaders are content companies that sell a subscription. **Flo built a 100+-article library plus 9 free calculators driving 6M monthly visitors from search** with minimal ad spend.

Tactics:

- **Pillar-cluster** on our 3–5 core conditions/biomarkers (“the ultimate guide to [LDL / HbA1c / TSH]” → 15–30 cluster articles).
- **Programmatic templates** for the long tail: one page per biomarker (“What is a normal [ferritin] level — and what does the test cost?”), each fusing the *health* answer with the *cost* angle (our wedge baked into SEO).
- **Free interactive tools/calculators** — highest-ROI programmatic asset; they earn backlinks and rank. A cost-estimator-by-biomarker tool is our Flo-calculator move *and* a demo of the wedge.
- **AEO/GEO** — optimize for AI-answer surfaces (the 2026 frontier).
- **⚠️ YMYL compliance caveat:** Google holds health (“Your Money or Your Life”) content to higher E-E-A-T standards. **Attribute content to a credentialed clinician and cite primary literature**, or it won’t rank — which dovetails with the founder-credibility play below.

Economics: amortized CAC **\$0–\$50**, approaching zero at scale; **6–12 month lag** before traffic compounds. Seed-stage target: **1,000–5,000 monthly organic visitors within 12 months** (per brief benchmark).

② **Founder / creator-led earned media — the category cheat code.** A credible health voice generates massive earned reach at ~\$0 marginal CAC. Function rode Dr. Mark Hyman's 2.5M IG following (~40k → 200k+ members in a year); Levels deliberately turned co-founder Casey Means into a ~1M-follower voice via the podcast circuit (Rogan, Huberman). **If we lack a famous founder, we manufacture authority (estimate):** put our clinical founder/advisor on the health-podcast circuit and niche condition podcasts, publish under their byline (which also satisfies the YMYL/E-E-A-T need), and build *their* audience as a company asset. This is the cheapest reach in the category but requires a genuinely credible voice.

③ **Referral / virality — the WOM amplifier.** WOM is already the biggest channel in this category; a referral program instruments and amplifies it. **80% of sharing happens via "dark social" (WhatsApp/text)** — which is exactly why Flo's top referral source is WhatsApp. **Whoop's double-sided referral (advocate gets 1 free month, friend gets \$30 off) drives >10% of new sign-ups.**

Tactics: double-sided incentive (give-a-month / get-a-discount); make sharing native to a *result* ("share your in-range win" / "I found a \$X cheaper lab"); WhatsApp/SMS-first share sheets; **gate the reward on the referred user activating, not just installing**, to protect economics. Target K-factor 0.15–0.25 (good) → 0.4 (great); realistically we engineer a sub-1 K-factor that lowers *blended* CAC, not true virality. **Critical gap:** the product today has **zero referral/invite code and provider-sharing is inbound-only** (a provider must request; a patient cannot invite their own doctor or family) — this must be built (see §5).

④ **Community.** Levels treats "community as a growth strategy" (its \$38M Series A was "driven by member and community alignment"). Community is slow, low-CAC, and deepens the retention that feeds WOM. Tactics: a focused chronic-condition/cost-savings hub (Discord/Circle), member challenges (Strava's "Challenges" lifted 90-day retention 18%→32%), and spotlighting member "this explained my result / saved me money" stories as both content and referral fuel.

⑤ **Micro-influencer + CPA affiliate.** Distinct from founder fame: *paid/incentivized* creator distribution. Oura gifts rings to value-aligned creators (millions of organic impressions; blended CAC ~\$50–80); Whoop runs affiliates on a **CPA model** (pay only on conversion). Tactics: prioritize **micro-influencers (10k–100k)** in chronic-condition and longevity niches over mega-creators (cheaper, higher trust); **gift-then-affiliate**; structure everything as **CPA, not flat-fee** so spend is acquisition-locked. CAC **\$40–\$120 (estimate).**

⑥ **PR / Product Hunt launch — a one-time spike, not a channel.** Ash (AI mental health) hit #1 Product of the Day by pre-seeding supporters in relevant communities. The win is made *before* launch day: line up our community/waitlist to upvote in the first hours, pair with a press angle (a striking cost-data finding, or the founder-credibility story), and **convert the spike into email captures, not just installs.**

⑦ **Partnerships (labs / wearables / telehealth) — retention & credibility first, distribution second.** The category converged in 2025 on "always-on infrastructure linking sensors + software + labs" (Oura Health Panels, Whoop lab panels, Function↔Quest+Ezra). For us (estimate):

- **Wearable data sync** (Apple Health / Oura / Whoop / Garmin, via an aggregator like Junction) makes the app stickier and more shareable.
- **At-home lab-kit integration** creates a recurring "result moment" that fuels WOM and re-engagement.
- Structure as **rev-share / affiliate (pay-on-conversion)** to keep CAC variable.
- *This is a "future/adjacent" lane only* — labs, wearables, and telehealth are legitimate partnerships; there is **no employer channel here or anywhere.**

3. Activation & Retention Loops

Retention — not conversion — is the binding constraint. The best-converting health categories also churn fastest. The single most predictive churn signal is **<3 sessions in the first 14 days → 3–4× churn**. Everything below is engineered to beat that.

3.1 Onboarding → first value

The activation moment is: drop a lab PDF → see extracted biomarkers + out-of-range flags in seconds. The signup→first-value path already exists in code (register → email-verify → 4-step wizard: welcome → upload lab → health profile → done), and it is reasonably complete. But it has real gaps to close before we drive traffic to it:

- **Email verification is a hard wall** (login fails until the link is clicked). This is a known funnel choke point and the prior UX review flagged a “dead registration-verification funnel” — must be walked end-to-end and confirmed working before launch.
- **First value depends on the user having a lab PDF**, and auto-sync is **Quest-only and PRO-gated**. We must add a **sample/demo path** (e.g., “try it with a sample lab”) so an empty account isn’t a dead end.
- The prior UX review flagged a **“placebo OCR review step”** and **“health-goal create 100% dead”** (remediated per changelog but **unverified end-to-end**). Placebo steps in onboarding are trust-killers exactly where trust is being established — **verify before driving acquisition**.

Activation target metric: “added or extracted first biomarker within session 1,” plus engineering the email+push sequence to drive **3+ meaningful sessions in the first 14 days**.

3.2 Habit / notification / fresh-data mechanics

The durable retention engine for a *record* app is **showing the user something new and personal each session** — trends over time, a new reading, progress against their own baseline — plus **timely reminders**. Critically, the biomarker layer is structurally a **real time series** (latest value + history, oldest-first), so the longitudinal trend hook — the retention product — is sound.

Mechanics to build/strengthen:

- **Fresh-data hooks:** “your new result is ready,” “your LDL moved since last draw,” weekly trend summary. The lifecycle email engine already ships (weekly summary, goal reminders, out-of-range alerts, new-results, plan-expiring) — this is the *primary retention loop today* and it is genuinely shipped and multi-instance-safe.
- **The biggest retention gap is re-engagement reach:** the app is **web-only with no push**. Email is the *weakest* channel for a web app. Closing this (PWA + web push, then native) is the single highest-leverage retention investment (see §5).
- **Light gamification (estimate on magnitudes — secondary sources):** streaks/milestones can lift DAU and cut 30-day churn; per the brief, a 7+ day streak correlates with ~2.3× daily engagement. Add a simple streak/“in-range %” progression — *without* dark patterns, given the trust-sensitivity of health data.
- **Stickiness target:** utility/health DAU/MAU of **20–30%**.

4. Messaging Pillars (anti-“just another AI chat”)

Every message reinforces the fusion and the trust posture, and explicitly *avoids* positioning us as a chatbot.

Pillar	The message	Proof / why it lands
1. Health + cost in one place	“Understand your health <i>and</i> what your care will cost — together.”	The unoccupied competitive position; no rival fuses the two.
2. You own it	“Your record. Your data. Private, encrypted, exportable, deletable — anytime.”	Member-owned PHR; export/delete are always-on every tier. Trust is the product.
3. Grounded in your data	“Plain-language answers from <i>your</i> labs and <i>your</i> plan — not the internet.”	Differentiates from generic AI-over-records; AI is grounded in the user’s own record.
4. We never sell your data	“We do not sell or share your health data for advertising. Ever.”	A <i>conversion lever</i> (per the brief, 83% of consumers rank data protection as a top trust factor; 71% would quit a company that shared sensitive data) — and legally load-bearing under the FTC HBNR post-GoodRx. Only make this claim if architecture guarantees it.
5. Built for the cost you actually pay	“See your real out-of-pocket cost under <i>your</i> deductible — before the bill.”	Speaks to the 34%-with-\$2,000+-deductible reality; 58% would shop if they knew costs upfront.

Explicit anti-positioning: we never lead with “AI chat.” The chatbot is a *feature inside* a cost-aware health record, not the product. Leading with “AI over your records” puts us in a fight with ChatGPT/Perplexity/Claude-for-Healthcare we cannot win.

Trust-signal messaging discipline (honesty rule): we hold **no certifications** (only the Anthropic BAA is signed). We **do not claim HIPAA, SOC 2, or HITRUST compliance** — none are in place. We may truthfully market the *technical* posture we have built (per-user AES-256-GCM field encryption, Postgres FORCE row-level security that fails closed, 7-year audit logging, JWT rotation/revocation), and we must **retract the stale README claims** (“Last Audit Jan 2025 / 0 findings,” “fully encrypted”) before any public marketing. SOC 2/HITRUST are *future* trust signals for a consumer audience — not sales gates and not present-tense claims.

5. Phased Launch Sequence — Three Gates, In Order

Gates run in order; growth spend (\$2) does not begin until Gate 3. This is grounded in the readiness gap list and the regulatory regime in the brief.

Readiness callout — severity legend (so this checklist is self-contained for a board reader):

- **H-2 (open High):** FHIR multi-instance correctness breaks across instances; forces `--max-instances=1` until Redis is provisioned (blocks autoscale + exact spend caps).
- **H-3 (open High):** Google Document AI / OCR dollars are *not* tracked against the budget; the \$50/day cap bounds only Claude tokens, so OCR spend is effectively uncapped.
- **L24 (High-rated compliance residue):** legacy `user_files.original_filename` is still **plaintext PHI in production**; filenames routinely embed patient names/dates.
- **M12 / M13 (Medium):** documented plan-limit *bypass* — a free user can exceed plan caps; must be closed before charging.
- **Quota TOCTOU (Medium, accepted):** concurrent requests can overshoot a limit by N-1; backstopped today by the dollar cap.

Gate 1 — Compliance / Legal (the primary regime is FTC + state law, NOT HIPAA)

The legal characterizations below reflect our working read of the regime and the cited enforcement precedents in the brief; they are **subject to review by privacy counsel before launch**, not settled legal opinion.

For a pure consumer-controlled PHR, **HIPAA generally does not apply** (the user supplies data directly; consumer-directed FHIR does not, by itself, create a Business-Associate relationship). Our counsel's working read of the primary regime is:

- **FTC Health Breach Notification Rule (incl. 2024 amendments).** A consumer-uploaded PHR that *also* pulls FHIR **likely meets** the "multiple sources" test, which would make **HBNR our primary federal obligation** (subject to legal confirmation). The 2024 rule makes **unauthorized disclosure (e.g., ad-tracker sharing) itself a reportable breach**; per the brief, penalties run up to ~\$51,744/violation, indexed annually. Notice ≤60 days; simultaneous FTC notice at 500+ individuals.
- **State consumer-health-data laws. Washington MHMDA carries a private right of action** (first class action filed Feb 2025; recovery is WCPA actual damages trebled up to a \$25,000 cap — *not* statutory per-violation damages) and requires a **standalone Consumer Health Data Privacy Policy** + separate collect/share/sell consents + a geofencing ban. **Nevada SB 370** is parallel (AG-enforced). **CCPA/CPRA** treats health data as Sensitive Personal Information, with new ADMT/risk-assessment rules relevant to our AI (effective 2026).
- **FTC enforcement pattern to design against (penalty figures per the brief):** GoodRx (\$1.5M, HBNR), BetterHelp (\$7.8M, FTC Act §5), Premom (\$100k, HBNR), Flo (FTC Act §5). The recurring trigger across all four is **third-party ad/analytics trackers firing on health data without consent**. This is our single highest-probability enforcement vector.

Gate 1 checklist (must close before any paying consumer):

- [] **Audit every SDK/pixel/tracker** — no Meta Pixel, Google Analytics, or ad SDK firing on health data without explicit opt-in consent. (*This is the #1 enforcement vector — the GoodRx/BetterHelp/Premom/Flo failure mode.*)
- [] Publish a **general Privacy Policy + ToS + a standalone Consumer Health Data Privacy Policy** (WA/NV); identical privacy-policy URL across web/app.
- [] **AI medical-advice disclaimer** ("not a medical device; does not diagnose, treat, or prevent; consult a professional"), with marketing language consistent with the wellness positioning (FDA judges the totality of

claims).

- [] **Breach-response runbook** + a named **Security Officer** (pulled forward from the otherwise-deferrable HIPAA paperwork because the HBNR breach clock cannot start without breach *detection*).
- [] **Confirm vendor BAAs for the services that actually touch PHI** — Google Cloud (Cloud SQL/GCS/Document AI), Quest, SendGrid are all currently *unconfirmed*. **SendGrid is not HIPAA-eligible** → restrict to provably PHI-free email or swap to Paubox/LuxSci. (Only the Anthropic BAA is signed today.)
- [] **Run the L24 plaintext-PHI backfill** — `user_files.original_filename` is still plaintext in prod (filenames embed patient names/dates); run the maintenance job, then drop the plaintext column.
- [] Working **data access / export / deletion** end-to-end (consumer legal expectation + the strongest health-trust signal), verified by a manual run-through.

Note on SOC 2 / HITRUST: these are **trust signals for a consumer audience, not sales gates** — there is no enterprise buyer demanding them. We do **not** over-budget them as blockers. SOC 2 is a reasonable *post-launch* trust investment; neither is a present-tense compliance claim.

Gate 2 — Product Hardening (demo → trustworthy daily record + D2C essentials)

The technical core is strong (encryption, FORCE RLS, audit, BAA gates). The gap is the *commercial and consumer-trust surface*. In rough priority:

- [] **P0 — Self-serve billing (Stripe), PRO only at launch.** The “Upgrade” button is a placebo (“Upgrades are not available yet. Contact us to upgrade manually.”); plans are admin-assigned. **No checkout = no D2C product, and a fake CTA erodes trust on first contact.** Done when a consumer can **self-subscribe to PRO**, a webhook updates `users.plan` / `planExpiresAt`, downgrade/cancel/failed-payment are handled, and receipts are emailed. **TEAM self-subscribe is explicitly v2** — it ships only alongside the multi-member/family account model (none exists today; selling TEAM now would sell a product the code cannot deliver).
- [] **P0 — Cap the Document AI / OCR cost path (H-3, open High).** OCR dollars are never recorded against the budget; the \$50/day cap bounds only Claude tokens. The moment billing opens publicly, a runaway/malicious user can drive an unbounded GCP bill. Done when OCR page cost is accrued via usage tracking and fail-closes like the Claude path.
- [] **P0 — MFA + tested account recovery.** This account is the user’s medical record and insurance IDs; account takeover = direct PHI breach. Add TOTP MFA + backup codes + a tested recovery flow.
- [] **P0 — Breach-detection alerting** (also a Gate 1 legal dependency): wire Cloud Logging alert policies to audit anomalies, repeated login failures, and RLS boot-guard FATAL exits, routed to an on-call human.
- [] **P0 — Close the plan-limit bypass (M12/M13) and quota TOCTOU races** before charging — otherwise paid gating leaks.
- [] **P1 — Mobile / PWA.** The app is **web-only — no native app, no PWA, no push**. For a “check my health every morning” product this is the single biggest distribution/retention handicap. **Web-only push reach is ~10–15× worse than native on iOS** (the biggest retention penalty). Ship an **installable, offline-capable PWA (manifest + service worker + web push + “add to home screen” coaching after a value moment)** first; defer native (App Store/Play) to v2 — note Play now requires an **Organization account + D-U-N-S** for health apps (Jan 2026) and HealthKit is native-only.

- [] **P1 — Verify the onboarding/activation funnel end-to-end** (kill the placebo OCR step, dead goal-create, dead verification funnel — remediated but unverified).
- [] **P1 — Provision Redis** to remove the `--max-instances=1` pin (currently required for FHIR multi-instance correctness, H-2, open High) so we can autoscale for a launch spike and enforce exact spend caps.
- [] **P1 — Test the untested PHI-path controllers** (aiChat, fhir, file, labUpload, sbcUpload) — exactly the upload/AI/FHIR seams where prior teardowns found the real bugs.
- [] **P1 — Build the referral/invite + patient-initiated sharing primitives** (today: zero referral code; provider sharing is inbound-only) — prerequisite for the §2 growth loops.
- [] **P1 — Error/crash monitoring** (no observability SDK today) so we learn checkout/upload/sync breaks before a consumer emails us.

Gate 3 — Distribution / Growth

Only after Gates 1–2: execute §2 in sequence — content/SEO + founder authority + ASO first (compounding, owned), then referral/community/CPA-influencer (amplifiers), then lab/wearable/telehealth partnerships, and **paid only last**, as a throttle on a proven machine. **NOT brokers. NOT paid-first.**

6. North-Star Metric & Funnel

6.1 North-star

Weekly Active Records (WAR): the number of users who, in the last 7 days, viewed a fresh personal data point *or* a cost/coverage answer grounded in their own record.

This metric is true to the wedge (fresh data + cost, not raw logins), predicts retention (it captures the “<3 sessions in 14 days” churn signal), and is honest (it cannot be gamed by a vanity install number).

6.2 Funnel & target benchmarks

Benchmarks are health & fitness category figures from the cited sources in the brief; targets are **(illustrative)** planning anchors, not commitments.

Funnel stage	Metric	Category benchmark	Launch target (illustrative)
Install / visit → signup	Signup rate	—	instrument first
Signup → activation	Added/extracted first biomarker in session 1	— (we set this)	≥ 40%
Activation → habit	≥3 meaningful sessions in first 14 days	<3 = 3–4× churn	maximize
Install → trial start	Trial start rate	11.2% global / 14.5% NA	~12–14%
Free → paid (trial)	Trial → paid	39.9%–42.2%	~40%

Funnel stage	Metric	Category benchmark	Launch target (illustrative)
Free → paid (no-trial freemium)	Download → paid	~3.7% freemium / 10.7%–12.1% hard	freemium first
Paid retention	1st renewal	59.2% (H&F)	meet/beat benchmark
Paid retention	Day-30 free retention	3–8% free	beat via fresh-data + push
Economics	LTV:CAC	3:1 min, 3:1–6:1 H&F	≥ 3:1 before paid spend
Economics	Annual mix	60–67% of H&F subs are annual	push annual at the aha moment

Honesty flags (per the brief’s source notes): RevenueCat and Adapty differ on headline numbers (trial→paid 39.9% vs 42.2%; download→paid 10.7% vs 12.1%) — treat as ranges. Market concentration is sobering: **the top 10% of H&F apps capture ~92.6% of category revenue**, and only **~5% reach \$10K revenue in two years**. Retention is getting *harder* (2026 category Year-1 cancellation ~72%). This is why \$3’s retention mechanics, not the paywall model, are the real game.

7. The Freemium → Paywall-Test Sequencing

Decision (founder-set): launch freemium now; test a harder paywall later. The data supports this exact path for a *record* app whose value compounds over days/weeks (you must log/sync data, then see trends) — the opposite of an instant-utility AI app where a hard Day-0 paywall wins.

7.1 Why freemium/trial first

- A hard, no-trial Day-0 paywall would gate users **before** the “aha,” where they will not convert. Health & Fitness is explicitly a **“trial-inclusive”** category.
- Freemium builds the **funnel, trust, word-of-mouth, and the retention data** we need to run a *good* pricing experiment later. The preconditions to harden — proven PMF/retention, runway to absorb a conversion dip, and A/B tooling — are all things we *acquire by launching softer first*.
- Map to the **existing FREE/PRO plan-gating infra** (`requirePlanLimit` / `requirePlanFeature` ; flags like `aiChatsPerDay` , `pdfUploadsPerMonth` , `questFhirIntegration`). Limits are already enforced fresh-from-DB and fail closed to FREE. **Fix the documented plan-limit bypass (M12/M13) and quota TOCTOU races before charging** (see Gate 2). (*TEAM exists in the gating substrate as display-only; it is not a launch SKU — see §7.2.*)

7.2 Concrete launch configuration (illustrative pricing)

- **Free tier:** manual biomarker entry + document vault, minimal/no AI + OCR — enough to build the funnel and trust.
- **Premium (PRO) — the one paid SKU at launch:** unlocks AI guidance, OCR/AI document extraction, insurance cost analysis, and FHIR lab-connect — the wedge value.
- **TEAM / family — NOT a launch SKU.** TEAM is display-only in the plan-gating substrate and there is **no multi-member account model in code**. TEAM self-subscribe is **v2**, shipping only when the family/multi-member

account model is built; we do not sell it at launch.

- **Trial:** a **17–32 day** free trial on annual (NOT 3–7 days — long trials convert ~45% vs ~26% for short, and let users reach the multi-week “aha”); **onboarding-placed paywall that echoes the user’s stated health/cost goal.**
- **Price anchor (illustrative):** ~\$69.99/yr + ~\$9.99–12.99/mo — the de-facto software-only health anchor (Calm/Headspace/Oura all converge near \$69.99/yr; current placeholder PRO is \$9.99/mo / \$99/yr). **Annual is the profit/retention lever** (~68% adoption, 40–60% better retention; annual retains ~33% vs ~17% monthly).

7.3 When and how to test a harder paywall

Trigger conditions (all must hold): (1) core retention at/above H&F benchmarks — don’t harden a leaky bucket; (2) runway to absorb a top-of-funnel/conversion dip (the ~5x conversion lift comes with an install-engagement collapse); (3) paywall A/B tooling live (RevenueCat/Adapty/Superwall); (4) **not dependent on organic/referral growth for distribution** — hardening kills that loop, which matters because our entire \$2 motion is organic/referral.

How to transition without alienating users:

- **Phase it** (Headspace model: keep some free content per category first, then later fully gate once new-user engagement supports it — which produced a double-digit paid lift).
- **Grandfather existing free users;** never retroactively paywall what they already use.
- **Run it as a controlled experiment on the new-install cohort only**, freemium control held out; decide on **ARPU + Year-1 LTV + refund rate at Day 60**, not raw conversion %.
- **Budget for a higher refund rate** on the harder variant (~5.8% vs ~3.4%) — buyer’s remorse before product trial, not a defect.
- **Endgame:** not “pick one” — keep a genuinely useful free tier for funnel/trust/WOM, with premium value (trends, exports, AI, cost analysis, integrations) behind the paywall and a long trial. Per the brief, a hard paywall converts ~5x better (10.7% vs 2.1%), but freemium builds the top-of-funnel and trust that our organic-first motion depends on. We capture both by sequencing.

8. The Honest Bottom Line

OwnMyHealth has an **A-/B+ security and data-integrity core** and a genuinely **differentiated, unoccupied market position** — the cost-aware health copilot no competitor fuses. But it is, today, **a finished single-player app with no go-to-market loop and no cash register:** no Stripe, no MFA, no mobile/PWA, no push, no referral loop, unconfirmed BAAs on the services that hold PHI, known plaintext-PHI residue in prod, and an uncapped OCR cost path. It is, in its own UX review’s words, “a polished demo, not yet a trustworthy daily health record,” and it holds **no certifications.**

The plan: **close Gate 1 (FTC/state-law compliance + tracker audit + breach runbook + vendor BAAs) and Gate 2 (PRO billing, OCR cost cap, MFA, breach alerting, plan-limit bypass, PWA, verified onboarding, referral primitives) before spending a dollar on acquisition** — then grow through compounding, organic, referral- and content-led channels around the cost+health fusion wedge, monetize freemium-first, and test a harder paywall only once retention data earns the right. The competitive window is real but finite — a planning judgment of **roughly one to two years**, not a researched countdown — before ChatGPT Health or a cost player spans the seam. Speed on the gates, and trust as the product, are how we use it.

Product Readiness Checklist

Verdict up front. OwnMyHealth has an A-/B+ *security and data-integrity core* (per-user AES-256-GCM field encryption, FORCE Row-Level Security, audit logging, BAA-gated AI), but its own UX review calls it a “*polished demo, not yet a trustworthy daily health record*.” It is **not yet a sellable direct-to-consumer product**: there is no way to take money, no mobile experience, no MFA, no breach detection, and known plaintext-PHI residue in production. This checklist is the path from that demo to a trustworthy, *paid* consumer daily health record. It holds **no certifications** today — only the Anthropic BAA is signed. Nothing below assumes HIPAA, SOC 2, or HITRUST is “in place,” because none of them are.

Scope: pure direct-to-consumer. This is an individual-sign-up, member-owned product. There is no employer, broker, or benefits channel anywhere in this plan.

How to read this checklist

Tier	Meaning	Gate
P0	Trust / safety / legal blockers. Cannot charge a single consumer until these close.	Before any paying user
P1	Needed for a credible <i>public</i> launch — the D2C growth and trust machinery.	Before public launch / scale
P2	Post-launch hardening and accepted residuals you’ve already chosen to defer.	After first cohort

Each item states the **gap**, **why it blocks a consumer launch**, and a “**done when...**” acceptance criterion. External numbers are grounded in the research brief and labeled `(estimate)` / `(illustrative)` where they are inferences rather than measured facts.

P0 — Trust / Safety / Legal blockers (close before ANY paying consumer)

P0-1. No self-serve billing (Stripe) — you cannot collect revenue

- Gap:** Plans are **display-only**. `config/plans.ts` carries FREE (\$0), PRO (\$9.99/mo, \$99/yr), TEAM (\$19.99/mo, \$199/yr) in cents, explicitly commented “*display only, no billing*,” and the prices self-described as “Placeholder.” The Upgrade button in `PlanSection.tsx` is a literal stub that fires a toast: “*Upgrades are not available yet. Contact us to upgrade manually.*” (`// TODO: wire to Stripe checkout`). Plan assignment is admin-only or direct DB edit. There is **zero Stripe code** — no SDK, no webhook, no checkout.
- Why it blocks a consumer launch:** A D2C product with no checkout is a free demo, not a business. There is no path to acquire a paying customer at scale, and a fake “Upgrade” CTA that resolves to “email support” actively burns trust at the exact moment of purchase intent. Plan *limits are already enforced at runtime* (`planGating.ts` reads the plan fresh from DB, honors `planExpiresAt` , fails closed to FREE) — so users genuinely hit walls today with no way to pay through them.

- **Done when:** a consumer can self-serve subscribe to PRO/TEAM via **Stripe Checkout**; a verified webhook updates `users.plan` + `planExpiresAt`; cancel / downgrade / failed-payment / lapse transitions are handled and reconciled against the existing `planExpiresAt` → **FREE** logic; receipts/invoices are emailed; and the `PlanSection.tsx` placebo handler is replaced by a live checkout redirect. Annual plans are offered first-class (the brief's profit/retention lever: ~68% annual adoption, 40–60% better retention).

P0-2. No verified self-serve data export & deletion

- **Gap:** `dataExport` and account deletion are ungated “by design,” but the prior UX review flagged Settings/Files surfaces as partly placebo, and there is **no documented, end-to-end-verified** “download all my data” + “delete my account” journey a consumer can complete unaided.
- **Why it blocks a consumer launch:** For a pure consumer PHR, export/deletion are not nice-to-haves — they are *legally required and the single biggest trust signal*. **CCPA/CPRA** grant access/delete/export rights and treat health data as Sensitive Personal Information; **Washington’s My Health My Data Act** grants a right to delete and carries a **private right of action** (first class action filed Feb 2025); Nevada SB 370 adds parallel rights. These bind a web-only consumer app *now*. A consumer who can’t take their labs and leave will not trust you to hold them.
- **Done when:** a logged-in consumer can (a) one-click export a complete, decrypted, human-readable archive of all PHI (biomarkers + history, insurance, goals, files), and (b) self-initiate account deletion that cascades, **destroys the per-user salt** (rendering encrypted PHI unrecoverable), **and hard-deletes any legacy plaintext rows the salt does not cover** (the P0-6 `original_filename` residue and any pre-rotation ciphertext per P2-5) — each with an email confirmation and an audit row, proven by a manual run-through, not merely route existence.

P0-3. No MFA and no proven account-recovery path

- **Gap:** “MFA TBD.” Auth has password + logout + reset email and revokes token families on email/password change, but there is **no second factor**.
- **Why it blocks a consumer launch:** This account *is* the user’s medical record and insurance member IDs. Account takeover = a direct PHI breach, which for a consumer health startup is existential — *trust is the product; one breach or FTC action ends the company* (brief, hard truth #3). Security-conscious consumers expect at least optional TOTP on a health account.
- **Done when:** TOTP (authenticator-app) MFA can be enabled by a consumer, is enforced on login and on sensitive operations (export / delete / email change), backup recovery codes exist, and a tested recovery flow restores access **without a human in the loop**. MFA reset revokes token families like the existing email/password flows.

P0-4. No breach-detection alerting (the FTC/breach clock can’t start)

- **Gap:** This is self-identified as the *most urgent gap*: nothing notifies a human when an anomaly occurs. The forensic substrate exists (immutable 7-yr encrypted audit log), but **detection** — the legally load-bearing half — does not.
- **Why it blocks a consumer launch:** As a non-HIPAA consumer PHR that *also* pulls FHIR, OwnMyHealth meets the **FTC Health Breach Notification Rule** “multiple sources” test → **HBNR is the primary federal obligation**. The 2024 HBNR amendments (effective Jul 29 2024) require notice **≤60 days** after discovery and **expanded “breach” to include unauthorized disclosure** (e.g., an ad/analytics tracker firing on health data — the GoodRx/BetterHelp/Premom/Flo failure mode). Penalties run up to **~\$53,088 per violation** (2025 inflation-

adjusted; re-indexed annually), and each affected individual/day can count separately. You cannot meet a 60-day clock you have no way to start.

- **Done when:** Cloud Logging alert policies fire on audit-log anomalies, repeated `LOGIN_FAILED`, and the RLS boot-guard FATAL exits, routing to an on-call human; a **named Security Officer** exists; and a breach-response runbook (HBNR $\leq$ 60-day notice; simultaneous FTC notice at 500+ individuals; notice naming third-party recipients) lives in `RUNBOOK.md`.

P0-5. Vendor BAAs unconfirmed for the services that actually hold PHI

- **Gap:** Only **Anthropic's BAA is confirmed signed**. Google Cloud (Cloud Run / Cloud SQL / GCS + Document AI), Quest, and SendGrid are all "TBD." **SendGrid is not HIPAA-eligible and won't sign a BAA**. Code *gates* on flags but cannot prove a contract exists.
- **Why it blocks a consumer launch:** Your database (Cloud SQL), file store (GCS), and OCR (Document AI) all hold or process raw PHI. Even though HIPAA generally does *not* apply to a consumer-controlled PHR, the moment provider/FHIR data flows create a Business-Associate path, these vendor relationships are load-bearing — and the FTC \$5 precedent (GoodRx \$1.5M, BetterHelp \$7.8M) means *any* unauthorized health-data sharing through an unvetted vendor is direct enforcement exposure.
- **Done when:** signed BAAs for Google Cloud (infra + Document AI) are on file and dated; SendGrid is **either** confirmed PHI-free in all templates **or** swapped to a HIPAA-eligible provider (e.g., Paubox/LuxSci per the brief); the Quest/FHIR data agreement is in place before FHIR is enabled in prod; and **no ad/analytics SDK or pixel fires on any health-data screen** (the #1 HBNR/\$5 enforcement vector).

P0-6. Legacy plaintext PHI residue still in production

- **Gap:** `user_files.original_filename` is still **plaintext in prod**. New uploads encrypt and reads fall back, but the `backfill-userfile-filenames` job has **not been run** and the plaintext column not dropped. Self-rated **High (compliance)**.
- **Why it blocks a consumer launch:** Raw client filenames routinely embed identity — `JohnSmith_DEXA_1980.pdf`. Shipping to paying consumers with *known* unencrypted PHI at rest is a compliance gap you've already flagged as High, and it directly undercuts the "fully encrypted" trust claim.
- **Done when:** the maintenance job runs in prod (DRY RUN $\rightarrow$ `--apply`), all legacy `original_filename` rows are encrypted/nulled, and a follow-up migration drops the plaintext column. (Retract any stale "fully encrypted" / "Last Audit Jan 2025 / 0 findings" README claims at the same time — overstated trust claims are themselves \$5 liability.)

P0-7. AI/OCR dollar cost is uncapped on the Document AI path (H-3)

- **Gap: H-3** — Google Document AI OCR dollars are **never recorded** against the AI budget (`ocrService.ts` has no `trackAIUsage`). The \$50/day circuit-breaker bounds only Claude tokens. This is the only *High* still open on the cost line.
- **Why it blocks a consumer launch:** The moment billing opens to the public, a malicious or runaway user can drive **unbounded OCR spend** bounded only by request *counts*, not dollars — a direct path to a surprise five-figure GCP bill and a self-inflicted DoS on a solo-founder budget. This collides head-on with the brief's hard truth #1 (brutal CAC, thin margins): an uncapped variable cost can erase the unit economics of every acquired user.

- **Done when:** Document AI page cost is estimated and accrued via `trackAIUsage` (or a Document-AI-specific tracker) so it counts against `AI_DAILY_BUDGET_USD` and per-user budgets, **failing closed with 503** like the Claude path.

P0 summary

#	Blocker	Done-when (one line)
P0-1	No Stripe billing	Self-serve Checkout + webhook updates <code>plan</code> / <code>planExpiresAt</code> ; annual offered
P0-2	No verified export/delete	One-click export + self-serve delete that destroys per-user salt and purges legacy plaintext rows, audited
P0-3	No MFA / recovery	TOTP + backup codes + human-free recovery, enforced on sensitive ops
P0-4	No breach alerting	Cloud Logging alerts → on-call human; named Security Officer; HBNR runbook
P0-5	BAAs unconfirmed	GCP/Document AI BAAs on file; SendGrid PHI-free or swapped; no trackers on PHI
P0-6	Plaintext filename PHI	Backfill job run; plaintext column dropped; stale claims retracted
P0-7	Uncapped OCR spend (H-3)	Document AI dollars tracked + fail-closed against the budget

P1 — Needed for a credible public launch (the D2C machinery)

P1-1. Web-only — no mobile app / PWA for a daily-habit product

- **Gap:** The stack is a **web-only** React + Vite SPA served from GCS. There is **no PWA** (no manifest, no service worker, no `vite-plugin-pwa` / Workbox — `public/` holds only `favicon.svg`), **no native app**, and **no push notifications of any kind** (zero web-push / FCM / service-worker references). Responsive web is reasonably thorough (viewport meta; ~223 `md:` / 107 `sm:` Tailwind classes; a focus-trapped mobile drawer), so it works in a phone *browser* but behaves as a mobile website, not a daily-habit app.
- **Why it blocks a credible launch (not P0):** A “daily health record” lives or dies on phone access and re-engagement. Native apps see materially higher engagement and ~90-day retention than web (`estimate;` `vendor-sourced,` `directional`), and **web-push reach on iOS is ~10–15× smaller than native and only works after a manual “Add to Home Screen”** — the single biggest retention handicap for a web-only health app. This caps activation and retention but does not legally block a first paying cohort, so it is P1.
- **Done when:** an **installable, offline-capable PWA** ships (manifest + service worker + web push + an “add to home screen” coaching prompt fired *after* a value moment), the core log / track / upload flows pass real-device mobile testing, and a decision is recorded on native iOS for v2 — noting that **Apple App Store guideline 5.1.1(v) requires in-app account deletion** and HealthKit is native-only, and that Google Play’s Jan-2026 rules

now require a verified Organization account + D-U-N-S for health apps. (None of these store rules bind today, because the app has no App Store / Play presence — they gate a *future* native build, not the web launch.)

P1-2. SPA edge security headers missing

- **Gap:** The static SPA from GCS emits **no CSP / X-Frame-Options / HSTS at the edge**; only the API origin carries Helmet headers. In-app frame-busting only.
- **Why it blocks a credible launch:** Clickjacking/framing defense on the page a consumer actually loads is expected of a security-marketed health product and is a visible gap in any third-party security or privacy review (e.g., a Mozilla *Privacy Not Included*-style audit).
- **Done when:** the Cloud CDN / load-balancer serves CSP, `X-Frame-Options: DENY` (or `frame-ancestors 'none'`), and HSTS on the SPA origin.

P1-3. Multi-instance seams force `--max-instances=1` (H-2)

- **Gap:** In-memory stores (AI spend accumulator, FHIR PKCE verifier map, access-token blacklist, rate-limit store) are per-process unless `REDIS_URL` is set. **H-2** (FHIR connect breaks across instances) forces pinning `--max-instances=1`; the spend cap dilutes N× and rate limits/token revocation degrade beyond one instance.
- **Why it blocks a credible launch:** You **cannot autoscale** to absorb a launch spike without either breaking FHIR or diluting your cost cap — and an uncapped cost cap is dangerous (see P0-7). Provisioning Redis is the single fix that unblocks autoscale, exact spend caps, and reliable FHIR.
- **Done when:** Cloud Memorystore/Redis is provisioned, `REDIS_URL` set, the `--max-instances=1` pin removed, and FHIR connect + spend cap + rate limits verified correct across ≥2 instances.

P1-4. Onboarding / activation loop is thin and partly placebo

- **Gap:** A 4-step onboarding wizard ships (welcome → upload lab → health profile → done) and **email verification is hard-gated at login** (a real funnel choke point with no “explore first” path). Prior teardowns flagged trust-breakers that *look* functional but weren’t — a **placebo OCR review step**, a **dead registration-verification funnel**, **health-goal create returning 422**, and onboarding GET-routes that write data. These are **reported remediated per the changelog but remain unverified end-to-end** (the central honesty caveat of this whole checklist). Time-to-first-value is strong *only if* the user has a lab PDF handy; an empty account shows a bare “upload your labs” empty state with no sample data, and lab auto-sync is **Quest-only and PRO-gated**.
- **Why it blocks a credible launch:** D2C conversion is won or lost in the first session, and the brief’s monetization data is blunt — placing the paywall at the user’s stated-goal “aha” and driving **3+ meaningful sessions in the first 14 days** is the single strongest churn predictor (FACT, Adapty 2026). Placebo steps in onboarding are trust-killers exactly where trust is being established.
- **Done when:** the funnel is walked end-to-end on a fresh account with **every step verified to do real work** (OCR review actually edits extracted values; goal-create persists; verification gates correctly), a no-PDF user has a real first-value path (sample/demo state or manual-entry quick win), and an **activation metric** is instrumented (e.g., “added first biomarker within session 1”).

P1-5. No retention / re-engagement loop a consumer actually feels

- **Gap:** A competent **email lifecycle engine** ships (`emailScheduler.ts`: weekly summary, goal reminders, out-of-range alerts, new-results, plan-expiring — preference-gated, multi-instance idempotent) — this is the *primary and*

only retention loop. There is **no push/PWA notification, no streaks/gamification, and no viral loop** (see P1-6). Email is the weakest channel for a web-only app.

- **Why it blocks a credible launch:** Health & fitness apps see **~3% Day-30 retention** and ~9.2% monthly churn (FACT, brief); a “daily” record with only an email nudge will churn after week one. Annual plans retain far better — roughly **33% vs 17% at one year** (FACT, Adapty 2026, via brief) — but only if the user reaches the value moment first.
- **Done when:** at least one re-engagement loop tied to the daily-record use case is reliable and de-duplicated across instances (e.g., “new lab synced,” “you haven’t logged in N days,” weekly trend summary), respects notification preferences, and is measured against a D7/D30 retention metric. A **longitudinal “what’s new in your trend” hook** is the durable retention engine for a record app — and the biomarker time-series substrate (`biomarkerSeries.ts` , latest + `BiomarkerHistory[]`) is structurally in place to power it.

P1-6. No virality — zero referral / invite, sharing is inbound-only

- **Gap: No referral / invite / “refer a friend” / promo-code system exists** (confirmed zero matches in the codebase). Provider sharing is **inbound-only** — a provider must request access and the patient approves; a patient cannot generate a share link or invite their own doctor or family. The “TEAM” tier is positioned “for families and caregivers” but there is **no family/multi-member account model or invite flow** — it’s just higher numeric limits on one account.
- **Why it blocks a credible launch:** The brief’s growth thesis is explicit — paid acquisition is dangerous (CAC up 40–60% 2023→2025; ~\$30–60 per paying subscriber (estimate)), so growth must be **organic / referral / content-led**. Word-of-mouth is the dominant channel for the category leaders (Flo, Function), and a double-sided referral can drive 10%+ of signups (Whoop (FACT, brief)). With no viral loop, the product *cannot grow itself* and the family/TEAM pitch is undeliverable.
- **Done when:** a **double-sided, activation-gated** referral program ships (reward unlocks when the referred user activates, not on install), shareable via WhatsApp/SMS-native share sheets; **and** a patient-initiated share path exists (invite your doctor/family, or a scoped share link) so the TEAM/family positioning is real. Instrument K-factor.

P1-7. Zero test coverage on the newest consumer-facing subsystems

- **Gap:** `aiChatController` , `fhirController` , `fileController` , `labUploadController` , `sbcUploadController` have **no tests** — exactly the upload / AI / FHIR paths a consumer touches most, and exactly where prior teardowns found the real bugs (“cores solid, weakness in the SEAMS”).
- **Why it blocks a credible launch:** Shipping *paid* features with no regression net invites a trust-breaking data bug (e.g., the documented contract-drift class where the frontend sends one field and the backend silently strips it).
- **Done when:** controller/route tests cover the lab + SBC upload, AI chat, FHIR, and file-download paths per `TESTING_PATTERNS.md` , including the cross-HTTP-boundary contract-drift class of bugs.

P1-8. No automated error/anomaly monitoring (no observability SDK)

- **Gap: No observability SDK** — no Sentry/Datadog/OpenTelemetry; logging is stdout → Cloud Logging only. (Distinct from P0-4’s *security* alerting — this is *product* error/latency/crash visibility.)
- **Why it blocks a credible launch:** With real paying users you must know when checkout, upload, or sync breaks *before* a consumer emails you. Silent failures in the purchase or activation flow directly destroy the unit economics

you paid CAC to acquire.

- **Done when:** error/crash monitoring (e.g., Sentry) and basic uptime/latency alerting are wired for **both** frontend and backend, with a triage runbook.

P1-9. Consumer legal & marketing trust surface is unbuilt

- **Gap:** There is **no public pricing/landing page** (`getAvailablePlans()` exists and the endpoint is public, but **no component consumes it** — the app is fully login-walled). The README still carries a stale *“Last Audit: January 2025 / 0 findings”* marketing header. No evidence of a published consumer **Privacy Policy, Terms of Service**, the **separate Consumer Health Data Privacy Policy** that Washington MHMDA and Nevada SB 370 *require*, **AI medical-advice disclaimers**, or consent flows.
- **Why it blocks a credible launch:** A D2C health product needs a public privacy posture *before* it takes money. MHMDA/SB 370 mandate a **standalone consumer-health-data privacy policy** and separate opt-in consents; **“we never sell your data” is legally enforceable** post-GoodRx/HBNR — only claim it if the architecture guarantees it. Stale/overstated audit claims are themselves \$5 liability. There is also no surface to *acquire* a logged-out visitor.
- **Done when:** a public marketing/pricing surface ships (consuming the existing `/plan/available`), a **Privacy Policy + ToS + standalone Consumer Health Data Privacy Policy** are published, **AI “not medical advice / consult a professional” disclaimers** are present and matched by actual product behavior, README trust claims are accurate and dated, and the committed pricing + primary persona are decided so the funnel can be built. (*SOC 2 / HITRUST are optional trust signals for a consumer audience — not launch gates; do not budget them as blockers.*)

P1 summary

#	Item	Done-when (one line)
P1-1	Web-only, no PWA/push	Installable offline PWA + web push + real-device mobile pass
P1-2	No edge headers	CSP + X-Frame-Options + HSTS on the SPA origin
P1-3	<code>--max-instances=1</code> (H-2)	Redis provisioned; pin removed; verified across ≥ 2 instances
P1-4	Placebo onboarding	Every step verified real; no-PDF first-value path; activation metric live
P1-5	Thin retention loop	≥ 1 reliable re-engagement loop measured on D7/D30
P1-6	No virality	Double-sided referral + patient-initiated sharing; K-factor instrumented
P1-7	Untested seams	Upload/AI/FHIR/file controllers covered
P1-8	No product monitoring	Sentry + uptime/latency alerting, FE + BE
P1-9	No legal/marketing surface	Public pricing + Privacy/ToS/CHD policy + AI disclaimers + accurate claims

P2 — Post-launch (hardening, optimization, accepted residuals)

P2-1. Quota TOCTOU race (L34/L36) — atomic reservation

- **Gap:** Plan-limit and AI-quota checks are count-then-allow; concurrent requests can overshoot by N-1. Documented and accepted, backstopped by the dollar cap.
- **Why P2:** Self-identified as low-value to fix now; bounded by the dollar cap and small concurrent-request windows. Becomes relevant only if a hard plan-limit SLA is sold. (Note: once Redis lands per P1-3, the dollar-cap backstop becomes exact, which further de-risks this.)
- **Done when:** usage is reserved atomically in the same RLS transaction as the write (`UPDATE ... WHERE n < :limit RETURNING n`) or via a DB constraint/trigger.

P2-2. CSP still allows 'unsafe-inline' styles

- **Gap:** Helmet CSP permits inline `<style>` because of Tailwind/runtime injection; nonce-based CSP not wired.
- **Why P2:** Style-injection hardening, not an active exploit; lower priority than the *missing* edge headers (P1-2).
- **Done when:** per-request nonce middleware threads a nonce into `index.html` + React style injection and 'unsafe-inline' is removed from `styleSrc`.

P2-3. Transitive dependency advisories

- **Gap:** `npm audit` reports 1 high (`hono` , not app-reachable) + 8 moderate (`uuid` chain via `@google-cloud/storage`); none reachable as deployed attack surface.
- **Why P2:** None exercised by the running app; the `uuid` fix needs a breaking `@google-cloud/storage` major.
- **Done when:** non-breaking `npm audit fix` clears `hono` ; the `uuid` major is taken on a controlled `@google-cloud/storage` upgrade (hold the auto-merge).

P2-4. FHIR sync has no outbound page/spend budget (L-13)

- **Gap:** A single authorized FHIR sync can fetch unbounded pages; bounded by request count, not work/dollars.
- **Why P2:** Feature is off by default and plan-gated PRO/TEAM; upstream provider-rate-limited. Fold in when FHIR goes GA for consumers.
- **Done when:** `labSyncService.syncLabResults` enforces a page/byte budget.

P2-5. PBKDF2 key-rotation debt + runbook

- **Gap:** Iteration count isn't stored per-ciphertext (try-current-then-legacy fallback); "leaks nothing" but is a migration artifact. No key-rotation runbook. (Note: the legacy-fallback ciphertext is also the residue the P0-2 deletion flow must hard-delete.)
- **Why P2:** No security impact today; cleanup + operational readiness.
- **Done when:** iteration count is stored per envelope, the legacy fallback is removed after a full re-encrypt, and a key-rotation runbook exists.

P2-6. Administrative policy set + DR/IR SOPs

- **Gap:** Written security-management policy, formal risk analysis, sanction policy, training, DR/backup plan, and break-glass SOP do not exist. (*The breach-response SOP + named Security Officer are pulled forward into P0-4 because the HBNR clock depends on them.*)
- **Why P2:** The *technical* safeguards are in place; the remaining *paperwork* is a maturity/trust item, not a first-paying-user blocker. These are also the artifacts you'd need if you ever pursue SOC 2/HITRUST as a *trust signal* — but per the thesis, those are not launch gates for a consumer audience.
- **Done when:** policies, incident-response SOP, DR/backup plan, and break-glass procedure are authored, stored, and on a review cadence.

Operational readiness (cross-cutting — must accompany the first paying cohort)

The moment you take money, you take on operational obligations a demo never had. These pair tightly with P0-4 (security alerting) and P1-8 (product monitoring) but are broken out because they are *organizational*, not just code.

Capability	Gap today	Done when...	Tier
Monitoring & alerting	Stdout→Cloud Logging only; no SDK	Sentry (FE+BE) + Cloud Logging alert policies on errors, latency, and security anomalies	P0-4 / P1-8
On-call	No rotation; solo dev	A defined on-call path (even a single-person escalation + paging) so a payment/upload/breach event reaches a human fast	P1
Status page	None	A public status page (or lightweight uptime page) so paying users see incidents instead of emailing	P1
Support channel	"Contact us to upgrade manually" is the <i>only</i> documented support path	A real support inbox/help surface with a triage SLA (illustrative) , separate from the (soon-removed) manual-upgrade hack	P1
Incident/breach runbook	None	HBNR-compliant breach runbook (≤60-day notice; FTC at 500+; name third-party recipients) + named Security Officer in RUNBOOK.md	P0-4
Backups & restore drill	DR/backup plan not authored	Cloud SQL automated backups verified by a tested restore , with documented RPO/RTO (illustrative)	P1 / P2-6
Cost guardrails	\$50/day cap bounds only Claude; OCR uncapped (H-3); no GCP budget alert	OCR dollars tracked (P0-7) and a GCP billing budget + alert as a backstop against runaway spend	P0-7

Bottom line

The engine is genuinely strong; the **commercial and consumer-trust surface is unbuilt**. Close the **seven P0s** — Stripe billing, verified export/delete, MFA/recovery, breach alerting + Security Officer, confirmed BAAs (and no trackers on PHI), the plaintext-filename backfill, and the uncapped OCR cost path — and you can responsibly charge a first cohort. Close the **P1s** — PWA + push, Redis-for-autoscale, real (non-placebo) onboarding, a felt retention loop, an actual referral/sharing growth loop, test coverage on the upload/AI/FHIR seams, product monitoring, and the consumer legal/marketing surface — for a credible public launch. Everything in **P2** is hardening you've already chosen to defer.

Two honesty anchors to keep front-of-mind: this product is a *"polished demo, not yet a trustworthy daily health record"* until the P0s and the onboarding/retention P1s are *verified end-to-end* — the changelog reports the known trust-breakers fixed, but none of those fixes are confirmed in production — and it holds **no certifications**; the only signed agreement is the Anthropic BAA. Sell on the defensible wedge — **understand your health and what your care will cost, in one private, member-owned record** — not on a chatbot that was commoditized in January 2026, and never on compliance you don't yet have.

Consumer Privacy & Compliance Roadmap

Status & honesty note. OwnMyHealth holds **no certifications** today (only the Anthropic Business Associate Agreement is signed). Its own UX review calls it a *“polished demo, not yet a trustworthy daily health record.”* Nothing in this roadmap should be read as a claim that the product is currently compliant, certified, or audited. This is the path to a defensible consumer-trust posture, not a description of one already in place.

Sourcing. All regulatory facts, penalty amounts, enforcement-case values, effective dates, and third-party trust statistics in this document are drawn from the **direct-to-consumer regulatory and market research brief (2026-06-20)** prepared for this roadmap; product, security, and financial figures are from the **2026-06-20 codebase inspection**. Figures carried from those sources are presented as cited to them — not as independently verified by the author — and are flagged “(per research brief)” where they are softer third-party statistics. Author inferences are labeled **(estimate)**.

OwnMyHealth is a **pure direct-to-consumer (B2C) personal health record**: an individual signs up, uploads their own labs and insurance documents, optionally connects provider data via FHIR *at their own direction*, and queries an AI guide grounded in their own data. There is no employer, broker, TPA, or per-employee channel anywhere in this plan. That single fact reshapes the entire compliance picture — because the regulatory regime for a consumer-controlled PHR is **not** the one most healthcare founders assume.

1. Regulatory Posture

1.1 Why HIPAA generally does NOT apply

The instinct in digital health is to treat HIPAA as the master regime. For a consumer-controlled PHR, that instinct is **wrong and expensive** — it leads teams to over-build for the wrong rules while missing the ones that actually carry enforcement risk.

HIPAA binds only **covered entities** (providers, health plans, clearinghouses) and their **business associates**. Apps offered *directly to consumers* to track their own health data are not, on that basis, required to comply with HIPAA. Because OwnMyHealth’s users supply data **directly to the app** (manual entry, document uploads) rather than the app receiving data *on behalf of a covered entity*, the product falls outside HIPAA for that data.

The FHIR / provider-data nuance — the crux. When a consumer exercises their HIPAA *right of access* to direct a provider to transmit records to an app **the consumer chose** (the SMART-on-FHIR pattern OwnMyHealth uses for Quest lab sync), the receiving app does **not** thereby become a business associate. Per HHS OCR guidance: once health information is received from a covered entity, at the individual’s direction, by an app that is neither a covered entity nor a business associate, **the information is no longer subject to the HIPAA Rules**. Interoperability alone does not create HIPAA status.

The narrow conditions that WOULD create a Business-Associate obligation. HIPAA attaches if **any** of the following becomes true:

Trigger	Example
You build/operate the app for or on behalf of a covered entity under contract	A provider contracts OwnMyHealth for patient-management services; patient data auto-flows into the provider's EHR
A health plan offers your app to its members to store plan/claims/wellness records	Creates BA obligations on the app
You perform a function involving PHI on behalf of a covered entity (not merely receiving data at the <i>consumer's</i> direction)	Writing back into a provider's EHR on the provider's behalf

Practical guardrail (estimate). Keep the FHIR connection strictly *consumer-initiated and consumer-directed*. Sign **no BAAs** with providers/plans, do not position OwnMyHealth as performing services *for* a provider, and do not write back into a provider EHR on a provider's behalf — unless you deliberately intend to take on HIPAA scope. **A single B2B2C-style clinic or payer deal can flip the entire data store into HIPAA scope.** This is one more reason the pure-D2C strategy and the lean compliance posture reinforce each other.

1.2 The FTC Health Breach Notification Rule (HBNR) — the PRIMARY regime

For a non-HIPAA consumer PHR, the **FTC Health Breach Notification Rule is your primary federal obligation**. It applies precisely to *vendors of personal health records and PHR-related entities not covered by HIPAA* — the exact regulatory gap OwnMyHealth occupies.

Why OwnMyHealth is squarely in scope. The 2024 final rule (announced April 26, 2024; effective **July 29, 2024** — per research brief) loosened the PHR “multiple sources” test: a product is a PHR if it has the *technical capacity* to draw health data from **multiple sources** — e.g., a health API plus manual entry — *even if it doesn't actually draw from all of them*. An app that connects via FHIR **and** accepts user uploads clearly qualifies.

The single most important 2024 change. “Breach of security” was expanded **beyond hacking** to cover a company's **intentional but unauthorized disclosure** — for example, sharing health data with advertising vendors. The trigger shifted from unauthorized *acquisition* to unauthorized *disclosure*. **Voluntary sharing of health data without consumer authorization is now itself a reportable breach.** This expansion is load-bearing for the rest of this roadmap: it governs not only ad/analytics trackers but *any* third-party flow of health data that isn't properly authorized — including the AI/OCR/storage vendors at the core of the product (see Gate 0, items 1 and 6b).

Notification mechanics:

Requirement	Detail
Who to notify	Affected individuals, the FTC, and (for large breaches) the media
Timing	No later than 60 calendar days after discovery (per research brief)
500+ individuals	FTC must be notified simultaneously with individuals (per research brief)
Content	Must, in most cases, name the third parties that acquired the unsecured information
Method	Email plus electronic notice (text / in-app)

Penalty exposure. HBNR violations are treated as unfair/deceptive practices, with penalties up to **~\$53,088 per violation** (FTC Act §5(m), annually re-indexed — most-current figure per research brief). At per-record counting, a

single mishandled breach is an existential event for a solo-founder consumer startup.

Enforcement precedents — note the distinct legal hooks (do not conflate them; all figures per research brief):

Company	Year	Amount	Legal basis	What happened
GoodRx	2023	\$1.5M civil penalty	HBNR (first-ever) + FTC Act	Shared Rx/health data via Meta, Google, Criteo, Twilio trackers; banned from sharing health data for advertising
Premom (Easy Healthcare)	2023	\$100K civil penalty	HBNR + FTC Act	Fertility tracker shared data with Google, AppsFlyer, Chinese analytics; permanent ad-sharing ban
BetterHelp	2023	\$7.8M consumer refunds	FTC Act §5 (deceptive) — <i>not</i> HBNR	Disclosed mental-health intake data to Facebook/Snapchat for ads
Flo Health	2021	No monetary penalty	FTC Act §5	Shared intimate cycle data with Facebook/Google despite privacy promises

The recurring trigger across all four cases (estimate): third-party advertising/analytics trackers (Meta Pixel, Google, SDKs) firing on health data without explicit consent. This is the single highest-probability enforcement vector for a consumer health app — and the post-2024 HBNR makes that sharing *itself* a reportable breach.

1.3 State laws that bite a consumer app

(Regulatory effective dates in this section are per research brief.)

WASHINGTON MY HEALTH MY DATA ACT (MHMDA) — THE SHARPEST TEETH

- **Broad scope:** “consumer health data” = info linked/reasonably linkable to a consumer identifying past/present/future physical or mental health status, **including data derived or inferred from non-health data.**
- **No thresholds:** any entity doing business in WA or targeting WA consumers is a “regulated entity” — no revenue or user-count minimum.
- **HIPAA carve-out:** PHI already under HIPAA is excluded — but OwnMyHealth’s non-HIPAA consumer data is squarely covered.
- **Three-gate consent stack:** (1) opt-in **collection** consent; (2) *separate and distinct* **sharing** consent; (3) a **signed written authorization to sell**.
- **Geofencing ban:** absolute prohibition on geofencing around health-care facilities, no consent exception.
- **Separate Consumer Health Data Privacy Policy** required — distinct from the general privacy policy.
- **PRIVATE RIGHT OF ACTION (the critical risk):** enforced via the WA Consumer Protection Act — any MHMDA violation is a per-se CPA violation, actionable by **both the AG and private plaintiffs**. **Correction to a common misconception:** MHMDA provides **no statutory damages** — recovery is *actual* damages, trebled up to a **\$25,000 cap** (per research brief), plus attorneys’ fees. The “BIPA 2.0” class-action risk is real (first class action *Maxwell v. Amazon.com* filed Feb 10, 2025 — per research brief), but the per-plaintiff bounty is bounded.

CCPA / CPRA (CALIFORNIA)

- Health data is “**sensitive personal information**” (**SPI**), giving consumers the right to **limit use and disclosure** of SPI.

- The CPPA finalized regulations in **July 2025** (per research brief) adding Automated Decision-Making Technology (ADMT), cybersecurity-audit, and risk-assessment obligations — **directly relevant to OwnMyHealth’s AI assistant** if it drives decisions; clarifying regs effective **Jan 1, 2026** (per research brief).
- No private right of action except for certain data breaches.

NEVADA — SB 370 (NOT THE OLDER SB 220)

- Standalone non-HIPAA health-data law, effective **March 31, 2024** (per research brief): requires a published consumer-health-data privacy policy, affirmative consent before collecting/sharing, separate authorization to sell, and a geofencing ban. **AG-enforced, no private right of action** — contrast WA.

Planning posture (estimate): build a **multistate consent architecture** (separate collect / share / sell gates) keyed to **WA MHMDA as the strictest baseline**, rather than patching state by state. The WA/NV model is spreading.

2. Required Consumer-Facing Artifacts

For a pure-D2C health app, the compliance work and the trust-conversion work are largely **the same artifacts**. These are not bureaucratic overhead — each is also a conversion lever (per research brief: 83% of consumers say protecting their personal data is among the most crucial factors in trusting a company; 71% would stop doing business with a company that gave away sensitive data without permission).

Artifact	Why required	Notes for OwnMyHealth
General privacy policy	FTC §5 (must be truthful — broken promises = the BetterHelp/Flo failure mode); CCPA/CPRA disclosures	Must be accurate. Retract the stale README “Last Audit: Jan 2025 / 0 findings” and “fully encrypted” overclaims before publishing any public trust copy — false security claims are FTC-enforceable.
Separate Consumer Health Data Privacy Policy	Mandatory under WA MHMDA and NV SB 370	A distinct document from the general policy; identical privacy-policy URLs required across web/app per platform rules (§3).
Opt-in consent flows (collect / share / sell — <i>separate</i>)	MHMDA & NV require <i>separate</i> consents; sale needs signed authorization	Maps to the multistate consent architecture. The “we don’t sell” posture means the <i>sale</i> gate may simply never be offered — a feature, not a gap.
Data access / export / deletion	CCPA/CPRA rights; MHMDA right to delete; Apple 5.1.1(v) in-app account deletion; baseline consumer trust	Currently a launch gap. The product’s own readiness review flags that no verified, self-serve <i>export-all + delete-my-account</i> journey exists end-to-end; deletion must destroy the per-user encryption salt to render PHI unrecoverable. This must be proven by manual run-through , not just route existence.
AI medical-advice disclaimers	Keeps the AI guide as “information, not a clinical action plan” — out of FDA device territory	FDA judges the totality of claims : a “wellness” label does not override clinical/diagnostic language in marketing. Disclaimers must be backed by actual product behavior; the AI must never be the <i>sole basis</i> for clinical action. Display “not medical advice / consult a professional” prominently.

Artifact	Why required	Notes for OwnMyHealth
Breach-response plan	HBNR: individual + FTC notice ≤60 days; simultaneous FTC notice at 500+; notice names third-party recipients	Currently the most urgent gap. Audit logging with 7-yr retention exists (per codebase inspection) and the FORCE RLS guard fails closed — but no breach-detection alerting is wired , the audit path's reliability is unverified end-to-end , and five PHI-path controllers are untested, so the 60-day clock cannot reliably start today. A named human and a runbook are prerequisites to launch (see §5).
"We don't sell your data" posture	Post-GoodRx/HBNR, this claim is legally enforceable — and a conversion lever	Only make the claim if the architecture <i>guarantees</i> it. Concretely: audit every third-party SDK/pixel/tracker; no Meta Pixel / Google Analytics / ad SDK fires on health data without explicit opt-in — and confirm the product's own AI/OCR/storage vendors don't use the data beyond service delivery (Gate 0, item 6b). This is the #1 enforcement failure mode and the #1 trust signal simultaneously.

3. App-Store / Platform Health-Data Policies

Scope reality: OwnMyHealth is **web-only today** (no native app, no PWA). These platform policies do **not** gate the current web launch — but they are hard prerequisites the moment a native iOS/Android app ships, and they shape the privacy posture regardless. Treat this section as forward-looking gating, not a current blocker. (*All policy dates per research brief.*)

3.1 Apple App Store

Guideline	Requirement
5.1.3(i) / 5.1.2(vi)	Health/fitness/medical data may not be used or disclosed for advertising, marketing, or use-based data mining (other than improving health management), and not by third parties. Must disclose the specific health data collected.
5.1.3(ii)	May not store personal health information in iCloud; no false data written to HealthKit.
1.4.1	Medical apps should remind users to consult a doctor before medical decisions; accuracy claims must disclose data + methodology or face rejection; sensor-only BP/glucose/blood-oxygen/x-ray claims are not permitted.
5.1.1	Privacy-policy link required in App Store Connect and in-app; must cover collection, uses, sharing (with equal-protection guarantee), retention/deletion, and consent revocation. Explicit consent required before collecting data.
5.1.1(v)	If the app supports account creation, it must offer in-app account deletion .
App Privacy "Nutrition" Labels	Must declare data types including "Health & Fitness" and "Sensitive Info," and whether data is linked to the user or used to track. Since May 1, 2024 , "required reason" APIs must be declared in a privacy-manifest file or the submission is rejected.

3.2 Google Play (notably stricter on accountability after 2025–2026)

Requirement	Detail
Mandatory medical disclaimer	Apps without regulatory clearance must state the app is “not a medical device and does not diagnose, treat, cure, or prevent any condition” — placed in the first paragraph of the app description — and must also remind users to consult a healthcare professional.
Health apps declaration form + privacy policy	Must complete the Play Console declaration; privacy policy on an active, public, non-geofenced URL (no PDFs), linked inside the app.
Health Connect / sensitive-data restrictions	Health-record data (history, diagnoses, meds, labs) gated to apps with justified, articulated use cases (Mar 5, 2025 update).
January 2026 escalation	The “incidental use” path is eliminated; individual developer accounts are no longer permitted for health/medical apps — a verified Organization account with a D-U-N-S number is required (migration deadline Jan 28, 2026); privacy-policy URLs must be identical across Play Console, in-app, and website.
Data Safety section	Google’s consumer-visible analogue to Apple’s Nutrition Label; different categories/self-attestation.

Platform takeaway (estimate): the **Play Jan-2026 Organization-account + D-U-N-S requirement** raises the bar to publish a native Android health app and must be factored into any native-launch timeline. **HealthKit is native-only** — a PWA cannot read Apple Health — which is the single strongest reason OwnMyHealth would *eventually* need a native iOS app. Across both stores, the binding rule echoes the FTC posture: **no advertising/data-mining on health data, prominent disclaimers, frictionless deletion, and clean privacy labels**. The compliance work and the platform work are, again, the same work.

4. Where SOC 2 / HITRUST Fit — TRUST Signals, Not D2C Gates

This is where founder budget is most often misallocated. **For a pure-D2C app with no covered-entity customers, neither SOC 2 nor HITRUST is a legal requirement or a sales gate** — there is no enterprise buyer demanding them. SOC 2 is explicitly voluntary (driven by market/client expectations); HITRUST, while a common payer/provider *procurement* requirement, is “not legally required itself.”

The trap: these certifications become “necessary” only if OwnMyHealth pursues B2B2C deals (clinics/payers) — which, per §1.1, is **also the exact move that would drag the product into HIPAA scope**. So SOC 2/HITRUST track your *go-to-market*, not your D2C launch. **Do not over-budget them as launch blockers.**

That said, they retain *some* consumer value as **trust signals** — the “independently audited” badge raises perceived legitimacy (per research brief, HITRUST-certified orgs reported breaches at only 0.59% in 2024, a credible objective signal), and a clean independent privacy rating (e.g., Mozilla *Privacy Not Included*) is a rare external endorsement. But for a consumer audience these are *indirect* — far less load-bearing than a true, prominent “we don’t sell your data” promise, clean app-store privacy labels, and frictionless deletion.

Cost ranges (so they can be deferred deliberately, not by accident; all ranges per research brief):

Trust-spend item	Cost range	D2C role
SOC 2 Type II	\$25–45K	Optional trust signal; defer until B2B2C is on the roadmap
HITRUST e1	~\$35K	Optional; procurement-driven, not D2C
HIPAA program build	\$10–25K	Only if a BA path is taken on (see §1.1)
Penetration test	\$10–20K	Recommended pre-launch — meaningful security assurance for the price; pairs with the open security work
Cyber / privacy insurance	\$5–13K/yr	Recommended — backstops the existential-breach risk for a solo founder
Healthcare-privacy counsel (HBNR + state-law + AI-disclaimer review)	\$20–60K	Required-adjacent — given the genuinely multi-regime surface (HBNR + MHMDA private right of action + CCPA ADMT + FDA AI framing), this is the highest-value compliance spend

The deliberate deferral call (estimate): spend on **counsel, a pentest, and cyber insurance** before launch; **defer SOC 2 and HITRUST** until and unless a non-D2C channel is genuinely on the table. This is the opposite of the default healthcare-startup reflex, and it is correct for a pure consumer product.

5. Sequenced Timeline — What Gates Launch vs. Optional Trust Spend

Scope of this roadmap. These gates cover the **privacy/compliance** surface only. “Launch” below means the **first public consumer launch**. The paid tier follows once self-serve billing is wired: Stripe is **not yet integrated** and the documented plan-limit-bypass (M12/M13) and quota TOCTOU races would leak revenue the moment money is involved — those are **product-hardening prerequisites tracked separately**, not compliance gates. The compliance gates and the revenue gate must not be conflated: closing every item below makes the product *legally launchable to consumers*, not *able to take money*.

Sequencing principle: **legal/safety blockers first, trust amplifiers second, certifications last (and only if GTM demands them).**

Gate 0 — Must close BEFORE any public consumer launch (legal/safety blockers)

- Tracker/SDK audit + “we don’t sell” guarantee.** Verify no ad/analytics pixel fires on health data without opt-in consent. (*The #1 enforcement vector — GoodRx/BetterHelp/Premom/Flo.*)
- Breach-response plan + breach-detection alerting + named Security Officer.** Wire alerting to audit-log anomalies and the RLS boot-guard FATAL exits so the **60-day HBNR clock can actually start**; author a breach runbook. Also verify the audit-log path end-to-end (it is currently unverified, and five PHI-path controllers are untested). (*Currently the most urgent gap.*)
- Verified self-serve export + account deletion** (export-all + delete-with-salt-destruction), proven by manual run-through. (*Legal expectation + Apple 5.1.1(v) + top consumer trust signal.*)

4. **Published privacy policy + separate Consumer Health Data Privacy Policy + AI medical-advice disclaimers**, with the stale README audit/encryption overclaims retracted. (*MHMDA/NV mandatory; FTC §5 truthfulness.*)
5. **Multistate opt-in consent architecture** (collect / share / sell, keyed to WA MHMDA). (*MHMDA private-right-of-action exposure.*)
6. **Vendor data-flow controls** (two parts):
 - **(6a) Data-processing / no-secondary-use agreements** (BAA-equivalent terms where the vendor offers them) for services that actually touch PHI — Google Cloud (Cloud SQL / GCS / Document AI), Quest, and SendGrid. *Note: SendGrid is **not** HIPAA-eligible and won't sign a BAA — restrict it to non-PHI email or swap to a HIPAA-eligible provider. In pure-D2C posture HIPAA may not bind, so these are not BAAs in the HIPAA sense; they are no-secondary-use contracts and remain best-practice for a health-data store.*
 - **(6b) AI/OCR/storage no-training, no-secondary-use confirmation.** Confirm that **no third-party AI/OCR/storage vendor uses consumer health data beyond service delivery** — specifically that Anthropic (BAA signed) and Google Document AI do **not** train models on user PHI and that all such flows are contractually no-secondary-use **and disclosed/authorized in the consent architecture (item 5)**. (*Rationale: under the post-2024 HBNR, an unauthorized third-party disclosure is itself a reportable breach — §1.2 — so routine PHI flows to the AI/OCR/storage pipeline are in scope, not just ad trackers.*)
7. **Healthcare-privacy counsel review** of the above (HBNR including the disclosure-as-breach analysis for the AI/OCR pipeline, MHMDA, CCPA ADMT, AI/FDA framing).

Gate 1 — Strongly recommended for a credible public launch

8. **Penetration test** (\$10–20K) and **cyber/privacy insurance** (\$5–13K/yr).
9. **Clean app-store privacy labels / Data Safety section** prepared (even ahead of a native app, to anchor the public privacy posture).
10. **CCPA/CPRA ADMT + risk-assessment review** for the AI feature (regs effective Jan 1, 2026 — per research brief).

Gate 2 — Forward-looking (gates native mobile, not web launch)

11. **Apple privacy-manifest + health-disclaimer compliance** and **Google Play Organization account + D-U-N-S** (deadline Jan 28, 2026 — per research brief) — prerequisites *before* any native build, not before web launch.

Optional / deferred trust spend (NOT launch gates)

12. **SOC 2 Type II** (\$25–45K) and **HITRUST e1** (~\$35K) — defer unless/until a non-D2C channel is pursued (which would also change the HIPAA analysis).
13. **Independent privacy rating** (e.g., Mozilla) — pursue once the no-tracker posture is verifiably clean; a bad review is reputational damage, so do not invite it prematurely.

Summary Table

Item	Cost range	Blocks launch?	Legally required or trust?
Tracker/SDK audit + “no-sell” guarantee	Internal eng time	Yes	Legal (HBNR / FTC §5 — top enforcement vector)
Breach-response plan + detection alerting + named Security Officer	Internal eng/ops + counsel review	Yes	Legal (HBNR 60-day clock)
Verified self-serve export + account deletion	Internal eng time	Yes	Legal + trust (CCPA/MHMDA + Apple 5.1.1(v))
General privacy policy (overclaims retracted)	Counsel (part of below)	Yes	Legal (FTC §5 truthfulness)
Separate Consumer Health Data Privacy Policy	Counsel (part of below)	Yes	Legal (WA MHMDA + NV SB 370)
Multistate opt-in consent (collect/share/sell)	Internal eng time	Yes	Legal (MHMDA private right of action)
AI medical-advice disclaimers	Internal	Yes	Legal (FDA framing / FTC §5)
Vendor data-processing/no-secondary-use agreements (GCP/Quest; fix SendGrid)	Mostly negotiation	Yes (<i>best-practice for health data</i>)	Trust+ (HIPAA only if BA path taken)
AI/OCR no-training + disclosure-authorization confirmation	Internal + counsel	Yes	Legal (HBNR disclosure-as-breach)
Healthcare-privacy counsel (HBNR/state/AI)	\$20–60K	Yes (de facto)	Legal (highest-value compliance spend)
Penetration test	\$10–20K	Recommended, not blocking	Trust (security assurance)
Cyber / privacy insurance	\$5–13K/yr	Recommended, not blocking	Trust (existential-breach backstop)
Clean app-store privacy labels / Data Safety	Internal	No (gates native)	Legal (Apple/Play, at native ship)
Apple privacy-manifest + disclaimers	Internal	No (gates native iOS)	Legal (at native ship)
Google Play Org account + D-U-N-S (Jan 28, 2026)	Low	No (gates native Android)	Legal (at native ship)
SOC 2 Type II	\$25–45K	No	Trust (defer; GTM-driven)
HITRUST e1	~\$35K	No	Trust (defer; procurement-driven)
HIPAA program build	\$10–25K	No	Trust (only if BA path taken)
Independent privacy rating (Mozilla)	Low	No	Trust (pursue only once clean)

Billing note (cross-reference, not a compliance gate): self-serve Stripe billing + remediation of the plan-limit-bypass (M12/M13) and quota TOCTOU races are prerequisites for the *paid* tier and are tracked in the product-hardening plan. They are listed here only so the reader does not mistake “compliance launch-ready” for “revenue-ready.”

The one-line compliance thesis: for a pure consumer PHR, the gate is **the FTC Health Breach Notification Rule + WA MHMDA + a verifiable “we don’t sell your data” architecture (including no-secondary-use AI/OCR vendor flows) + working export/delete + breach detection** — *not* HIPAA, SOC 2, or HITRUST. Spend on **counsel, a pentest, and cyber insurance**; defer the enterprise certifications deliberately. The product is **not there yet** — it holds no certifications, has no breach-detection alerting, no verified export/delete flow, an unverified audit path, and unconfirmed vendor agreements — but every gating item above is achievable, and most of them double as the consumer-trust signals that *are* the product.

Pricing & Monetization

Status & honesty note. OwnMyHealth is a pure direct-to-consumer (B2C) product: individuals sign up, upload their own health and insurance documents, and own their record. There is no employer, broker, benefits, TPA, or per-employee channel anywhere in this plan. This document describes the **intended** monetization model. As of 2026-06-20 the product is, by its own UX review, a *“polished demo, not yet a trustworthy daily health record”*: **billing/Stripe is not wired** (the “Upgrade” button is a placebo that tells users to email support), the app holds **no certifications** (only the Anthropic BAA is signed — not HIPAA, SOC 2, or HITRUST), there is **no mobile app/PWA, no MFA**, and known cost-control holes remain open (H-3 OCR spend uncapped; in-memory quota caps until Redis). Every dollar figure below is **illustrative** unless cited to the research brief, and nothing here should be read as a claim that the revenue machinery exists today. Wiring self-serve billing is the single hardest launch blocker this document presumes will be closed first — alongside the legal gate in §6.

1. The Freemium-NOW Design

The decision (the founder’s explicit call) is **freemium now, with a planned pricing experiment to test a harder paywall later** once retention data exists. The goal of the free tier is to build top-of-funnel and trust; the goal of the paid tier is to monetize the features that (a) carry real marginal cost and (b) constitute the differentiated wedge — **record + cost-navigation fusion**, not generic “AI chat over your records” (which was commoditized in Jan 2026 by ChatGPT Health, Copilot Health, Perplexity Health, and Claude for Healthcare).

The split maps **directly onto the plan-gating substrate that already exists** in code (`requirePlanLimit` / `requirePlanFeature` ; flags like `aiChatsPerDay` , `pdfUploadsPerMonth` , `questFhirIntegration` ; `aiSpendGuard`). No new gating architecture is required — only the billing layer to move users between tiers, plus closing the documented plan-limit-bypass (M12/M13) and quota TOCTOU races.

Free vs. Premium feature map

Capability	Free	Premium	Existing gate / flag
Manual biomarker entry + longitudinal history	✔ Full	✔ Full	biomarker count limit
Document vault (upload, store, download, delete)	✔ Full	✔ Full	—
Data export + account deletion	✔ Always-on, every tier	✔	ungated by design (consumer right)
Insurance plan storage (manual)	✔ Limited count	✔ Higher/unlimited	insurance-plan count limit
Engagement emails / notifications	✔	✔	preference-gated
OCR / AI document extraction (lab PDF → structured biomarkers; SBC parsing)	✖ (minimal/none)	✔	<code>pdfUploadsPerMonth</code>

Capability	Free	Premium	Existing gate / flag
AI health guidance (chat + per-biomarker guidance)	✗ (minimal/none)	✓	aiChatsPerDay , aiSpendGuard
Insurance cost analysis (out-of-pocket projection, AI cost optimization)	✗	✓	cost-analysis limit
FHIR lab-connect (Quest auto-sync)	✗	✓	questFhirIntegration
Health profile (PRO-gated today)	✗	✓	healthProfile

Design principle: Free is a genuinely useful **manual personal health record + document vault** — enough to build the habit and earn trust, but it deliberately withholds the two things that *cost money to deliver* and *define the wedge*: AI/OCR extraction and the fused cost-navigation layer. This is the canonical “freemium as a base layer, subscription stacked on top” pattern — keep a real free tier for funnel/trust/word-of-mouth, gate the premium value (AI, OCR, cost analysis, integrations) behind the wall.

Naming note. Internally the tiers are `FREE` / `PRO` / `TEAM`. For pure D2C, **TEAM** is positioned to consumers as a **“Family/Caregiver” plan** — it is *not* a B2B seat product, and today it is only a higher set of numeric limits on a single account with **no family/multi-member model in code**. Treat the family tier as a **roadmap SKU, not a shipped one**; the launch decision is Free vs. a single Premium.

2. Illustrative Price Points

Annual is **pre-selected** in the UI because it is the profit and retention lever: per the brief, **~68% annual adoption** in this category and **40–60% better retention**, and Health & Fitness is the one category where annual *dominates* the mix (60.6–67% of subscriptions / 61% of revenue are annual). Monthly exists as an option but is priced so annual is obviously cheaper per month.

Benchmark anchors (from the brief)

Comp	Price	What it bundles	Relevance
Typical fitness/wellness app	~\$10–20/mo	software only	direct price-band peer
Calm / Headspace / Oura (software)	~ \$69.99/yr anchor	software only	the de-facto software-only annual anchor
Oura premium	~\$5.99/mo (+ \$349 hardware)	device analytics	proven low monthly WTP
Superpower	\$199/yr	+ physical lab draws	NOT a software-only comp (bundles labs)
Function Health	\$365/yr	+ 160+ labs 2×/yr, clinician review	NOT a software-only comp (bundles labs)

Function (\$365) and Superpower (\$199) are **not** like-for-like comps — both bundle physical lab draws and clinician services. OwnMyHealth is **software-only** (it ingests labs the user already has, it does not draw blood). The honest software-only anchor is the **~\$70/yr Calm/Headspace/Oura band**, not the longevity-testing band.

Illustrative OwnMyHealth pricing

All figures (**illustrative**) — the in-code values (PRO \$9.99/mo, \$99/yr ; TEAM \$19.99/mo, \$199/yr) are self-labeled “Placeholder, display only, no billing.”

Plan	Monthly (illustrative)	Annual (illustrative, pre-selected)	Effective \$/mo on annual	Rationale
Free	\$0	\$0	\$0	Manual record + vault; funnel + trust
Premium	~\$9.99/mo	~\$69.99– \$99/yr	~\$5.83– \$8.25/mo	Sits in the fitness \$10–20 band on monthly; annual at/just above the ~\$70 software anchor; monthly is ~1.2–1.7× the effective per-month cost of annual (i.e., a ~30–40% annual discount — the standard annual nudge)
Family/Caregiver (roadmap, not launch)	~\$19.99/mo	~\$199/yr	~\$16.58/mo	Higher limits + (future) multi-member; defer until a real family model ships

Annual-discount sanity check. At \$9.99/mo, the un-discounted year is ~\$120. Pricing annual at ~\$70–\$99 makes the effective monthly ~\$5.83–\$8.25 — a **~17–42% discount** vs. paying monthly, which is the standard “annual is obviously cheaper” nudge. (If a steeper discount is later desired, the monthly price must rise in lockstep to keep both numbers consistent and stay near the ~\$10–20 fitness band; do not widen the gap by quietly cutting the annual price alone.)

Price as a quality signal (estimate, grounded in brief): the brief notes higher-priced annual plans yield materially higher LTV (~\$70 LTV vs ~\$17 for low-priced; top-quartile pricing ~3× the LTV of bottom-quartile).

Recommendation: anchor Premium annual nearer **\$99** than \$70 *if* the cost-navigation value proposition lands in testing — don’t reflexively underprice the differentiated wedge. The price point is itself an experiment variable (see §4).

3. The Variable-Cost Floor — Why Free Must Gate the Costly Features

Unlike a pure-software subscription, **every premium action here has real marginal cost**. The free tier must therefore gate exactly the features that cost money, and Premium must price comfortably above embedded per-user cost. Two engines drive variable cost:

Cost engines (from the brief)

Cost driver	Pricing	Where used	Tracked against budget?
Anthropic Claude — Haiku	\$0.80 / \$4.00 per Mtok (in/out)	AI chat, lab extraction	✔ Yes — counts against the \$50/day cap
Anthropic Claude — Sonnet	\$3.00 / \$15.00 per Mtok (in/out)	SBC parsing, cost analysis	✔ Yes — counts against the \$50/day cap
Google Document AI (OCR)	per-page	every lab/SBC PDF upload	✗ NO — not dollar-tracked (H-3)

PHI-handling footnote (\$1-legal-gate item, not just a cost item). Document AI (OCR over user lab PDFs / SBCs) and the Claude paths process consumer PHI, and the lifecycle email path uses **SendGrid, which is not HIPAA-eligible and will not sign a BAA**. Before paid OCR/AI ships, each vendor’s PHI flow must be confirmed against the consumer-privacy posture and the AI medical-advice disclaimer requirements: keep SendGrid restricted to **non-PHI** content (or swap to a HIPAA-eligible mailer such as Paubox/LuxSci), and confirm the Google Cloud BAA covers Document AI. These are legal-gate prerequisites (see §6), not merely economics.

What protects margin today

- **\$50/day dollar spend cap** (`aiSpendGuard`) — a hard circuit-breaker, but it **only bounds Claude token spend**, not OCR.
- **Per-plan quotas** — `aiChatsPerDay` , `pdfUploadsPerMonth` , cost-analysis count, etc., enforced fresh from the DB (lapsed plan → Free), failing closed to Free on DB error.
- **Model routing for cost** — cheap/high-volume work (chat, lab extraction) on Haiku; expensive/low-volume reasoning (SBC, cost analysis) on Sonnet.

The open holes (must be honest about these)

1. **H-3 — OCR is uncapped in dollars (open High).** Document AI is per-page and **not** run through `trackAIUsage` , so the \$50/day cap does not bound it. The moment billing opens to the public, a malicious or runaway user can drive **unbounded OCR spend** bounded only by request *counts*, not dollars — a direct path to a surprise five-figure GCP bill and/or self-inflicted DoS on a solo-founder budget. **This must be fixed before paid OCR ships:** estimate and accrue per-page OCR cost via `trackAIUsage` so it counts against the daily/per-user budget and fail-closes with 503 like the Claude path.
2. **In-memory caps until Redis (H-2 / M-1).** The spend accumulator, rate-limit store, and FHIR PKCE/token state are per-process. Without `REDIS_URL` , the service must run `--max-instances=1` or the **\$50/day cap dilutes by N×** across instances (and FHIR connect breaks). Provisioning Cloud Memorystore/Redis is the single fix that unblocks autoscale **and** makes the spend cap exact across instances — a prerequisite for trusting the cost ceiling under any launch spike.
3. **Plan-limit bypass + quota TOCTOU (M12/M13, L34/L36).** Documented races let concurrent requests overshoot a limit by N-1; accepted-and-backstopped by the dollar cap today, but they weaken the margin guarantee and should be tightened (atomic reservation in the same RLS transaction) before a hard-paywall SLA is sold.

Margin logic

The pricing rule is simple: **Premium annual revenue per user (~\$70–\$99/yr illustrative) must exceed that user’s embedded Claude + OCR + infrastructure cost with comfortable headroom.** The plan quotas exist precisely to keep the heaviest users inside a known cost envelope. **Until H-3 is closed and Redis makes the cap exact, the true per-user cost ceiling is not actually known on the OCR line** — so closing those two items is a monetization prerequisite, not just a hardening nicety.

4. The Planned Paywall Experiment

Why freemium first (not a hard paywall on day one)

The brief is explicit that a **hard paywall converts ~5× better** than freemium (≈10.7% vs ≈2.1% download-to-paid; ~\$49.30 vs ~\$24.24 Year-1 LTV per payer). So why start soft?

- 1. **Value compounds over days/weeks, not in the first session.** A longitudinal health record only delivers its “aha” *after* the user logs data and sees trends — the brief classifies Health & Fitness as a **trial-inclusive** category, the opposite of an instant-utility app where a hard Day-0 paywall wins. A hard gate before the aha moment gates users where they won’t convert.
- 2. **Freemium builds the three things a good paywall experiment requires:** top-of-funnel, **trust** (the whole product in a consumer-PHI category where *trust is the product*), and the **retention + analytics data** needed to run the experiment well.
- 3. **The growth model is organic/referral/content-led, not paid-first** (brutal CAC ~\$30–60; weak free retention ~3–8% day-30). A hard paywall’s documented downside is a **top-of-funnel collapse** — fatal when distribution depends on word-of-mouth and SEO rather than paid acquisition.

How and when to test a harder paywall

Move toward a harder gate (shorter/no trial, or more features locked) **only when all of these hold** — never harden a leaky bucket:

Precondition	Why it gates the experiment
Core retention proven at/above Health & Fitness renewal benchmarks	A hard paywall converts more of who you keep but keeps far fewer; pointless on a leaky bucket
Runway to absorb a conversion-rate + install-engagement dip	The ~5× conversion lift comes with a top-of-funnel collapse
Paywall A/B + analytics tooling live (e.g., RevenueCat/Adapty/Superwall) so decisions read on ARPU/LTV, not raw conversion %	Price experiments improve LTV far more often than they lift conversion
Not dependent on organic/referral growth at that moment	Hardening kills the viral loop the brief says must carry growth

How to run it without alienating existing free users

- **Phase it; don't flip the whole library at once.** The Headspace playbook (from the brief): keep some value free per category first, *then* gate harder once new-user engagement is high enough to support it — which later produced a double-digit lift in paid subs.
- **Grandfather existing free users.** Do not retroactively paywall what they already use; abrupt full paywalls drive bounce.
- **Run it as a controlled experiment on the *new-install cohort only*,** with a freemium control held out; read **ARPU + Year-1 LTV + refund rate at Day 60** before rolling forward. Cadence: ~2–3 paywall experiments/quarter, decision metric = ARPU.
- **Favor a long free trial over a no-trial wall when you do harden.** The brief shows **17–32 day trials convert ~42–46%** vs only ~26% for 3–7 day trials — a long trial lets a longitudinal-value product reach its aha. Lead with a long-trial annual offer before testing a true no-trial gate.
- **Budget for higher refunds** on the harder variant (~5.8% vs ~3.4%) — buyer's remorse before product trial, not a defect.
- **Place the paywall in onboarding, echoing the user's stated goal.** Onboarding-placed paywalls more than double in-app-gate conversion; surfacing the user's own onboarding answers on the paywall outperforms most design tweaks. (This depends on the onboarding funnel being *real* end-to-end — the prior UX review flagged a placebo OCR review step and a dead goal-create path that must be fixed first.)

Recommended concrete sequence

1. **Launch:** Free core + **Premium with a 17–32 day free trial on annual** (not a 3–7 day trial), onboarding-placed paywall echoing the user's health goal, anchored at **~\$69.99–\$99/yr + ~\$9.99/mo (illustrative)** — annual pre-selected. (*Gated on Stripe being wired, H-3/Redis closed, and the \$6 legal gate cleared.*)
2. **Instrument & retain:** track renewal curve, Day-60 ARPU, refund rate; drive retention with longitudinal trends, reminders, and (once built) referral + a re-engagement loop before touching pricing.
3. **Then test harder:** once retention ≥ benchmark *and* runway + A/B tooling exist, run a new-cohort hard-gate experiment, freemium control held out, existing users grandfathered, decide on ARPU/LTV at Day 60, expect a top-of-funnel dip + higher refunds.

5. Illustrative LTV / Unit Economics vs. CAC

All figures in this section are illustrative, built from the brief's benchmark rates applied to OwnMyHealth's illustrative price points. They are planning skeletons, not measured results — the product has no billing and therefore **zero realized revenue** today.

The CAC reality (from the brief)

- Fully-loaded **CAC ~\$30–60 per paying subscriber.**
- Free-user **day-30 retention ~3–8%** (weak); **~30% of annual subs cancel in month 1.**
- Freemium converts **~5×** worse than a hard paywall (~2.1% vs ~10.7% download-to-paid).

- Healthy-economics guardrail: **LTV:CAC $\geq$ 3:1**, CAC payback < **12 months**; health/wellness can run **3:1–6:1**.

Funnel skeleton (illustrative, freemium + trial)

Applying the brief's benchmarks to a freemium-with-trial funnel: of 100 installs, ~11 start a trial, ~40–42% of those convert → **roughly 4–5 paying per 100 installs** via the trial funnel (a no-trial freemium gate lands closer to ~2–3.7 per 100).

Per-subscriber economics (illustrative)

Scenario	Price (illustrative)	Year-1 LTV per payer (illustrative)	vs. CAC \$30–60	LTV:CAC
Freemium baseline (brief Year-1 LTV/payer)	~\$70–\$99/yr	~\$24 (brief freemium figure)	below mid-CAC	~0.4–0.8 : 1 ❌
Annual Premium, retention at benchmark	~\$99/yr	~\$46 (brief annual-plan H&F LTV)	near-to-above CAC	~0.8–1.5 : 1 ⚠️
Hard-paywall payer (brief)	~\$70–\$99/yr	~\$49 Year-1	above low-CAC	~0.8–1.6 : 1 ⚠️
Multi-year annual w/ strong retention (estimate)	~\$99/yr × ~2 yr	~\$90–\$140	clears 3:1 only at low CAC	~1.5–3+ : 1 ✅ (only if retention holds)

What the numbers say (the honest read)

- **Year-1 LTV per payer alone does NOT clear a healthy 3:1 against a \$30–60 CAC.** At a single year of revenue (~\$24–\$49 illustrative), the math is roughly break-even to underwater. This is the central unit-economics tension the brief insists be confronted head-on.
- **The model only works on three levers, in order:**
 1. **Drive CAC toward the floor via organic/referral/content/SEO**, *not* paid acquisition — paid-first against a leaky bucket “lights money on fire.” Cheap acquisition is what makes a ~\$24–\$49 Year-1 LTV survivable.
 2. **Multi-year retention** — annual plans retain ~33% vs ~17% monthly; a payer who renews into year 2–3 is where the 3:1 actually materializes. Retention is the binding constraint, not conversion.
 3. **Protect contribution margin** — because every AI/OCR call has marginal cost, LTV must be read **net of embedded Claude + OCR cost**; closing H-3 and provisioning Redis are prerequisites for trusting that the per-payer contribution is positive.
- **Concentration risk (sobering, from the brief):** the top 10% of Health & Fitness apps capture ~92.6% of category revenue; only ~5% of H&F apps reach \$10K total revenue in their first two years. A credible plan assumes this is hard, leads with cheap organic growth + retention, and treats the harder-paywall test as the lever to pull *after* retention is proven — not a shortcut around it.

Bottom line. Freemium-now is the right sequencing for a trust-dependent, value-compounds-over-time consumer health record: it builds the funnel, the trust, and the data. But the unit economics only close if CAC is held to the organic floor and payers are retained into multiple years — and if the OCR cost hole (H-3) and the in-memory cap (Redis) are fixed so that “Premium priced above embedded cost” is actually *true* and not just intended. The paywall experiment is the planned mechanism to find the ARPU-maximizing gate **after** retention is demonstrated — run on new cohorts, grandfathering existing free users, decided on ARPU/LTV rather than raw conversion.

6. Legal Gate Before Paid Launch

Opening a public, paid funnel is exactly the act that sharpens consumer-PHI legal exposure — and the thesis is blunt that *one breach or FTC action ends a consumer health startup*. The compliance/legal gate is **first in order**, ahead of product-hardening and growth, and must be cleared before the paywall flips. For a pure consumer PHR, the operative regime is **not HIPAA**:

- **FTC Health Breach Notification Rule (HBNR), incl. the 2024 amendments.** A consumer-uploaded PHR that *also* pulls FHIR data meets the rule’s “multiple sources” test, so the HBNR is the **primary federal obligation**. The 2024 amendments redefine a “breach” to include **unauthorized disclosure** — voluntary sharing of health data without consumer authorization (e.g., an ad/analytics SDK firing on health data) is itself a reportable breach. Notice is required within **60 days** (FTC notified simultaneously for breaches of 500+). Penalties run up to ~\$51,744 per violation, re-indexed annually. Enforcement precedent: **GoodRx, BetterHelp, Premom, Flo** — the recurring trigger is third-party trackers on health data.
- **Washington My Health My Data Act (MHMDA).** Carries a **private right of action** (“BIPA 2.0” class-action risk; first class action filed Feb 2025) and requires a **separate Consumer Health Data Privacy Policy** plus separate opt-in consents for collection / sharing / sale. Treat MHMDA as the strictest baseline. (Nevada SB 370 imposes a parallel consent + geofencing-ban regime, AG-enforced.)
- **CCPA/CPRA.** Treat health data as **sensitive personal information**, honor “limit use of SPI” plus access/export/deletion rights, and assess the CCPA ADMT / risk-assessment rules (effective 2026) for the AI feature.
- **HIPAA applies only narrowly** — it attaches *only if* a provider/plan relationship or a Business-Associate path forms (e.g., building the app *for* a covered entity, or signing a BAA). Keep the FHIR connection strictly **consumer-directed**; do not sign BAAs or position the product as performing services *for* a provider/plan, or the whole data store flips into HIPAA scope.

Must be in place before the paywall flips:

- A truthful, prominent **consumer Privacy Policy + Terms of Service**, plus the standalone **Consumer Health Data Privacy Policy** (MHMDA/NV) — and **no** “we never sell your data” claim the architecture can’t guarantee (it is legally enforceable post-GoodRx).
- **AI medical-advice disclaimers** (“information, not a clinical action plan; not a substitute for professional medical advice”), with marketing language aligned to the wellness positioning so the totality-of-claims stays out of FDA device territory.
- **App-store / platform health-data policies** satisfied *if/when* a mobile app ships (Apple 5.1.x health-data + in-app account deletion + privacy nutrition labels; Google Play health declaration + mandatory disclaimer + Jan-

2026 Organization-account/D-U-N-S requirement). Web-only today defers these but not the FTC/state regimes.

- A **breach-response runbook** (60-day clock, 500+ simultaneous-FTC notice, third-party-recipient naming) with a named Security Officer and breach-detection alerting wired — the §164.404-style clock cannot start without detection.
- An audit that **no ad/analytics SDK or pixel fires on health data without explicit opt-in consent** — the single highest-probability enforcement vector.

Do not over-budget the trust signals. SOC 2 and HITRUST are *consumer-trust signals*, not launch gates for pure D2C — there is no enterprise buyer demanding them, and pursuing the B2B2C deal that would require them is also the thing that drags the product into HIPAA scope. They are a later, optional credibility spend, not a precondition for charging a first cohort.

Competitive Landscape

Document scope. Pure direct-to-consumer (B2C). Every individual signs up, uploads their own health and insurance documents, and owns their record. There is no employer, broker, benefits, or per-employee channel anywhere in this analysis. Adjacent partnerships (labs, wearables, telehealth) are noted only as future product surface, never as a sales channel.

Readiness honesty. OwnMyHealth today is, by its own UX review, a *“polished demo, not yet a trustworthy daily health record.”* It holds **no certifications** — HIPAA, SOC 2, and HITRUST are **not** in place; only an Anthropic BAA is signed. Billing is not wired, there is no mobile app or PWA, and two High-severity issues are open (uncapped Document AI OCR spend; FHIR multi-instance pinned to one instance until Redis). This document positions where OwnMyHealth *can* win, not where it already has.

Sourcing convention. Internal product facts come from direct codebase inspection. **Competitor pricing, funding, and usage figures are drawn from public reporting as of June 2026 and should be re-verified before board use** — they are marked (*reported*) throughout. Figures marked (*estimate*) are OwnMyHealth’s own inference. Do not treat any (*reported*) competitor figure as independently verified.

1. The competitive question

OwnMyHealth competes for one consumer job: **“Help me understand my health *and* what my care will cost — in one private place I control.”** That job sits at the intersection of four feature pillars:

1. **Personal health record (PHR)** — aggregate labs, documents, and clinical data the consumer owns.
2. **Biomarker trends** — longitudinal interpretation of lab values over time, flagged in/out of range.
3. **Insurance / cost navigation** — parse the Summary of Benefits, project out-of-pocket cost, analyze the financial side of care.
4. **AI grounded in the user’s own data** — a guide that reasons over *this* user’s records and *this* user’s plan.

The field below is organized by which pillars each competitor owns. The recurring finding: **everyone owns one or two pillars; no one cleanly welds the health rail to the cost rail.**

2. The field, by category

2.1 Longevity / biomarker D2C — *they own “your biomarkers,” not your record, and never touch cost*

These sell **lab panels + interpretation**. They generate health data; they do not aggregate your existing records, and **none touch insurance or cost.**

Player	What it does for a consumer	Pricing (<i>reported</i>)	Key weakness
Function Health	Annual membership, 160+ biomarkers tested ~2×/yr, clinician review, action plan; lets users upload past labs/scans; “Private AI Chat” over <i>its own</i> lab data; Apple Health + wearable connect	\$365/yr (~\$1/day); advanced tests (cancer/Alzheimer’s/MRI) extra	Lab-test-first, not a true longitudinal record; zero insurance/cost layer ; AI scoped to its own labs; now a <i>connected data source inside ChatGPT Health</i> — risks being commoditized into a feed for someone else’s AI
Superpower	Continuous-monitoring membership; one blood draw → 100+ biomarkers; app-booked draws via Quest/at-home; AI health coach; uploads past bloodwork	\$199/yr core	Biomarker-centric, no record-aggregation depth, no cost/insurance ; younger/smaller than Function
Levels	Metabolic-health app built on CGM; tiers add labs + clinician review; uploads past bloodwork	Membership ~\$199/yr (some sources cite \$125 entry); CGM + labs separate	Narrow (glucose-led); CGM fatigue; no record breadth; no cost/insurance ; capital-constrained vs the Function/Superpower wave (estimate)
InsideTracker	Blood-biomarker analysis + recommendations; analyzes uploaded data or new tests; added an AI coach	Membership \$149/yr ; blood plans \$340–\$489; up to ~\$1,781/yr	Oldest-feeling of the cohort, thinly capitalized (last round Sep 2022, <i>reported</i>); no cost/insurance , no record aggregation

Category takeaway. Well-funded — Function reportedly raised a **\$298M Series B at a \$2.5B valuation (Nov 2025)** and runs **~\$100M revenue at ~200k+ members** (*reported; re-verify*) — but **single-rail**: they own biomarker *generation*, not the user’s full record, and not a single one touches cost or insurance.

Strategic implication for OwnMyHealth. Do **not** compete on biomarker *testing* — Function’s war chest wins that. Treat lab panels as an *ingested input*, and win on what they structurally lack: the longitudinal record fusion and the cost rail.

2.2 PHR aggregators — *they own record consolidation, but stop there*

These own **record consolidation**. They are weak or absent on biomarker-trend intelligence, mostly absent on cost, and none ships AI-grounded-in-your-data as the *product*.

Player	What it does for a consumer	Pricing (<i>reported</i>)	Key weakness
Apple Health / Health Records	Aggregates clinical records (labs, meds, conditions) into iPhone via SMART-on-FHIR from 700+ health organizations (<i>reported</i>); consolidates wearables; share-with-provider	Free (bundled with iPhone)	No cost/insurance/billing ; biomarker “trends” are shallow (values, not interpretation); no AI reasoning over the record; iOS-only ; depends on each institution’s FHIR support

Player	What it does for a consumer	Pricing (reported)	Key weakness
MyChart (Epic) — <i>closest existing fusion</i>	Patient portal: meds, test results, appointments, medical bills, price estimates — “all in one place, even across organizations”; MyChart Central links portals	Free to patients	Locked to Epic-running providers ; bills/estimates are <i>that provider's</i> charges, not cross-provider shopping or insurance optimization; no biomarker intelligence, no true AI-on-your-data; a tether to the health system, not a consumer-owned record
Fasten Health	Open-source, self-hosted family PHR aggregating records from 100,000s of insurers/hospitals via FHIR	Free self-hosted; ~\$50 one-time for desktop/cloud (reported)	Technical/self-host barrier; no biomarker intelligence, no AI, no cost/insurance ; not a mass-consumer product
b.well Connected Health	FHIR platform unifying records + financial info + wearables	Partner-distributed, not consumer-priced (estimate)	Not a true D2C product — it's the <i>plumbing</i> behind others (now reportedly Perplexity's record backend via a Mar 2026 partnership); no consumer cost-navigation experience surfaced
Hugo Health	Cloud platform for individuals to acquire/harmonize health data; research-data orientation (Yale/VA usage)	Not clearly consumer-priced (estimate)	Research-leaning, low D2C presence; no biomarker-trend or cost-navigation experience

Category takeaway. MyChart is the only player already showing records + labs + bills + price estimates together — but it is Epic-locked, shows only that provider's prices (no shopping/optimization), and has no biomarker intelligence or AI-on-your-data. Everyone else aggregates and stops.

Strategic implication for OwnMyHealth. Don't try to out-aggregate Apple/Epic/b.well on raw record rails — treat those as *inputs* (as Perplexity and ChatGPT do). The opening MyChart leaves wide is **cross-provider, consumer-owned, and cost-optimizing** rather than system-tethered.

2.3 AI health assistants — *the fastest-moving and most directly threatening category*

Player	What it does for a consumer	Pricing (reported)	Key weakness
ChatGPT Health (OpenAI)	Dedicated “Health” space (launched Jan 7, 2026, reported); connect medical records/portals, Apple Health, Function; grounds answers in your labs, visit summaries, and insurance documents ; helps you “ <i>understand the trade-offs of different insurance options based on your healthcare patterns</i> ”	No separate price; rolls out across Free/Go/Plus/Pro tiers; US-only at launch	Explicitly not for diagnosis/treatment ; LLM hallucination risk; does NOT do cost navigation — no price-shopping, bill auditing, or claims work; insurance reach is limited to <i>interpreting</i> plan trade-offs; data sits inside OpenAI; a chat surface, not a structured longitudinal record with trend charts

Player	What it does for a consumer	Pricing (reported)	Key weakness
Perplexity Health	Launched ~ Mar 20, 2026 (reported); connectors to personal health data — Apple Health + EHRs from 1.7M+ providers (via b.well) + Fitbit/Withings/Ultrahuman; personalized dashboard that tracks biomarker and activity trends over time ; AI answers factor in your bloodwork + cardiac history	Rolls out first to Perplexity Pro/Max subscribers	Educational only — “doesn’t diagnose, treat, or prevent”; no insurance/cost/bill navigation at all ; relies on b.well for the record backend (dependency)

Category takeaway — this is the clear-and-present danger. Perplexity Health already ships **three of OwnMyHealth’s four pillars** (PHR + biomarker trends + AI-on-data), missing only cost/insurance. ChatGPT Health adds the unique twist of *reading insurance documents and reasoning about plan trade-offs* — the closest anyone comes to the cost rail. **But neither does true cost navigation** (price-shopping, bill audit, claim optimization). Distribution context (reported, re-verify): **~230M people ask ChatGPT health questions weekly; 32% of consumers used an AI chatbot for health info in 2025, roughly double 2024’s 16%** — these players carry enormous reach.

Honesty note. The Jan-2026 arrival of these products **commoditized “AI chat over your records.”** OwnMyHealth must **not** position on the chatbot. Its AI is a *feature in service of the fusion*, not the differentiator.

2.4 Consumer cost / insurance tools — *fragmented, and walled off from the health-record world*

Player	What it does for a consumer	Pricing (reported)	Key weakness
GoodRx	Prescription discount/comparison across 70,000+ pharmacies	Free discounts; GoodRx Gold subscription exists	Rx-only ; no records, labs, or broader cost navigation; flat growth (\$796.9M FY2025 revenue, +1%, reported); a point solution
Sidecar Health	An <i>insurance plan</i> showing the “Benefit Amount” upfront for any procedure; shop providers, keep half the savings; publishes upfront pricing + quality scores	Access-style plans ~ \$175–\$295/mo (older structure)	It’s a carrier , not a navigation layer over your existing plan; only FL, GA, OH ; no health-record/biomarker side
Healthcare Bluebook	“Fair price” + quality ratings for procedures; shop highest-value providers	Almost entirely employer/health-plan distributed	Not consumer-purchasable on its own (out of pure-D2C scope; included for completeness); no records/biomarkers
Bill-nav cohort (Sheer Health, Goodbill, Counterforce)	Connect insurance, upload bills/claims; AI+humans track claims/deductibles and flag errors; bill negotiation; claim appeals	Sheer free + paid denial help; Goodbill 15% of savings ; Counterforce free	None touch your clinical records, labs, or biomarker trends — they start from the bill or the plan, never from your health

Category takeaway. The cost world is **fragmented and siloed** — Rx (GoodRx), shoppable care (Sidecar/Bluebook), claims tracking (Sheer), bill negotiation (Goodbill). Every one of them starts from the bill or the plan and has **zero visibility into your labs, conditions, or biomarker trajectory**.

3. The white space OwnMyHealth occupies

3.1 Four-pillar coverage map

No competitor owns all four pillars. Mapping each:

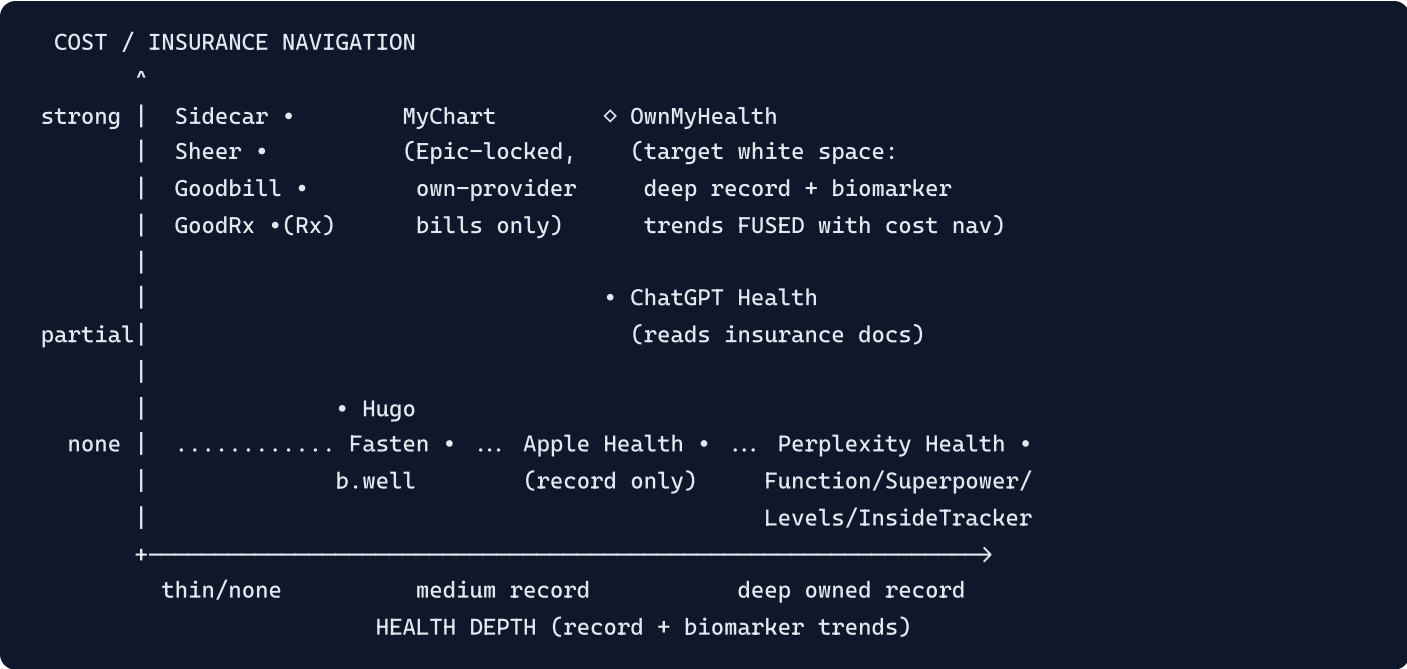
Player	PHR aggregation	Biomarker trends	Insurance / cost navigation	AI on your data
Function / Superpower / Levels / InsideTracker	weak (upload only)	strong	none	partial (own labs only)
Apple Health Records	strong	weak	none	none
MyChart (Epic)	strong (Epic-bound)	weak	partial (own-provider bills/estimates)	weak
Fasten / b.well / Hugo	strong	weak	none–weak	none
ChatGPT Health	strong (portals)	partial	partial (reads insurance docs, plan trade-offs)	strong
Perplexity Health	strong (1.7M providers)	strong (trend dashboard)	none	strong
GoodRx / Sidecar / Sheer / Goodbill	none	none	strong (each a slice)	partial (Sheer/Counterforce)
OwnMyHealth (target)	medium (upload + Quest FHIR)	strong (real time-series; behavior remediated, not yet fully verified)	strong (SBC parse + OOP projection + cost analysis)	strong (grounded in own record + plan)

The one genuinely unoccupied position: the *cost-navigation rail welded to the health rail*. Every cost player starts from the bill; every health/AI player either ignores cost (Perplexity, Apple, Function) or only *interprets* insurance documents without acting on cost (ChatGPT). **The seam between “where am I trending” and “what will it cost / how do I pay less” is unowned.**

3.2 Positioning map (illustrative)

Two axes that capture the strategic geography:

- **X — Health depth:** does the product hold a deep, longitudinal, owned record (left = thin/none → right = deep owned record + biomarker trends)?
- **Y — Cost/insurance navigation:** does it act on the financial side of care (bottom = none → top = real SBC parse + OOP projection)?



Reading: the entire upper-right quadrant — deep owned health record **and** real cost navigation — is empty. The cost tools cluster top-left (financial depth, no health record). The health/AI players cluster bottom-right (health depth, no cost). ChatGPT Health is the only competitor drifting toward the middle, which makes it the player most likely to close the gap (see §5).

3.3 The wedge, in one sentence

An AI that reasons over your unified record **and** your real costs at the same time. **Illustrative target reasoning loop** — “Your LDL is trending up across three draws → here’s the cheaper in-network lipid panel under your plan → here’s the generic statin via a GoodRx-style price → and this line on your last visit’s bill looks like a coding error.”

What is shipped vs. roadmap in that loop: the **biomarker trend** (real time-series), the **in-network/under-plan cost framing** (SBC parse + out-of-pocket projection + AI cost analysis) are **shipped**. The **Rx price comparison** and **bill-error / coding-error detection** are **roadmap**, not built. **No competitor connects the clinical “why” to the financial “how much / how do I pay less” in one reasoning loop** (estimate: this exact fusion is currently vacant) — and OwnMyHealth does not yet own the full loop either; it owns the two anchor halves and the seam between them.

4. Defensible differentiators

Four differentiators, each grounded in a *shipped* asset and each something a single-rail competitor cannot trivially copy.

- 1. **Health × cost fusion in one reasoning loop.** The only consumer product whose AI sees both the longitudinal clinical/biomarker record *and* the plan/deductible/cost picture, using each to inform the other. Cost players have no clinical context; health/AI players have no cost action layer. (*Shipped today: SBC extraction, expense projection + AI cost analysis, biomarker time-series — the two halves already exist in the same app; the deeper connected loop above is the build target.*)

2. **A real, owned longitudinal record — not a chat transcript.** Biomarkers are modeled as a genuine **time series** (latest value + dated history, oldest-first) — the history model is shipped (`biomarkerSeries`), so trends, sparklines, and out-of-range flags are *structurally* supported rather than re-derived by the AI each session. (*Honest caveat: the model is shipped and the trend behavior was remediated per the changelog, but it is **not yet fully verified end-to-end**.*) Perplexity has trends; ChatGPT does not. OwnMyHealth pairs trends *with* the cost rail neither of them has.
3. **Consumer-owned and consumer-controlled, cross-provider — not system-tethered.** Unlike MyChart (Epic-locked) or Apple (iOS-locked), the record is the *user's*, assembled from their uploads plus consumer-directed Quest/FHIR sync — portable, and not a tether to one health system or one phone OS. This is also the regulatory posture that keeps OwnMyHealth a consumer PHR (FTC HBNR regime), not a provider tool.
4. **Privacy-as-product, with the technical substrate already built.** The defensible long-term consumer wedge in health is *trust*. The encryption-and-isolation core is genuinely strong — per-user AES-256-GCM field encryption, Postgres FORCE row-level security that fails closed, audit logging, JWT rotation/revocation. (*Honest caveat: this is **technical capability, not certification**. OwnMyHealth holds no SOC 2/HITRUST/HIPAA attestation today; the differentiator is “we can credibly become the no-sell, encrypted, audited consumer health record,” not “we are certified.”*)

What is explicitly *not* a differentiator: “AI chat over your records.” That was commoditized in Jan 2026. The AI is the *delivery mechanism* for the fusion, never the moat.

5. How the wedge becomes revenue (freemium now, harder paywall later)

The four-pillar wedge is also the monetization engine, mapped directly onto the existing **FREE / PRO** plan-gating substrate (`requirePlanLimit` / `requirePlanFeature` , with flags like `aiChatsPerDay` , `pdfUploadsPerMonth` , `questFhirIntegration`).

- **The cost-fusion features *are* the Premium unlocks.** The differentiating wedge — **AI cost analysis, OCR/AI document extraction, insurance/SBC parsing, FHIR lab-connect, and the AI guide** — is exactly what the paid tier gates. The FREE tier (manual biomarker entry + document vault, minimal/no AI+OCR) is the trust- and funnel-builder that points users *toward* the fused experience they have to upgrade to get.
- **Sequence: freemium *now*, test a harder paywall *later*.** Build top-of-funnel and trust with freemium first; once retention data exists, run a planned pricing experiment to test a harder paywall / free-trial (hard paywalls convert materially better than freemium in published benchmarks, but freemium seeds the organic/referral growth this product depends on). **Annual plans are the retention lever** (higher adoption and materially better retention than monthly) and should anchor the eventual paid offer.
- **Tiering note (pre-empting the “is this B2B2C?” question).** The plan substrate today is **FREE / PRO / TEAM**. The **TEAM tier is a family/caregiver D2C plan** — multiple *individuals* (e.g., a caregiver managing a parent's record), **not** an employer or group-benefits SKU, and therefore not a channel drift. This document's monetization analysis focuses on the **FREE → Premium individual funnel**; the family tier is a consistent D2C extension, not a separate go-to-market.

- **The gating launch blocker: billing is unwired.** Plan *limits* are enforced at runtime, but the upgrade path is a stub — there is no Stripe/self-serve checkout, and upgrades are admin-only. **No funnel converts until billing ships.** This is the load-bearing readiness gap between “we own white space” and “we make money,” and it is the same gap \$6 names in the habit/distribution moat.

6. Competitive risks — who could close the gap, and how fast

The cost rail is OwnMyHealth’s differentiation **only until a better-funded player bolts on a cost layer**. The window is the differentiator, not a permanent moat.

Risk	Who	Why it’s credible	Mitigating reality
AI assistant adds a cost layer	ChatGPT Health (highest threat)	Already <i>reads insurance documents</i> and reasons about plan trade-offs — one product step from true cost navigation; ~230M weekly health users (<i>reported</i>); enormous distribution	Still no price-shopping/bill-audit/claims action; OpenAI’s incentive is general assistant breadth, not deep US-insurance plumbing (estimate)
AI assistant deepens its record + trend lead	Perplexity Health	Ships PHR + biomarker trends + AI today via b.well’s 1.7M-provider backend (<i>reported</i>)	No cost/insurance rail and a backend dependency (b.well); cost navigation is a different, US-payer-specific competency (estimate)
Platform owner makes it default	Apple Health	Owns the device, 700+ FHIR orgs (<i>reported</i>), free distribution	No cost/insurance/billing and no AI-on-record today; iOS-only; historically slow to add financial/insurance features (estimate)
Cost player adds the health record	Sheer Health (most plausible from the cost side)	Already a consumer “insurance copilot” (claims/deductible/bill tracking) — could ingest labs next	Starts from the bill, has no clinical/biomarker competency or record-aggregation muscle
A biomarker incumbent bundles cost	Function / Superpower	Capital and members to expand scope	Lab-test-first DNA; no insurance/cost competency; their model is selling <i>more tests</i> , not lowering care cost (estimate)

Estimated window: ~12–24 months before a big-AI entrant or a cost player (Sheer most likely) attempts to span the seam. (estimate)

7. The moat plan

The fusion is a *position*, not yet a *moat*. Four reinforcing moats convert the white space into something durable — sequenced honestly against a product that today holds no certifications, no billing, and no mobile surface.

1. **Depth-of-fusion moat (build the seam no one else has).** Go beyond co-locating health and cost: ship the *connected* reasoning loop — biomarker trend → recommended test → in-network price under the user’s plan → cheaper Rx → bill-error flag. This is the single asset every competitor lacks and the hardest to copy because it

requires *both* rails working together, not either alone. **This is the priority; the window is finite.** *Two open High issues are direct readiness dependencies of this wedge:* (a) **uncapped Document AI OCR spend (H-3)** must be dollar-capped before OCR-driven extraction becomes a paid feature at scale — today the \$50/day circuit-breaker bounds only Claude tokens, not per-page OCR, so the very Premium feature that drives the funnel has an uncapped cost tail; and (b) the **FHIR multi-instance constraint (H-2)** pins the service to a single instance until Redis is provisioned, capping the scalability of the lab-connect pillar. Neither blocks the position, but both gate whether the differentiating features can scale and price safely.

2. **Trust moat (make trust the product).** For a consumer PHR, **trust is the product — one breach or FTC action ends a consumer health startup.** Convert the strong technical substrate into *earned, external* trust: a true and prominent “we never sell your health data” posture (legally load-bearing post-GoodRx/HBNR), clean app-store privacy labels, a published consumer-health privacy policy, and — once resourced — SOC 2 as a credibility signal (a trust signal for consumers, **not** a sales gate, since there is no enterprise buyer). *Honest sequencing: this is a roadmap, not a current-state claim.*
3. **Data-gravity / switching-cost moat.** Every uploaded lab, parsed SBC, tracked biomarker, and corrected bill makes *this* user’s record more valuable and more painful to recreate elsewhere. The longitudinal record + the user’s own cost history compound into personal switching cost that a fresh ChatGPT/Perplexity session does not accumulate. Reinforce with frictionless export/portability — which paradoxically *deepens* trust and retention.
4. **Habit / distribution moat (the current gap, named honestly).** A daily-use record needs a habit surface, a growth loop, and a way to take money — and OwnMyHealth has **none of the three today**: web-only (no PWA/native, no push), no referral/invite, and no self-serve billing (the funnel from \$5 cannot convert until Stripe ships). The moat plan therefore *depends on* closing these readiness gaps: wire billing, ship a PWA + re-engagement loop so the fusion is felt daily, and grow via cheap, organic/content/SEO/referral-led motion (consumer-health CAC of ~\$30–60/paying subscriber makes paid-first untenable). Distribution is the moat OwnMyHealth has not yet started — and the one that decides whether the 12–24-month window is captured.

Bottom line

OwnMyHealth’s defensible position is **the cost-aware health copilot** — the only consumer product whose AI reasons over both the user’s longitudinal record *and* their real costs. The biomarker and cost-analysis assets that anchor that position are real and shipped (the deeper connected loop and full trend verification are still build/verify work); the white space (deep owned record × real cost navigation) is genuinely vacant; and the threat is concrete and converging (ChatGPT Health most of all). The mandate is to **build the depth-of-fusion seam and the trust posture inside a finite ~12–24-month window** — while honestly closing the readiness gaps (wire Stripe billing so the freemium→Premium funnel can convert, ship mobile, earn certifications, build distribution, and cap the open High issues) that today keep this a polished demo rather than the trustworthy daily record the position requires.

Cost-to-Market & Financial Model

Status & honesty note. This is an *illustrative* financial model for a pure direct-to-consumer (B2C) personal-health-record + cost-navigation app. Every figure is either grounded in the research brief or explicitly labeled **(estimate)** / **(illustrative)**. The product today is a **polished demo, not yet a trustworthy daily health record**: it holds **no certifications** (only the Anthropic BAA is signed), has **no billing system, no MFA, no mobile app/PWA**, two open High issues, and five untested PHI-path controllers. Nothing in this document should be read as a claim that HIPAA, SOC 2, or HITRUST controls are in place — they are not. This model prices the work required to *get to* a chargeable, trustworthy launch and the unit economics thereafter.

Gap-reference legend. P0-* / P1-* / P2-* refer to the launch-readiness gap list (P0 = blockers before any paying cohort; P1 = needed for a credible public launch; P2 = post-launch hardening). H-, M-, L-, L-M refer to the live `KNOWN_ISSUES` / `SECURITY_STATUS` issue IDs (e.g., H-3 = uncapped Document AI OCR spend; H-2 = FHIR multi-instance requires `--max-instances=1` ; L24 = legacy plaintext filename backfill; M12/M13 = plan-limit bypass; L-M16 = missing SPA edge headers). These IDs are reproduced here only as pointers; the authoritative source is the readiness triage / `KNOWN_ISSUES` doc set, not this model.

0. Model at a Glance

Item	Most-likely	Range	Basis
Cost to reach paid-launch readiness	~\$225K	\$170K–\$340K (illustrative)	\$1
Elapsed time to public paid launch	~5–6 months (2 parallel eng tracks)	4–8 months; single-track → 7–8 mo (estimate)	\$1
Monthly operating/variable cost at launch (low scale)	~\$1.6K/mo	\$1.0K–\$3.5K (illustrative)	\$2
24-month base-case paying subscribers	~1,150	500–2,800 (sensitivity)	\$3
24-month base-case ARR exit run-rate	~\$128K	\$42K (bear) – \$235K (bull) span	\$3
Blended LTV : CAC (mature, organic-led)	~3.0–3.5 : 1	1.3–5:1 (estimate)	\$4
Recommended raise	~\$750K–\$1.0M (pre-seed/SAFE)	—	\$5

The strategic premise (authoritative): **freemium now, test a harder paywall later**; win on **record-fusion + consumer cost-navigation**, not on commoditized “AI over your records”; grow via **organic/content/referral**, not paid-first. The model is built to that premise.

One base case, used everywhere. The base-case 24-month ARR exit run-rate is ~\$128K (from the \$3B trajectory). Earlier drafts quoted a softer “~\$95K” point; that figure was an annual-mix-timing variant and has been **retired** — \$3B’s ~\$128K is authoritative and is used in \$0, \$3, \$5, and the Bottom Line. Where a span is shown, it is explicitly **base (\$128K) → bull (\$235K)** or **bear (\$42K) → bull (\$235K)**, never a base-low blended with a bull-high.

1. Cost-to-Launch

Three buckets: **(A) product hardening, (B) minimal required compliance, (C) lean growth setup**. SOC 2 / HITRUST are **deliberately excluded** from the launch budget — for a pure-D2C product with no enterprise buyer they are *optional trust spend*, not sales gates (brief: regulatory section). They appear as a post-launch option in \$1B/\$5, not here.

Resourcing assumption (drives the timeline). The \$150K most-likely product-hardening spend buys the current **solo founder-engineer + heavy AI assist**, plus **one contract senior engineer** (billing/PWA) and **one part-time QA/security pass**. That is **two parallel engineering tracks**. The 5–6-month elapsed estimate assumes those two tracks run concurrently (e.g., billing on track 1 while PWA on track 2). **If execution is single-track** (one engineer serializing billing → PWA → MFA), the two ~4–6-week builds alone consume ~3 months and the schedule slips to **7–8 months** — the high end of the 4–8-month range. The measured build cadence (one developer, 7 months, with five PHI controllers still untested) makes single-track the *conservative* planning assumption; the 5–6-month headline is the *funded-two-track* case.

1A. Product hardening — close the P0/P1 gaps

These map directly to the readiness gap list (P0 = chargeable-cohort blockers; P1 = credible-public-launch). Labor is the dominant line.

Work item	Gap ref	Effort (est.)	Cost (illustrative)
Self-serve billing (Stripe Checkout + webhooks → <code>users.plan</code> / <code>planExpiresAt</code> , cancel/downgrade/failed-payment, receipts)	P0-1	4–6 wks	\$25K–\$45K
Verified self-serve export + account deletion (end-to-end, salt destruction, audit rows)	P0-2	2–3 wks	\$12K–\$20K
TOTP MFA + recovery codes + hardened account recovery	P0-3	2–3 wks	\$12K–\$20K
Breach-detection alerting + named Security Officer + breach runbook	P0-4	1–2 wks	\$6K–\$12K (+ officer is a role, not cash)
Cap Document AI / OCR dollar spend (H-3) — accrue per-page cost to budget, fail-closed	P0-7	1 wk	\$4K–\$8K
Run L24 plaintext-filename backfill + drop column (P0-6); confirm GCP/Document AI/Quest BAAs (P0-5)	P0-5/6	1 wk + legal	\$3K–\$6K

Work item	Gap ref	Effort (est.)	Cost (illustrative)
Installable PWA (manifest, service worker, web-push, “add to home screen” coaching, real-device pass on core log/track/upload)	P1-1	4–6 wks	\$25K–\$45K
Redis/Memorystore → remove <code>--max-instances=1</code> pin (unblocks autoscale, exact spend cap, reliable FHIR H-2)	P1-3	1 wk + infra	\$5K–\$9K
Onboarding/activation hardening (kill placebo OCR step, instrument activation metric)	P1-4	1–2 wks	\$8K–\$14K
Tests on the 5 untested PHI controllers (AI chat, FHIR, file, lab-upload, SBC) + edge security headers (L-M16) + error/uptime monitoring (Sentry)	P1-2/6/7	3–4 wks	\$18K–\$30K
Subtotal — product hardening		~4–5 mo calendar (2 tracks)	\$118K–\$209K

Most-likely product-hardening spend ≈ \$150K (illustrative). This is a fraction of the **~\$850K–\$1.1M traditional rebuild cost** (brief) because the asset already exists — we are finishing seams, not building. Note the effort weeks above sum to more than 5 calendar months *if serialized*; the 4–5-month calendar assumes the two-track resourcing stated above.

1B. Minimal required compliance (the *real* gate for a D2C health app)

The primary regime is **FTC HBNR + FTC Act §5 + state consumer-health-data laws** (WA MHMDA carries a **private right of action**) — **not** HIPAA (generally inapplicable to a consumer-controlled PHR absent a Business-Associate path). Spend here is small but non-optional.

Item	Cost (illustrative)	Basis (brief)
Healthcare-privacy counsel: HBNR posture, WA MHMDA / NV SB 370 / CCPA-CPRA review, AI medical-advice disclaimers, BetterHelp/GoodRx tracker audit	\$20K–\$60K	Brief: “~\$20–60k, real given the multi-regime surface”
Consumer Privacy Policy + separate Consumer Health Data Privacy Policy + ToS (counsel-drafted)	included above / +\$3K–\$8K	WA + NV require a standalone CHD policy
Breach-response capability build (overlaps P0-4) + cyber/privacy insurance	\$5K–\$13K/yr	Brief insurance benchmark
Pentest (trust signal + finds real bugs in the new billing/PHI seams)	\$10K–\$20K	Brief benchmark
Subtotal — minimal compliance	~\$38K–\$93K; most-likely ~\$55K (illustrative)	

Explicitly deferred (NOT in launch budget): SOC 2 Type II (\$25–45K), HITRUST e1 (~\$35K), formal HIPAA program (\$10–25K). These are *optional consumer-trust signals* with no enterprise buyer demanding them; revisit only if a future provider/FHIR-BA path emerges (out of scope for this pure-D2C plan).

1C. Lean growth setup (build the organic engine, not a paid budget)

Paid-first is dangerous here (brutal CAC, ~3–8% day-30 free retention — brief). Spend is on **owned, compounding** assets.

Item	Cost (illustrative)
Content/SEO foundation: pillar-cluster + programmatic biomarker/cost templates + 3–5 free calculators, credentialed-clinician attribution (E-E-A-T)	\$8K–\$20K
Lifecycle/email + referral instrumentation, analytics + paywall A/B tooling (RevenueCat/Adapty-class)	\$4K–\$10K
Product Hunt / PR launch kit, ASO assets (if/when native), landing + pricing page (currently absent)	\$3K–\$8K
Subtotal — growth setup	~\$15K–\$38K; most-likely ~\$20K (illustrative)

1D. Cost-to-launch summary

Bucket	Low	Most-likely	High
A. Product hardening	\$118K	\$150K	\$209K
B. Minimal compliance	\$38K	\$55K	\$93K
C. Growth setup	\$15K	\$20K	\$38K
Total	~\$170K	~\$225K	~\$340K

Headline: ~\$225K most-likely (illustrative), range \$170K–\$340K, ~5–6 months elapsed (two-track; single-track → 7–8 mo) to a chargeable, credibly-launchable D2C product. The \$0 glance-table and the Bottom Line both use this same **\$225K / \$170K–\$340K** figure. The single biggest line is engineering labor to close P0/P1; the single most-underrated line is privacy counsel (skipping it is how consumer-health startups get an FTC action — the thing the brief flags as existential).

Illustrative timeline to public paid launch (estimate; two parallel eng tracks):

Month	Track 1 (founder-eng)	Track 2 (contract eng)	Cross-cutting
0–2	Stripe billing, OCR cost cap, export/delete, L24 backfill	PWA scaffold (manifest/SW/web-push)	BAAs confirmed; privacy counsel engaged
2–4	MFA + recovery, Redis/autoscale, onboarding fix	PWA real-device pass; PHI-controller tests	Monitoring; privacy policies published
4–5	Pentest remediation	Edge headers, final QA	Pentest; content/SEO + referral live; pricing/landing page; closed beta
5–6	Public paid launch (freemium + long free trial on annual)		

Schedule risk (stated honestly): PWA (4–6 wk) and Stripe billing (4–6 wk) are each substantial; the 5–6-month calendar **only holds if they run on separate tracks**. On a single eng track they serialize to ~3 months by themselves and push the launch to **7–8 months**.

2. Operating / Variable Costs

Fixed infra is modest on Cloud Run + GCS + Cloud SQL. The variable risk is **AI + OCR per active user** — and the OCR path is currently *uncapped* (H-3), which is why P0-7 is a launch blocker, not a nicety.

2A. Fixed / platform monthly (illustrative, low scale)

Line	Monthly (est.)
Cloud Run + Cloud SQL (Postgres) + GCS	\$300–\$900
Redis / Memorystore (once provisioned, P1-3)	\$40–\$200
SendGrid email (non-PHI templates only; <i>not</i> HIPAA-eligible — restrict or swap to Paubox/LuxSci)	\$20–\$90
Monitoring (Sentry/uptime), domain, misc SaaS	\$100–\$300
Analytics + paywall/billing tooling (RevenueCat-class %, Stripe fees in \$4)	\$50–\$200
Fixed subtotal	~\$500–\$1,700/mo

2B. AI + OCR variable cost (the floor that scales with actives)

Model pricing (brief, per Mtok in/out): **Haiku \$0.80/\$4.00, Sonnet \$3.00/\$15.00**. Routing: chat + lab-extraction on **Haiku**; SBC parsing + cost-analysis on **Sonnet**. Document AI OCR is **per-page** and must be dollar-tracked (P0-7).

Illustrative per-active-paid-user monthly AI/OCR floor (estimate):

Component	Assumption (illustrative)	Cost/user/mo
AI chat (Haiku)	~15 msgs, ~3K tok each	~\$0.15–\$0.35
Lab/biomarker extraction (Haiku)	~1–2 reports	~\$0.05–\$0.15
SBC + cost analysis (Sonnet)	~1 SBC + 2 analyses	~\$0.20–\$0.50
Document AI OCR	~3–6 pages	~\$0.05–\$0.20
Per-paid-active floor		~\$0.45–\$1.20/mo
Per-free-active floor (freemium drag)	minimal AI/OCR by design; occasional extraction	~\$0.05–\$0.25/mo

Guardrails already in code: **\$50/day Claude spend cap** (must be extended to OCR per P0-7) and per-plan limits (`aiChatsPerDay` , `pdfUploadsPerMonth`). The **freemium variable-cost drag** (free users cost ~\$0.05–\$0.25/mo each in OCR/AI even before converting) is real and is why the free tier must keep AI/OCR minimal — exactly the current plan-gating design.

Blended operating cost at illustrative scale:

Stage	Actives	Component math (free × floor + paid × floor + fixed)	Est. monthly opex
Launch (mo 0)	~300 free / 10 paid	$(300 \times \$0.05 - 0.25) + (10 \times \$0.45 - 1.20) + \$500 - 1,700$	~\$1.0K–\$2.0K
Mo 12	~6K free / 250 paid	$(6K \times \$0.05 - 0.25) + (250 \times \$0.45 - 1.20) + \$500 - 1,700$	~\$1.1K–\$3.5K
Mo 24	~18K free / 1,150 paid	$(18K \times \$0.05 - 0.25 = \$0.9K - \$4.5K) + (1,150 \times \$0.45 - 1.20 = \$0.5K - \$1.4K) + \$0.5K - \$1.7K$	~\$1.9K–\$7.6K

The Mo24 band (**~\$1.9K–\$7.6K**) ties out to its own per-user floors at both ends. Earlier drafts showed a “\$4K–\$7K” floor that was higher than the component low sum; that has been corrected to the component-derived **\$1.9K** low. The realistic *expected* spend sits mid-band (mid-point usage + some support/tooling overhead) at roughly **\$4K–\$5K/mo**, but the honest range is \$1.9K–\$7.6K.

3. Illustrative 24-Month Subscription Funnel

3A. Stated assumptions (all illustrative; grounded where cited)

Assumption	Value	Source / rationale
Price	\$9.99/mo or \$69.99/yr (PRO)	App config \$9.99/mo; \$69.99/yr is the common adjacent consumer-health subscription anchor (Calm/Headspace meditation; Oura is hardware+sub — <i>not</i> direct PHR comps, but the de-facto software-subscription price point) — set below the current \$99/yr placeholder to match those anchors
Annual mix	~60% of paid (conservative)	H&F is the one category where annual dominates (~60–67% of subs — brief). The thesis cites ~68% <i>adoption</i> ; 60% is used deliberately as a conservative planning figure , not as the benchmark
Free→paid conversion	~2.5% (base) of free signups, via long-trial funnel	Freemium ~2.1–2.2% download→paid; a long-trial onboarding funnel lifts it (brief). Conservative vs 3.7–4.2% Adaptly H&F
Monthly paid churn	~7% (base)	H&F renewal curve ~59% first renewal; ~9.2% wellness monthly churn (brief) → blended with annual stickiness
Free day-30 retention	~5% (base)	Brief: ~3–8%

Assumption	Value	Source / rationale
CAC (blended)	~\$25 (base)	Organic-led; referral \$20–150, content ~\$0–50 amortized, paid throttle later (brief)
Organic : paid mix	~80 : 20	Paid is a late throttle, not the engine (brief)
Install→free-signup	~35%	(estimate); verification-gated funnel is a known choke point
Blended effective price	~\$9.30/mo/payer	60% annual (\$69.99/yr = \$5.83/mo) + 40% monthly (\$9.99) ≈ blended \$7.49 ... see derivation note below

Effective-price derivation (made explicit). A literal 60/40 annual/monthly blend of \$5.83 + \$9.99 ≈ **\$7.49/mo**. The model instead uses **~\$9.30/mo** as the blended *recognized-revenue* rate because (a) annual plans are **paid upfront** (cash is collected at \$69.99, recognized over 12 months but cash-positive day one) and (b) the annual *price* (\$69.99) is only a ~30% discount to 12× monthly, not 42%. For MRR-style reporting we apply the conservative **recognized** blend; for cash runway, annual prepayment is more favorable. To avoid silently mixing rates, **\$3B applies the same ~\$9.30 effective rate to every row** (MRR = cum. subs × \$9.30), including early months.

3B. Base-case trajectory (illustrative)

How the columns are computed (so the walk is traceable):

- **New paid/mo** = (that month's *new* free signups) × (effective trial-funnel conversion), **not** a flat 2.5% of the cumulative free base. Early months convert thin (funnel cold, content/SEO pre-ramp); the per-month conversion rises toward the ~2.5%-of-new-signups base as onboarding and referral mature, then the *count* grows because monthly signup volume grows.
- **Paying subs (cum)** = prior cum subs × (1 – 7% monthly churn) + new paid/mo.
- **MRR** = cum. paying subs × **\$9.30** blended effective rate (same rate every row).
- **ARR run-rate** = MRR × 12.

Month	New installs	Free signups (cum, net)	New paid/mo	Paying subs (cum)	MRR (subs×\$9.30)	ARR run-rate
1	600	~210	5	5	~\$0.05K	~\$0.6K
3	1,200	~900	18	40	~\$0.37K	~\$4.5K
6	2,500	~2,600	45	150	~\$1.4K	~\$17K
9	4,000	~4,800	70	310	~\$2.9K	~\$35K
12	6,000	~7,200	95	500	~\$4.7K	~\$56K
18	9,500	~12,500	130	820	~\$7.6K	~\$92K
24	13,000	~18,000	150	~1,150	~\$10.7K	~\$128K

Why cum subs > naive (2.5% × cum free). A flat 2.5% of the ~18K cumulative free base would imply only ~450 payers at mo 24 — but conversion applies to *new signups each month*, and payers **accumulate** (net of 7% churn) across all 24 months, so the cumulative count (~1,150) is the running sum of monthly conversions minus churn, not a one-shot 2.5% of the ending free base. The monthly new-paid figures (5 → 18 → 45 → 70 → 95 → 130 → 150) reflect rising signup volume *and* a maturing funnel; summed and churned forward they reconcile to ~1,150. Organic compounding (content/SEO's 6–12-mo lag, referral ramp) drives the install acceleration after ~mo 6.

The base-case ARR exit is a **~\$128K run-rate** — modest, and that honesty matters: this is a *seed-stage organic build*, not a hyper-growth story.

3C. Sensitivity (24-month exit)

Scenario	Conversion	Churn	CAC	Subs (mo 24)	ARR run-rate
Bear	1.5%	9%	\$45	~500	~\$42K
Base	2.5%	7%	\$25	~1,150	~\$128K
Bull (referral loop + harder paywall test works)	4.5%	5%	\$20	~2,800	~\$235K

The swing is dominated by **conversion × churn × organic reach** — i.e., the three things the strategy explicitly engineers for (sticky daily-use wedge, referral loop, content funnel). Paid spend is *not* a lever here by design. The full **bear→bull span is \$42K–\$235K**; the **base is \$128K** (single point, not a range).

4. Unit Economics

4A. LTV, CAC, payback (illustrative)

Assumptions: blended effective revenue **~\$9.30/mo**; gross margin after Stripe (~2.9%+\$0.30), AI/OCR floor (~\$0.45–\$1.20), and email/support **~78%** (estimate); base churn 7%/mo.

Average paid life — and why ~14 months is deliberately conservative. A flat 7% monthly churn implies a pure-monthly cohort life of $1 / 0.07 \approx 14$ months. The plan also assumes ~60% annual mix with 40–60% better retention, which would lift the **blended** life materially: blending 40% monthly at ~14 mo with 60% annual at ~22–28 mo gives a blended **~19–22 months**. **The base case deliberately uses the lower ~14-month figure as a margin of safety** — i.e., it under-counts the annual-retention lift the thesis elsewhere calls the single biggest profit lever. Using the blended ~19–22 mo would move base LTV above ~\$140 and base LTV:CAC above ~4:1; the table below holds the conservative ~14 mo so the board sees the *floor*, not the optimistic case.

Metric	Base (conservative ~14 mo)	Bull	Bear
Avg. paid lifetime	~14 mo	~20 mo	~11 mo
Gross-margin LTV/payer	~\$100	~\$190	~\$60
Blended CAC	~\$25	~\$20	~\$45

Metric	Base (conservative ~14 mo)	Bull	Bear
LTV : CAC	~3.0–3.5 : 1	~5:1	~1.3:1
CAC payback	~3–4 mo	~2–3 mo	~9–11 mo

Healthy guardrail is **3:1 LTV:CAC, payback <12 mo** (brief). Base case clears it **only because CAC is held low by organic/referral** — if the plan drifts to paid-first (blended CAC \$30–60 per *paying* sub, brief), the ratio collapses toward the bear case. This is the quantitative argument for the organic-first mandate. **The conservative ~14-mo life means the true blended LTV:CAC is likely better than the ~3–3.5:1 shown** — a margin of safety, not a ceiling.

4B. The freemium variable-cost drag

Free users are not free: at ~\$0.05–\$0.25/mo each in OCR/AI, **18,000 free users = ~\$900–\$4,500/mo of pure cost** carried against ~1,150 payers. Mitigations (already designed): keep AI/OCR minimal on FREE, enforce `pdfUploadsPerMonth / aiChatsPerDay`, and fix the documented **plan-limit-bypass (M12/M13) + quota TOCTOU** so free users can’t exceed caps. This drag is the price of top-of-funnel/trust — acceptable *if* the conversion funnel and referral loop perform.

4C. The freemium → harder-paywall lever (planned, not day-one)

Research: a **hard paywall converts ~5× better** (10.7% vs 2.1% download→paid) but **collapses top-of-funnel** and kills referral loops. Sequence (per thesis): **launch freemium + 17–32-day annual trial** to build funnel/trust/data → once retention ≥ H&F benchmarks and A/B tooling exists, **test a harder gate on new-install cohorts only**, grandfather existing free users, decide on **ARPU/Day-60 LTV**, expect higher refunds. Pushing **annual** (≈68% adoption, 40–60% better retention — brief) is the single biggest retention/profit lever inside this.

5. Funding Ask & Runway

5A. Use of funds (illustrative)

Bucket	Amount	Notes
Product hardening (P0/P1)	\$150K	\$1A — billing, PWA, MFA, autoscale, tests
Minimal compliance + counsel + pentest + insurance	\$55K	\$1B — the FTC/state-law gate
Growth setup (content/SEO/referral/tooling)	\$20K	\$1C — owned engine
~12-mo operating runway (opex + small founder/contract comp)	\$250K–\$400K	infra modest; labor dominates
Contingency (~15%)	~\$75K	new-billing/PHI-seam risk
Total raise	~\$750K–\$1.0M	pre-seed SAFE

5B. Why this size, and the climate

- ~\$750K–\$1.0M funds **launch** + ~12–18 months of **organic-led growth** to a **base ~\$128K ARR run-rate (bull ~\$235K)** and a real retention dataset — the proof needed to (a) run the harder-paywall pricing experiment and (b) raise a priced seed.
- **Climate (brief, Rock Health 2025):** US digital-health VC **\$14.2B (+35% YoY)**; **AI-native took 54% of dollars** with a deal-size premium; **consumer/wellness re-rated 8th→3rd** most-funded value prop (Oura’s \$900M round the largest tracked). The fundable narrative is **AI-native + clearly-differentiated + consumer-tailwind-backed** — which is exactly the **record-fusion + cost-navigation wedge**, *not* the commoditized chatbot.
- **Asset-value framing (not a spend line):** the existing ~96K-LOC codebase represents ~\$850K–\$1.1M of equivalent build (brief) — i.e., the raise buys *finishing + go-to-market*, not a from-scratch build, which is the capital-efficiency story for investors.

5C. Honest risk register (state these to the board)

Risk	Why it matters	Mitigation in plan
Trust/breach is existential	One FTC HBNR action or breach ends a consumer-health startup (GoodRx/BetterHelp/Flo precedents)	\$1B counsel + tracker audit + breach alerting (P0-4) + pentest
AI-over-records commoditized (Jan 2026)	ChatGPT Health / Perplexity Health ship 3 of 4 pillars; ~12–24-mo window	Win on cost-navigation + record fusion , the unowned seam
Weak free retention / brutal CAC	~3–8% day-30 free retention; \$30–60 paid CAC	Organic/referral-led, sticky daily wedge, freemium funnel — <i>not</i> paid-first
No billing / not yet trustworthy	Can’t collect revenue; “polished demo”	P0-1 Stripe + P0/P1 close-out are the gating spend
Freemium cost drag	Free users cost real OCR/AI dollars	Minimal-AI free tier + fix plan-limit bypass + OCR cap (P0-7)
Schedule slips to single-track	One eng track serializes billing+PWA → 7–8 mo, burning ~2 extra months of runway	Fund the contract eng (two tracks); contingency covers slip

Bottom line

For ~\$225K (range \$170K–\$340K) and ~5–6 months (two parallel eng tracks; single-track → 7–8 months), OwnMyHealth can convert a high-value but un-monetizable demo into a **chargeable, credibly-compliant D2C product** — by closing the P0/P1 seams (billing, PWA, MFA, OCR cost cap, breach alerting), buying the **minimal FTC/state-law compliance** that is the *real* gate (and deliberately deferring SOC 2/HITRUST as optional trust spend), and standing up an **organic-first** growth engine. A ~\$750K–\$1.0M **pre-seed** then funds ~12–18 months to a **base ~\$128K ARR run-rate (bear \$42K → bull \$235K)** and the retention data needed to run the **harder-paywall pricing experiment** — all while defending the one durable, currently-unowned position: **understand your health and what your care will cost, in one private, member-owned record.**

Consumer Value Proposition

Pure direct-to-consumer. A single-page positioning sheet — the basis for the landing-page hero and a short investor blurb. Stats are illustrative and should be re-confirmed against the cited source/year before any public use. The product is in **early access**: self-serve billing is not yet live, and OwnMyHealth holds no security certifications today.

Understand your health — and what your care will actually cost — in one private place.

The only personal health record with an AI guide that reasons over both your longitudinal health data *and* your real insurance costs — in a single loop.

The problem

Your health story is scattered across portals, PDFs, and lab printouts. Your medical costs are opaque — deductibles keep climbing, and you find out what something costs *after* you get the bill. And the new wave of AI health chatbots is impressive but generic: it doesn't know **your** labs, **your** plan, or **your** history.

More than a third of insured Americans now carry a single-coverage deductible of \$2,000+, and families pay roughly \$27,000 a year for coverage.¹ People are managing more of their own care and money than ever — with worse tools than they use to track a package.

The solution

OwnMyHealth brings the two halves of your health life together in one member-owned, encrypted place:

-  **Your record, over time.** Drop in a lab PDF or connect supported labs — biomarkers are read automatically and tracked as a real trend line, flagged when they move out of range.
-  **Know before you go.** OwnMyHealth reads your insurance Summary of Benefits and projects your out-of-pocket cost against your actual deductible — so a procedure or visit isn't a surprise.
-  **Ask your own data.** An AI guide that answers using *your* records and *your* plan — not a generic chatbot. Educational, never a diagnosis.
-  **Yours, and private.** Per-user encryption, row-level isolation designed to fail closed, and full access logging. We don't sell your data.

Why now

Deductibles and out-of-pocket costs are at record highs, new price-transparency and interoperability rules are putting your data and prices within reach, and consumers increasingly expect to *own* their health information. The

one thing missing is a tool that connects “how am I trending?” to “what will it cost — and how do I pay less?” **No other consumer product welds those two together.**

What it costs

Free to start	Track biomarkers manually, store your documents in a private vault.
Premium <i>(illustrative — final pricing TBD pending a launch pricing test)</i>	~\$9.99/mo or ~\$69.99/yr (≈ \$5.83/mo). Unlocks AI guidance, automatic reading of lab & insurance documents, insurance cost analysis, and lab connections.

Trust, honestly stated

Privacy was engineered in from the start — per-user AES-256-GCM encryption, database row-level isolation designed to fail closed, and audit logging. We are building toward independent security attestation (e.g., SOC 2) and operate under a clear consumer privacy posture governed by the FTC Health Breach Notification Rule and state privacy laws (Washington My Health My Data Act, CCPA/CPRA). We do **not** claim certifications we don’t yet hold, and we will publish our security and privacy practices plainly.

→ Join the early-access waitlist.

Be among the first to own your complete health and cost picture in one place.

¹ Deductible and family-premium figures: KFF Employer Health Benefits Survey (2024–2025); directional, confirm the specific source year before public use.

Confidential — internal & investor use.

Risk Register

Prepared 2026-06-20. Scope: pure direct-to-consumer (B2C) consumer-health record + cost-navigation app. No employer / broker / benefits / PEPM channel anywhere in this analysis — the in-code FREE/PRO/TEAM “Team/family” tier is treated strictly as **consumer household sharing, not employer/seat licensing** (see R11).

Likelihood / Impact scale: Low / Med / High. **Impact = severity if it materializes** (High = company-ending or product-defining). Likelihood = probability over the next ~12 months on the current path.

Sourcing convention (read this). Every external market/competitor/benchmark/regulatory figure carries an inline bracketed tag keyed to the **Sources** footnotes at the end (e.g., [RC25] , [FTC24]). A tag means the number is a published third-party/source figure; vendor-benchmark roundups are directional (~), not audited. A claim marked **(estimate)** is a derived planning inference, not a sourced figure. A claim marked **(proposed anchor)** is a product/pricing decision we are choosing, not an external fact. Product/technical claims without a tag are verified against the codebase as read on 2026-06-20 or are stated in the MEASURED PRODUCT FACTS.

Honest readiness baseline: the product is, by its own UX review, a “polished demo, not yet a trustworthy daily health record.” It holds **NO certifications** (only an Anthropic BAA is signed); has **no billing system, no MFA, no mobile app/PWA**; carries **two open High issues** (H-3 uncapped Document AI OCR spend; H-2 FHIR multi-instance requires `--max-instances=1` until Redis); **five PHI-path controllers are untested**; and known trust-breakers (placebo OCR review, biomarker time-series, dead goal-create, a11y islands) are remediated per changelog but **unverified end-to-end**. This register assumes that baseline — it does not assume the demo is shippable today.

Tier 1 — The three most-likely-to-kill-it

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R1	CAC exceeds LTV — the bucket leaks faster than it fills. The core D2C failure mode. Fully-loaded CAC ~\$30–60 per paying subscriber (estimate, derived from ~\$3.70–4.70 CPI ÷ low install-to-paid conversion) [Phoenix25] while free-user day-30 retention is only ~3% for H&F apps [Adapty26] and freemium converts at ~2.1–2.2% download-to-paid [RC25] [Adapty26]; cross-channel CAC rose ~40–60% (2023→2025) [Phoenix25] and post-ATT health-targeting restrictions push paid-social CAC above the ~\$230 Facebook baseline [Phoenix25] (the targeting-restriction impact itself is (estimate)). If we acquire via paid-first, we light money on fire against a ~3% D30 bucket.	growth / financial	High	High (company-ending)	Do not run paid-first. Sequence: fix retention (engineer 3+ sessions in first 14 days — the #1 churn predictor [Adapty26]) → compound on owned channels (founder/clinician authority on the podcast circuit [Sacra25]; content/SEO + programmatic biomarker/symptom/"is my X normal?" pages, the Flo ~6M-monthly-search-visitor playbook [GCS24]; ASO) → amplify with a double-sided, activation-gated referral loop (Whoop's referral drives >10% of sign-ups [Talkable22]) → only then use paid as a <i>throttle</i>, gated on LTV:CAC ≥ 3:1 with CAC payback < 12 months — chosen go/no-go thresholds, not brief benchmarks (the 3:1–4:1 healthy band is itself sourced [Userpilot26]). Push annual plans (~60–67% of H&F subscriptions; ~44% annual vs ~17% monthly 1-yr retention [Adapty26][RC25]).	Blended CAC trending up while D30/D7 retention is flat or falling; referral K-factor stuck near 0; organic traffic not compounding 6–9 months after content launch; LTV:CAC below 3:1.

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R2	Launching before the consumer-PHI trust/compliance posture is real → FTC HBNR action or breach. Trust IS the product; one breach or FTC action ends a consumer health startup. We have a strong <i>technical</i> core (FORCE RLS, AES-256-GCM, audit log) but no breach-detection alerting (the HBNR 60-day discovery clock can't reliably start [FTC24]), unconfirmed BAAs for the services that actually hold PHI (Google Cloud SQL/GCS/Document AI, Quest, SendGrid all TBD), legacy plaintext PHI residue in prod (L24 filename backfill not run; new uploads already encrypt, only legacy rows remain plaintext via read-fallback), and no MFA. The 2024 HBNR makes even <i>unauthorized sharing</i> (e.g., an ad/analytics SDK firing on health data) a reportable breach [JonesDay24] ; GoodRx \$1.5M [FTC-GR] , BetterHelp \$7.8M (FTC Act \$5, not HBNR) [FTC-BH] , Premom \$100K [FTC-PM] , Flo (FTC Act \$5) [FTC-Flo] are the precedents; penalties run up to	regulatory / security	Med	High (company-ending)	Treat compliance as Gate 0 (before any paying user). Stand up breach-detection alerting on audit anomalies + RLS FATAL exits routed to a named on-call; confirm/sign GCP + Document AI BAAs (or prove the path PHI-free); SendGrid will not sign a BAA [SG] → keep it strictly PHI-free or swap to Paubox/LuxSci; run the L24 filename-encryption backfill and drop the plaintext column; ship TOTP MFA + recovery (treated as a Gate-0 must-have, see R3); audit every third-party SDK/pixel — zero ad/analytics trackers firing on health data without explicit opt-in (the GoodRx/BetterHelp/Premom/Flo failure mode); publish a standalone Consumer Health Data Privacy Policy (WA [KLGates] + NV SB 370 [Orrick]) + general privacy policy + ToS + AI medical-advice disclaimer; retract the stale README “Last Audit Jan 2025 / 0 findings / fully encrypted” overclaims. SOC 2/HITRUST are <i>trust signals</i>, not legal gates [Censinet] — do not over-budget them as blockers.	Any ad/analytics SDK detected on a PHI path; a privacy researcher / Mozilla <i>Privacy Not Included</i> pulls trackers [Mozilla] ; a consumer “where’s my data going?” complaint; a security-review finding on the untested PHI controllers; inbound from a state AG or plaintiff’s-bar MHMDA filing (first class action <i>Maxwell v. Amazon</i> filed Feb 2025) [ByteBack25] .

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
	~\$51,744/violation, inflation-indexed [HBNRpen] . WA MHMDA adds a private right of action (recovery is WCPA actual damages trebled up to a \$25,000 cap, not statutory damages) [CooLey] .					
R3	Shipping the demo torches early users and reviews with known trust-breakers. D2C conversion is won or lost in the first session; a “polished demo, not yet a trustworthy daily health record” with placebo OCR review, broken biomarker time-series, 100%-dead goal-create, a fake “Upgrade” button that says “ <i>contact us to upgrade manually</i> ,” and a11y islands will produce 1-star reviews and word-of-mouth damage that organic growth (R1’s whole strategy) cannot survive. Store ratings are load-bearing third-party social proof for an anxious health buyer [MobiLoud25] .	product / growth	High	High	Gate 1 (product-hardening) before any public launch: walk the full onboarding funnel on a fresh account with every step doing real work (OCR review actually edits values; first biomarker/goal persists; verification gates correctly); verify the remediated trust-breakers end-to-end (currently <i>unverified</i>); wire real Stripe self-serve billing so the upgrade path is real, not a placebo; add controller/route tests on the five untested PHI/upload/AI/FHIR seams (where prior teardowns found the real bugs — “cores solid, weakness in the SEAMS”). Do a closed beta before open ASO/PR launch.	Beta testers hitting a step that “looks like it works but doesn’t”; first-session drop-off at onboarding; support tickets about the dead Upgrade button; sub-4.0 early store/app rating; activation metric (“first biomarker in session 1”) below target.

Tier 2 — Strategic / competitive risks

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R4	AI-chat commoditization closes the wedge. “AI over your records” was commoditized Jan 2026 by ChatGPT Health, Copilot Health, Perplexity Health, and Claude for Healthcare [KFF26]. Perplexity Health (Mar 2026) already ships PHR + biomarker trends + AI-on-your-data with EHR reach across ~1.7M providers via b.well [Perplexity26]; ChatGPT Health <i>reads insurance documents and reasons about plan trade-offs</i> and reports ~230M people asking health questions on ChatGPT weekly [TechCrunch26]. If we position on the chatbot, we lose.	market	High	High	Do not compete on the chatbot. Win on the unowned four-pillar fusion — longitudinal record + biomarker trends + insurance/cost navigation + AI grounded in the user’s own data — where no shipped competitor connects the clinical “why” to the financial “how much / how to pay less” (estimate: this exact fusion is currently vacant). Treat record aggregation and AI as ingested inputs; make cost-navigation (SBC parsing, OOP projection, cost analysis) the differentiated, daily-use surface.	A big-AI entrant or a cost player (Sheer Health is the most plausible [NCHN25]) bolts a cost/bill layer onto an AI record product; our “fusion” demo no longer feels distinct in user testing.
R5	Platform dependence — Apple/Google policy + the ChatGPT Health distribution gravity well. Web-only today (no native, no PWA) caps reach and push: PWA-reachable push audience on iOS is (estimate) ~10–15× smaller than native (manual home-screen install gates web-push) [MagicBell26], and push is the channel that drives a daily health habit. Going native invokes Apple §5.1.3 (no health-data ad/data-mining), §5.1.1(v) in-app account deletion [Apple], and Google Play’s Jan 2026 rules: org account + D-U-N-S required, “incidental use” path eliminated, mandatory “not a medical device” disclaimer [MyAppMon26]. Meanwhile distribution gravity favors the incumbents’ AI surfaces.	product / growth	Med	Med-High	Ship an installable PWA now (manifest + service worker + web push + “add to home screen” coaching after a value moment) to recover most native engagement/retention cheaply without the store burden; plan the native build <i>and</i> Play org/D-U-N-S verification + Apple health-disclaimer/privacy-manifest work ahead of submission; design to store policies from day one (clean privacy labels, in-app deletion, disclaimers) so platform compliance and trust messaging are the same artifact. Note HealthKit read is native-only — the strongest single later reason to go native [Apple].	A store policy update tightening health-app rules; Play org-verification deadline (Jan 28 2026) pressure; flat retention attributable to no push/no home-screen presence; rising share of “I just use ChatGPT for this” in user interviews.

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R6	Cost-navigation rail — our differentiator — is closeable in a ~12–24 month window (estimate). The seam between health and cost is currently unowned, but ChatGPT Health is <i>adjacent</i> (it already reads insurance docs) and Sheer Health is adjacent from the cost side [NCHN25]. The window is the differentiator, not a permanent moat.	market	Med	High	Deepen the cost rail into a real reasoning loop (“LDL trending up over 3 draws → cheaper in-network panel / generic statin price → this bill has a coding error”) that a generalist chatbot can’t replicate from un-fused data. Concrete next step: instrument <i>cost-surface engagement</i> as an activation sub-metric — target ≥30% of activated users open a cost projection within their first 14 days (proposed target) — and ship at least one fused clinical→cost insight in the SBC/cost-analysis path before open launch. Build proprietary value in the fusion + the user’s own structured longitudinal record.	A competitor announces a cost/insurance feature welded to a health record; press framing of “health + cost in one place” attached to another brand; cost-surface engagement tracking below the activation target.

Tier 3 — Product, monetization, financial & execution risks

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R7	No cash register — Stripe is not wired. The “Upgrade” button is a literal placebo; plan assignment is admin/DB-only. A D2C product that cannot take money is a free demo, and the fake CTA erodes first-contact trust. Launch blocker.	product / financial	High (current state)	High	Wire Stripe Checkout + webhook to <code>users.plan</code> / <code>planExpiresAt</code> ; handle cancel/downgrade/failed-payment; email receipts; replace the placeholder handler. Map to existing FREE/PRO plan-gating infra.	Motivated users hitting the upgrade wall and emailing support; \$0 realized revenue despite over-limit events.

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R8	Weak retention on a low-frequency record + no habit surface. H&F apps churn ~9.2%/month [RetCheck26] , ~3% D30 retention [Adapty26] , with ~44% of cancellations in the first 90 days [Adapty26] ; new data arrives only a few times/year (auto-sync is Quest-only and PRO-gated), so daily-habit fuel is thin, and re-engagement is email-only with no push, streaks, or referral loop.	product / growth	High	High	Build the longitudinal “trend/fresh-data” hook as the retention product (every entry must extend a continuous timeline, not create an orphan row); add reminder/nudge loops, streaks/milestones (streaks correlate with materially higher DAU, secondary data [Plotline25]), and a working re-engagement loop measured on D7/D30; widen auto-sync beyond Quest over time; PWA push for daily prompts.	D7/D30 below H&F benchmark renewal curve; <3 sessions in first 14 days (3–4× churn predictor [Adapty26]); engagement concentrated in one-time uploads.
R9	Freemium top-of-funnel without the harder-paywall test → too few payers. Freemium converts ~5× worse than a hard paywall (~2.1% vs ~10.7% download-to-paid [RC25]). Building freemium-first is correct for trust/funnel, but if we never run the pricing experiment we undermonetize.	financial / growth	Med	Med	Launch freemium + a 17–32 day trial on annual — long trials convert far better than 3–7 day (~42–46% vs ~26% median [RC26] [Airbridge26]) — with an onboarding-placed paywall echoing the user’s stated goal [Airbridge26] . Proposed price anchor: ~\$9.99–12.99/mo list with annual at ~\$69.99/yr (~\$5.83/mo) — a product decision, set at the software-only premium-health convergence point (Calm/Headspace/Oura all anchor annual at ~\$69.99 [ChoosingTherapy25]), and consistent with the ~\$6/mo WTP comparable in R16. Instrument renewal curve + Day-60 ARPU; once retention ≥ H&F benchmarks + runway + A/B tooling (chosen preconditions, not benchmarks), test a harder gate on new-install cohorts (freemium control held out, existing users grandfathered), decide on ARPU/LTV not raw conversion %.	Conversion stuck near ~2–4% with no experiment running; ARPU flat; no paywall A/B infrastructure in place.

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R10	Document AI OCR cost is uncapped (H-3) — a surprise five-figure GCP bill the moment billing opens. The \$50/day circuit-breaker bounds only Claude tokens; Google Document AI is per-page and not dollar-tracked. A malicious or runaway user can drive unbounded OCR spend, a direct path to cost-runaway and/or self-inflicted DoS on a solo-founder budget.	financial / security	Med-High	Med-High	Accrue Document AI page cost via <code>trackAIUsage</code> so it counts against the daily/per-user budget and fail-closes with 503 like the Claude path; cap free-tier OCR pages; close the documented plan-limit bypass (M12/M13) and quota TOCTOU races (backstopped today only by the dollar cap).	Daily GCP Document AI line item rising faster than active users; a single user generating outsized OCR page volume; budget alert thresholds breached.
R11	No viral/growth loop at all — the product cannot grow itself. Zero referral/invite/promo system; provider sharing is inbound-only (patient can't invite their doctor/family); the in-code "Team/family" tier has no multi-member/invite model — it is just higher numeric limits on a single account. This directly undercuts R1's organic strategy.	growth / product	High (current state)	Med-High	Build a double-sided, activation-gated referral program (WhatsApp/SMS-native, à la Whoop <code>[Talkable22]</code>); add patient-initiated sharing (invite-your-doctor / share-a-result link) and a real multi-member model behind the Team tier — family/household sharing only; this is consumer household sharing, not employer/seat licensing; instrument K-factor.	Referral K-factor ~0; "Team" purchasers with no one to invite; WOM not showing up in attribution.
R12	PHI-handling vendor in the email path (SendGrid) is not HIPAA-eligible / won't sign a BAA [SG] . Notifications could leak PHI to a non-BAA processor.	regulatory / security	Med	Med-High	Prove email templates are strictly PHI-free, or swap to a HIPAA-eligible provider (Paubox/LuxSci); document the decision in the BAA inventory.	A notification/email template found to contain biomarker values, names, or insurance details.

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R13	Multi-instance correctness seams force <code>--max-instances=1</code> (H-2), blocking autoscale for a launch spike. In-memory stores (spend accumulator, FHIR PKCE map, token blacklist, rate-limiter) are per-process until Redis exists; pinning to one instance means a viral/PR spike has no headroom, and the dollar cap dilutes N× if unpinned.	product / execution	Med	Med	Provision Cloud Memorystore/Redis, set <code>REDIS_URL</code> , remove the <code>--max-instances=1</code> pin; verify FHIR connect, exact spend cap, and rate limits across ≥2 instances before any launch that could spike traffic.	A PR/Product-Hunt spike hitting the single-instance ceiling; FHIR connect failures under load; spend cap behaving inconsistently.
R14	AI medical-advice / FDA-positioning slip. An AI guide grounded in personal health data risks crossing from “wellness information” into “diagnose/treat” territory; the FDA judges the <i>totality of claims</i> , so a marketing line can override a policy disclaimer <code>[HoganLovells]</code> .	regulatory	Med	Med-High	Prominent, consistent “not medical advice / consult a professional” disclaimers; AI never the sole basis for clinical action; align <i>all</i> marketing copy with the wellness positioning; enforce the disclaimer on every advice path (incl. cost analysis) as a tested invariant; keep the existing spend/usage guardrails.	Marketing or AI output drifting into diagnostic/treatment claims; a cost-advice response shipping without the enforced disclaimer; app-store reviewer rejection on medical claims.
R15	Solo-developer / key-person + program-maturity gap. ~96K lines built primarily by one developer with heavy AI assistance; no Security Officer, no written policies, no incident-response/DR runbooks. Bus-factor of one is an existential execution + diligence risk.	execution / security	Med	High	Name a Security Officer; author the core §164.316 policies + breach/IR + DR runbooks (pull breach-response forward; defer training/sanction/formal risk-analysis to post-first-cohort); document the codebase; reduce single-points-of-failure before a raise (diligence will probe this).	A critical bug only one person can fix; stalled progress during any absence; investor diligence questions on team depth and security ownership.

#	Risk	Category	Likelihood	Impact	Mitigation	Early-warning signal
R16	Misframing the market / over-stated TAM in the raise. Capital is barbelled toward AI-native, clearly-differentiated stories (AI = ~54% of 2025 US digital-health VC dollars; fitness & wellness re-rated from 8th- to 3rd-most-funded value prop) [RockHealth26], but standalone PHR and consumer cost-tools have historically weak paid WTP. Presenting the ~\$140B US / ~\$493B global “digital health” TAM [NovaOne25] [IMARC25] as our SAM, or leading with PHR-as-paid-product, invites diligence pushback.	financial / market	Med	Med	Anchor SAM on the ~\$12B US mHealth base (~11% CAGR [GVR24]); treat PHR (~\$10B global, low-single-digit growth [RandM25]) and consumer price-transparency (~\$2B, B2B-skewed [TBRC26]) as <i>feature value</i> not separate pools; lead the narrative with the highest-confidence tailwinds (KFF: 34% of covered workers now have a \$2,000+ single deductible [KFF25]; ONC: 65% accessed records online, 57% via an app, 2024 [ONC25]) + the AI-native fusion differentiation + reopened exits (5 health IPOs in 2025 [RockHealth26]); price WTP off the proven ~\$6/mo Oura-style insight anchor [Oura25] (which our ~\$69.99/yr ≈ \$5.83/mo annual ties to, see R9), not PHR utility.	Investor pushback on TAM definition or retention/WTP assumptions; pitch leaning on PHR storage rather than the cost+AI fusion.
R17	Intent-vs-behavior gap in cost-shopping + AI-trust deficit. ~64% of Americans have never price-shopped care (though ~58% say they would with upfront costs) [Fierce24], and ~30% of AI-health non-users cite distrust (up from ~23%) [RockHealthAI25]. The wedge depends on behavior consumers say they want but rarely do.	market / growth	Med	Med	Reduce friction to the “aha” — make cost insight automatic from uploaded SBC/labs rather than requiring active shopping; pair AI output with accuracy/safety framing grounded in the user’s own data to counter distrust. Concrete next step: treat cost-surface engagement as an activation sub-metric (shared with R6) — target ≥30% of activated users open a cost projection in their first 14 days (proposed target) — and report it alongside record engagement, not just record usage.	Cost-navigation features with low engagement despite stated demand; AI features under-used; “I don’t trust it” feedback.

Go / No-Go Kill-Criteria Gates

Gates run **in order**. Do not advance to a later gate (or open the wallet on growth) until the earlier gate's criteria are met. This operationalizes the three-gate thesis (Compliance/Legal → Product-Hardening → Distribution/Growth) and the Tier-1 risks.

Gate 0 — Compliance / Legal (before ANY paying consumer)

No-Go until ALL true:

- Breach-detection alerting live, routed to a **named** Security Officer / on-call; breach-response runbook exists (HBNR 60-day clock can start [FTC24]).
- BAAs signed (or proven PHI-free path) for **Google Cloud SQL/GCS + Document AI**; SendGrid PHI-free-or-swapped [SG] ; Quest agreement in place before FHIR is enabled in prod.
- **L24 legacy plaintext PHI backfill run** and plaintext column dropped.
- **Zero** ad/analytics/tracker SDKs firing on any PHI path without explicit opt-in (the GoodRx/BetterHelp/Premom/Flo failure mode [FTC-GR][FTC-BH]).
- Standalone Consumer Health Data Privacy Policy (WA [KL Gates] + NV SB 370 [Orrick]) + general privacy policy + ToS + AI medical-advice disclaimer **published**; stale README "0 findings / fully encrypted" claims retracted.
- **TOTP MFA + recovery shipped** — treated as a Gate-0 must-have, not optional: this account is the user's medical record and insurance member IDs, account takeover = direct PHI breach, and R2 lists "no MFA" among the launch-blocking trust deficits. (Recovery codes + a tested no-support-human recovery path ship in lockstep so MFA can't create permanent lockouts.)

Gate 1 — Product-Hardening (before public launch)

No-Go until ALL true:

- **Stripe self-serve billing live** (subscribe / cancel / failed-payment / receipts) — the Upgrade button is real.
- Onboarding funnel walked end-to-end on a fresh account with **every step doing real work**; the four known trust-breakers verified fixed **end-to-end** (not just per changelog).
- Controller/route tests cover the **five untested PHI/upload/AI/FHIR seams**.
- **H-3 Document AI OCR spend capped** in dollars; free-tier OCR pages bounded; plan-limit bypass (M12/M13) closed.
- **H-2 resolved** (Redis provisioned, --max-instances=1 pin removed) **or** a documented launch-scale cap accepted.
- Installable **PWA** shipped (push + home-screen) — a real mobile habit surface exists.
- Activation instrumented ("first biomarker in session 1"; cost-surface engagement per R6/R17); closed beta passed without trust-breaker reports.

Gate 2 — Distribution / Growth (before scaling spend)

No-Go on paid acquisition until ALL true:

- D7/D30 retention **at or above H&F benchmarks** [Adapty26] ; ≥3 sessions in first 14 days for activated users.

- A working **referral loop** live with measurable K-factor > 0.
- Owned organic engines (content/SEO, ASO, founder/clinician authority) showing compounding traffic.
- **LTV:CAC ≥ 3:1** with CAC payback < 12 months on early cohorts — these are **chosen go/no-go thresholds** (the 3:1–4:1 healthy band is sourced [Userpilot26] ; the specific gate is our decision).
- Paywall A/B infrastructure in place to run the harder-paywall pricing experiment on ARPU.

Standing kill-criteria (any one = halt + reassess)

- A **breach or FTC/state-AG (incl. WA MHMDA) action** — existential; stop-the-line.
- Tracker/SDK discovered leaking health data → immediate remediation before any further launch.
- After a genuine, retention-first organic push, **LTV:CAC cannot clear 3:1** and no channel shows a path to it → the core D2C unit economics don't work; pivot or stop.
- A big-AI/cost incumbent **welds cost-navigation to a health record** and our fusion no longer tests as differentiated → revisit the wedge before further spend.

Sources

External figures are keyed to the research brief's cited sources (name + date). Tags marked (*secondary*) are vendor/aggregator roundups — directional, not audited.

- [RC25] / [RC26] — RevenueCat, *State of Subscription Apps 2025 / Subscription App Trends & Benchmarks 2026* (download→paid 10.7% hard vs 2.1% freemium; trial-length conversion; annual mix).
- [Adapty26] — Adapty, *Health & Fitness App Subscription Benchmarks 2026* (~3% D30 retention; ~2.2% freemium download→paid; 44% of cancellations in first 90 days; renewal curve; annual vs monthly retention; 3+ sessions/14-day churn predictor; H&F refund 4.71%).
- [Airbridge26] — Airbridge, *Hard Paywall vs Freemium 2026 / App Onboarding Before the Paywall* (May 2026) (trial-length conversion; onboarding-placed paywall; harder-paywall transition preconditions).
- [Phoenix25] — Phoenix Strategy Group, *CAC Benchmarks by Channel 2025* (CPI iOS \$4.70 / Android \$3.70; cross-channel CAC +40–60% 2023→2025; Facebook CAC ~\$230 baseline).
- [Userpilot26] — Userpilot, *Average CAC Benchmarks 2026* (LTV:CAC 3:1–4:1 healthy band).
- [Talkable22] — Talkable, *Whoop referral case study* (Jan 2022) (double-sided referral; >10% of sign-ups).
- [GCS24] — Growth Case Studies, *Flo Growth Case Study* (2024) (~6M monthly search visitors; content/calculator engine; WOM dominant).
- [Sacra25] — Sacra, *Function Health / Levels* (Sam Corcos) (2024–2025) (founder/creator-led earned-media playbook).
- [Plotline25] (*secondary*) — Plotline / *Trophy.so, Streaks & gamification* (2025) (streaks → higher DAU; magnitudes directional).
- [RetCheck26] — RetentionCheck, *Fitness App Churn 2026* (~9.2% monthly churn).
- [ChoosingTherapy25] / [Oura25] — Calm/Headspace via ChoosingTherapy (2025); Oura Membership (~\$69.99/yr software anchor; \$5.99/mo premium).

- **[KFF26]** — KFF / trade press (Jan–Mar 2026) (ChatGPT Health, Copilot Health, Perplexity Health, Claude for Healthcare commoditization wave).
- **[Perplexity26]** — Perplexity blog / mHealthSpot (Mar 2026) (PHR + biomarker trends + AI-on-data; ~1.7M-provider EHR reach via b.well).
- **[TechCrunch26]** — TechCrunch (Jan 7 2026) (ChatGPT Health; ~230M weekly health askers; reads insurance docs / plan trade-offs).
- **[NCHN25]** — NC Health News (Nov 2025) (Sheer Health consumer insurance copilot; cost-side adjacency).
- **[FTC24]** — FTC, *Finalizes Changes to HBNR* (Apr 2024) + *Updated HBNR* blog (60-day notice; 500+ simultaneous FTC notice; effective Jul 29 2024).
- **[JonesDay24]** — Jones Day, *FTC's Final HBNR* (Jul 2024) ("multiple sources" test; unauthorized *disclosure*/ad-tracker sharing = reportable breach).
- **[HBNRpen]** — Federal Register, *Civil Penalty Adjustments* (Jan 10 2024) (up to ~\$51,744/violation, indexed).
- **[FTC-GR]** — HIPAA Journal / FTC (Feb 2023) (GoodRx \$1.5M, first HBNR action).
- **[FTC-BH]** — Arnold & Porter / EPIC (Mar 2023) (BetterHelp \$7.8M — FTC Act §5, not HBNR).
- **[FTC-PM]** — FierceHealthcare / Arnold & Porter (2023) (Premom/Easy Healthcare \$100K — HBNR).
- **[FTC-Flo]** — FTC (Jun 2021) (Flo Health — FTC Act §5).
- **[Cooley]** — Cooley CDP, *MHMDA Enforcement Risks* (WCPA actual damages, trebled up to \$25,000 cap; no statutory damages).
- **[ByteBack25]** — Byte Back / WilmerHale (Feb 2025) (first MHMDA class action, *Maxwell v. Amazon*).
- **[KLGates]** — K&L Gates (Mar 2024) (WA MHMDA standalone Consumer Health Data Privacy Policy requirement).
- **[Orrick]** — Orrick (2023) (Nevada SB 370 consumer-health-data law; AG-enforced).
- **[SG]** — Research brief integration note (SendGrid not HIPAA-eligible / won't sign a BAA; Paubox/LuxSci alternatives).
- **[Censinet]** — Censinet, *SOC 2 vs HITRUST* (voluntary trust signals, not legal gates for pure D2C).
- **[Mozilla]** — Mozilla Foundation, *Privacy Not Included* (2022–2023) (consumer-facing tracker/privacy reviews).
- **[Apple]** — Apple App Store Review Guidelines (§5.1.3 health-data ad/data-mining ban; §5.1.1(v) in-app deletion; HealthKit native-only).
- **[MyAppMon26]** — My App Monitor (Jan 15 2026) (Google Play health-app rules: Org account + D-U-N-S, Jan 28 2026 deadline; "incidental use" eliminated; mandatory disclaimer).
- **[MagicBell26]** — MagicBell / Webscraft (2026) (*secondary, directional*) (iOS web-push reach ~10–15× smaller than native; manual home-screen install gate).
- **[MobiLoud25]** — MobiLoud (2025) (*secondary, directional*) (store presence/ratings as discovery + trust signal).
- **[HoganLoveLLs]** — Hogan Lovells, *AI Wellness or Regulated Medical Device?* (FDA judges totality of claims; marketing can override a policy disclaimer).
- **[RockHealth26]** — Rock Health, *2025 Year-End Digital Health Funding* (Jan 2026) (US digital-health VC \$14.2B, +35%; AI = 54% of dollars; fitness & wellness 8th→3rd value prop; 5 IPOs).
- **[RockHealthAI25]** — Rock Health Consumer Adoption Survey via FierceHealthcare (2025) (AI-health distrust ~30%, up from ~23%).
- **[Fierce24]** — FierceHealthcare (2024) (~64% never price-shopped; ~58% would with upfront costs).

- **[NovaOne25]** / **[IMARC25]** — Nova One Advisor (US digital health ~\$140B, 2025) / IMARC (global digital health ~\$493B, 2024) — broad TAM ceiling, not SAM.
- **[GVR24]** — Grand View Research (2024) (US mHealth apps ~\$12B, ~11% CAGR) — SAM anchor.
- **[RandM25]** — Research and Markets (2025) (global PHR software ~\$10B, low-single-digit growth).
- **[TBRC26]** — The Business Research Company (2025/26) (healthcare price-transparency systems ~\$2B, B2B-skewed).
- **[KFF25]** — KFF 2025 Employer Health Benefits Survey (34% of covered workers have a \$2,000+ single deductible).
- **[ONC25]** — ASTP/ONC Data Brief No. 77 (Jul 2025, fielded 2024) (65% accessed records online; 57% via an app).

*Items marked **(estimate)** are derived planning inferences; items marked **(proposed anchor)** / **(proposed target)** are product decisions we are choosing, not external facts; all other external figures carry an inline source tag keyed above. This is a strategy artifact, not legal advice — confirm statutory text and engage privacy counsel before launch.*